



UNIVERSIDAD NACIONAL EXPERIMENTAL
DE LOS LLANOS OCCIDENTALES
"EZEQUIEL ZAMORA"
VICERRECTORADO DE PLANIFICACIÓN
Y DESARROLLO SOCIAL
PROGRAMA CIENCIAS BÁSICAS Y APLICADAS
SUBPROGRAMA INGENIERÍA EN INFORMÁTICA
BARINAS ESTADO BARINAS



AUDITORIA INFORMÁTICA A LA RED FISICA DEL PEAJE BOCONOITO – AUTOPISTA JOSÉ ANTONIO PÁEZ

Trabajo Especial de Grado presentado para optar al título de:
Ingeniero en Informática

Autor: Rodríguez, Omar Jose
CI:27.576.101
Tutor: Dr. Jairo Archila

Barinas, julio 2025



UNIVERSIDAD NACIONAL EXPERIMENTAL
DE LOS LLANOS OCCIDENTALES
"EZEQUIEL ZAMORA"
VICERRECTORADO DE PLANIFICACIÓN
Y DESARROLLO SOCIAL
PROGRAMA CIENCIAS BÁSICAS Y APLICADAS
SUBPROGRAMA INGENIERÍA EN INFORMÁTICA
BARINAS ESTADO BARINAS



ACEPTACIÓN DEL TUTOR

Yo, Jairo Archila, cedula de identidad N.º 11.193.149, hago constar que he leído el proyecto de Trabajo Especial de Grado, **AUDITORIA INFORMÁTICA A LA RED FISICA DEL PEAJE BOCONOITO - AUTOPISTA JOSÉ ANTONIO PÁEZ**, presentado por el ciudadano: Rodríguez, Omar José CI: 27.576.101, para optar al título de Ingeniero en Informática y acepto asesorar al estudiante, en calidad de tutor, durante el periodo de desarrollo del trabajo hasta su presentación y evaluación.

En la ciudad de Barinas, a los 20 días del mes de Junio del año 2025.

Nombre y Apellido: Jairo Archila
Firma de aprobación del tutor

11.193.149

ÍNDICE GENERAL

	Pp.
Dedicatoria.....	iii
Agradecimiento.....	iv
Índice General.....	v
Índice De Cuadros.....	vi
Índice De Figuras.....	vii
Índice de Gráficos.....	viii
Resumen.....	ix
Introducción	1
 CAPÍTULO I. EL PROBLEMA	 3
Planteamiento del Problema	3
Objetivos de la Investigación	8
Justificación	8
Alcance y Limitaciones	11
 CAPÍTULO II. MARCO TEÓRICO	 12
Antecedentes de la Investigación	12
Bases Teóricas	12
Bases Legales	92
Definición de Términos Básicos	93
Sistema de Variables	100
 CAPÍTULO III. MARCO METODOLÓGICO	 102
Naturaleza de la Investigación	103
Diseño de la Investigación	104
Tipo de la Investigación	104
Modalidad de la Investigación	105
Población y Muestra	105
Técnica e Instrumento de Recolección de Datos	106
Validez y Confiabilidad del Instrumento	107
 CAPÍTULO IV. RESULTADOS	 109
Análisis e interpretación de resultados	109
 CAPÍTULO V. CONCLUSIONES Y RECOMENDACIONES	 121
Conclusiones	121
Recomendaciones	122
 CAPÍTULO VI. PROPUESTA	 123
 Bibliografía	 140

INDICE DE CUADROS

Cuadro		Pág
1	Perfiles Profesionales y Actividades	44
2	Sistema de Variables	100
3	Operacionalización de Variables	102
4	Población y muestra	106
5	Resultados Item 1	110
6	Resultados Item 2	111
7	Resultados Item 3	112
8	Resultados Item 4	113
9	Resultados Item 5	114
10	Resultados Item 6	115
11	Resultados Item 7	116
12	Resultados Item 8	117
13	Resultados Item 9	118
14	Resultados Item 10	119
15	Resultados del cuestionario en el dominio A9. Control de Acceso	126
16	Listado de vulnerabilidades del dominio A9. Control de Acceso	129
17	Calculo de análisis de riesgo del dominio A9. Control de Acceso	130
18	Matriz de riesgos del dominio A9. Control de Acceso	131
19	Resultados del cuestionario en el dominio A11. Seguridad Física y del Entorno	
20	Listado de vulnerabilidades del dominio A11. Seguridad Física y del Entorno	133
21	Calculo de análisis de riesgo del dominio A11. Seguridad Física y del Entorno	136
22	Matriz de riesgos del dominio A11. Seguridad Física y del Entorno	138

INDICE DE FIGURAS

Figura		Pág.
1	Las tres dimensiones conceptuales de COBIT	80

INDICE DE GRÁFICOS

Gráfico		Pág.
1	Resultados Item 1	110
2	Resultados Item 2	111
3	Resultados Item 3	112
4	Resultados Item 4	113
5	Resultados Item 5	114
6	Resultados Item 6	115
7	Resultados Item 7	116
8	Resultados Item 8	117
9	Resultados Item 9	118
10	Resultados Item 10	119



UNIVERSIDAD NACIONAL EXPERIMENTAL
DE LOS LLANOS OCCIDENTALES
"EZEQUIEL ZAMORA"
VICERRECTORADO DE PLANIFICACION
Y DESARROLLO SOCIAL
PROGRAMA CIENCIAS BÁSICAS Y APLICADAS
SUBPROGRAMA INGENIERÍA INFORMÁTICA



AUDITORIA DE RED FISICA DEL PEAJE BOCONOITO – AUTOPISTA JOSÉ ANTONIO PÁEZ

Línea de Investigación: Auditoria Informática

Autor: Br. Rodríguez, Omar

Tutor: Dr. Jairo Archila

Año: 2025

RESUMEN

El estudio de investigación tiene como objetivo general Realizar una Auditoría de Red Física en la evaluación de asociados en el Peaje Boconoito ubicado en la autopista José Antonio Páez del estado Portuguesa. Dentro de las teóricas empleadas se presenta la teoría de evaluación de riesgos y como principales constructos teóricos se tiene la definición de proceso de control, componentes del control interno basado en la metodología Objetivos de Control para la información y Tecnologías relacionadas (COBIT), todos muy relevantes para fundamentar la investigación. El estudio se abordó bajo un diseño de campo, de nivel descriptivo, enmarcado en un proyecto factible. Los datos se recolectaron mediante la técnica de la encuesta, y la aplicación del cuestionario como instrumento de la investigación. Para el logro de este trabajo la población estuvo conformada por seis (06) colaboradores que laboran en el Peaje de Boconoito. De la misma forma la propuesta de una Auditoría informática para evaluación de riesgos en los sistemas, que permitirá al centro de operaciones, adaptar nuevas estrategias en los procedimientos y fortalecer los ya existentes, brindando respuestas y diagnósticos más eficaces en el manejo de riesgos de gestión de la Unidad a fin de garantizar la consecución de sus objetivos específicos y los objetivos estratégicos de la corporación.

Introducción

Las organizaciones actuales requieren mantenerse activas y efectivas en la competencia global; las presiones del entorno, producto del avance tecnológico, las estrategias competitivas, las exigencias de los clientes y todas las variables endógenas y exógenas, determinan un singular juego de oportunidades y amenazas que deben ser oportunamente valoradas. En todo esto, la información y las tecnologías relacionadas que la soportan, producto de las operaciones del negocio, poseen un singular y alto grado de importancia y relevancia como activos de gran valor para la organización y la empresa. Esa información y los procesos de Tecnología de la Información que la planifican y organizan, la generan y administran, y la gerencian y evalúan, deben ser controlados a través de la implantación de técnicas de control efectivas, en procura del cumplimiento de objetivos de control que garanticen la calidad y satisfacción de los procesos alineados con los objetivos del negocio.

La complejidad creciente de las plataformas informáticas, múltiples sistemas de hardware y software, redes globales de comunicación de datos, comercio y negocio electrónico, capacidad de delinquir de los usuarios, generan nuevas amenazas de riesgo para los sistemas de información del negocio. Por todo esto, es necesario, como parte de los planes en materia de gobierno de TI, establecer en las organizaciones una estructura de relaciones y procesos dirigida a controlar la información para alcanzar los objetivos del negocio, adicionando valor mientras se mantiene un balance equilibrado de los riesgos sobre la Tecnología de Información y sus procesos.

La presente investigación plantea en el Capítulo I, un estudio del problema de control y seguridad de la información y las tecnologías relacionadas; en el Capítulo II se presenta un estudio documental de antecedentes de investigación en esta línea y bases teóricas, resaltando el papel fundamental de la investigación adelantada desde el año 1996 por la

ISACF (Information System Audit and Control Foundation) y el IT Governance Institute que ha producido el proyecto COBIT, resumiendo las mejores prácticas de aceptación universal para el tratamiento del problema de control de TI. En el Capítulo III se presenta el Marco Metodológico de la presente investigación, aplicada como caso de estudio real, la Red Física del Peaje Boconoito – Autopista José Antonio Páez permitió la aplicación de los instrumentos para la presente investigación y la realización del diagnóstico situacional referido al problema en estudio.

Finalmente, en el Capítulo IV, se presenta resultados preliminares del estudio, posteriormente el Capítulo V, se muestran conclusiones y recomendaciones y finalmente el Capítulo VI la propuesta factible de desarrollo del Modelo Metodológico de Auditoría de Información y Tecnologías Relacionadas que fundamentado en el proyecto COBIT, propone la aplicación de una serie de métodos y técnicas a través de varias fases, para el tratamiento del problema de evaluación y auditoría, facilitando la comprensión y promoción de la estructura COBIT como modelo practico a seguir.

CAPÍTULO I

EL PROBLEMA

Planteamiento del Problema

Para resaltar la relevancia y significado que los procesos de información y las tecnologías relacionadas tienen para las organizaciones actuales en procura del logro de los objetivos del negocio, resulta muy apropiada la mención de O'Brien (1998) a este aspecto: "La tecnología de la información se ha convertido en una necesidad estratégica, crea en ella, actúe con base en ella o conviértase en un acontecimiento tangencial en la historia".

La revolución tecnológica aplicada a la gestión de la información ha crecido a pasos agigantados en los últimos años. Las organizaciones como sistemas abiertos que son, están relacionadas con su entorno; las empresas y organizaciones están sometidas a presiones e influencias de órdenes económicos, industriales y sociales en los que se encuentran inmersas; en consecuencia, si las tendencias tecnológicas y los entornos económicos e industriales cambian, deben adaptarse rápidamente a las nuevas circunstancias para sobrevivir. Como cita Rodríguez (1998) en la presentación de Piattini y Del Peso (1998) "Una de las tendencias actuales más significativas es la que nos ha dirigido desde una Sociedad Industrial hacia una llamada Sociedad de Información".

Los cambios suceden muy rápido respecto a los procesos de adaptación de las organizaciones; están afectando al mundo entero, y su comprensión es fundamental para las organizaciones de todo tipo,

particularmente en el contexto de los Sistemas de Información (SI) y Tecnologías de la Información y las Comunicaciones (TIC). Aunque los avances tecnológicos han sido constantes y espectaculares, en los últimos veinte años se ha producido una verdadera revolución tecnológica de gran impacto para la propia industria informática, así como de consecuencias importantes para el resto de los sectores.

En consecuencia, cada vez, un mayor número de organizaciones considera que la información y la tecnología asociada a ella representan sus activos más importantes. De igual modo que se exige para los otros activos de la empresa, los requerimientos de calidad, controles, seguridad e información sobre los procesos de datos e información y sobre la tecnología relacionada son indispensables.

En este sentido, la gerencia debe establecer un sistema de Control Interno adecuado que minimice los riesgos producidos por la aplicación de la tecnología informática. Tal sistema debe soportar debidamente los procesos del negocio a través de la garantía de seguridad de los sistemas de información. Por lo tanto, el nivel o estado de la seguridad de información y las tecnologías relacionadas en una organización, es un objetivo a evaluar de primer orden. El cumplimiento de este objetivo, es la función principal de la evaluación y el control informáticos.

El continuo y creciente desarrollo de sistemas de información basados en el uso de computadoras y otras tecnologías de procesos, gestión y comunicación de información, ha convertido al computador en una herramienta indispensable en las organizaciones, proporcionándole un control más efectivo sobre sus recursos y operaciones, como también en la ejecución propia de esas operaciones. Sin embargo, esos mismos sistemas tienen cada vez, un mayor número de personas preocupadas debido a que el control computarizado de los activos, el fácil acceso a la información y la creciente dependencia de la tecnología pueden convertir a las organizaciones en entes más vulnerables que nunca, cuestionándose en este sentido en qué

medida están sus sistemas de información adecuadamente controlados contra los riesgos informáticos.

A pesar de los grandes adelantos tecnológicos y de su aplicación al procesamiento de datos y gestión de información en lo que se ha llamado Tecnologías de la Información y las Comunicaciones (TIC), la incorporación de este importante recurso a las operaciones y gestión de la información en la organizaciones ha generado una problemática particular que se ha hecho evidente en múltiples organizaciones alrededor del mundo. Como lo cita Rodríguez (1998) presidente de la Organización de Auditoría Informática, Capítulo español de ISACA, (Information Systems Audit And Control Association), en la presentación de Piattini y del Peso (1998),

“...la situación actual de los sistemas de información en las organizaciones se caracteriza frecuentemente por una falta de asimilación de las nuevas tecnologías, por una infrautilización de los equipos informáticos, por un descontento generalizado de los usuarios, por una obsolescencia de las aplicaciones informáticas actuales, por una falta de planificación de los Sistemas de Información, y por soluciones planteadas parcialmente que, al no estar integradas, producen islotes de mecanización y de procesos manuales, en muchos casos redundantes e/o incoherentes, difíciles de controlar y caros de mantener. En definitiva, por una falta de estándares y metodologías, y por una falta de formación y cultura generalizada, sobre todo en los aspectos de control y de seguridad informática. La auditoría informática ha aportado soluciones, en el pasado, para estos problemas; pero se ha realizado frecuentemente, hasta ahora, solo en grandes empresas y, en la mayoría de los casos, como un complemento de la auditoría financiera...”

Cada día, son mayores las inversiones en tecnologías de información y mayor la dependencia del negocio de las estructuras informáticas; los sistemas de control y seguridad de la información exigen mayor rigurosidad en áreas tan diversas como la planificación de proyectos, la organización de

la unidad de informática, la dirección y gestión de los recursos informáticos, la administración y control de infraestructuras e instalaciones, el desarrollo y mantenimiento de aplicaciones, la explotación de los sistemas de información, las bases de datos, las comunicaciones y redes, la ofimática, la seguridad general y particular, los recursos humanos y la calidad.

La globalización ha impuesto nuevos retos de competencia, las organizaciones se deben reestructurar hacia operaciones cada vez más competitivas y, como consecuencia deben aprovechar los avances de las tecnologías de los sistemas de información para mejorar su situación competitiva. Hoy en día se habla de reingeniería de negocios y de procesos, de calidad total, de procesos distribuidos, de organizaciones planas, de múltiples tipos de sistemas de información: MIS (Management Information System), EIS/DSS (Executive Information System)/Decision Support Systems), ERP (Enterprise Resource Planning), CRM (Customer Relationship Management) y otros, como cambios que generan un impacto en la manera en que operan las organizaciones privadas y públicas. Estos cambios están teniendo y continuaran teniendo implicaciones profundas para la gestión y para las estructuras de control en todas las organizaciones.

Todo lo anterior deriva en qué la previsión, el control, la seguridad, y la reducción de costos, implicados en los sistemas de información son una estrategia fundamental de las organizaciones actuales. La automatización de las funciones y procesos de la organización, por su propia naturaleza, genera una mayor dependencia de mecanismos de control en las computadoras y redes desde el punto de vista del hardware y del software. La aplicación de la informática al proceso del negocio crea o genera unos riesgos informáticos de los que hay que proteger y preservar a la organización con un conjunto de controles, y la calidad y eficacia de estos controles es el objetivo central a evaluar para poder identificar los puntos débiles y mejorarlos. Esta es una de las funciones de las Auditoría Informática.

En este caso se presenta el Peaje Boconoito ubicado en la Autopista

José Antonio Páez, dentro del mismo han venido sucediendo varios eventos en la red de comunicación de datos a nivel físico, considerándose a llegar a pensar en sabotaje interno y/o externo ya que en algunas oportunidades el sistema de cobranza ha dejado de funcionar por problemas de comunicación, a pesar de existir vigilancia a través de cámaras, las suspensiones del servicio eléctrico deja sin operatividad los sistemas mientras la planta eléctrica enciende, el área de operaciones no es un área aislada de la empresa, todo el personal tiene acceso a la entrada de esta área, incluso se ha visto entrar personas que no pertenecen a la empresa, el personal que labora en taquilla es rotativo lo cual pudiese afectar la situación, el personal de informática no se encuentra en la localidad sino que viene de Barquisimeto cuando la falla es mayor, pese a las grandes ventajas que representan los sistemas de información, las amenazas y la vulnerabilidad de estos es una realidad; es por ello que surge en esta investigación la necesidad de evaluar la seguridad y el funcionamiento de la red los datos de información y con ello los riesgos a los que se exponen, así como su resguardo y seguridad, es un tema que cobra cada día mayor interés. Dicho interés de acuerdo con Cedeño (2008) se debe a que “los sistemas de información concentran los datos en archivos de computadoras que son una vía de fácil acceso” (p.52), esto hace posible que un gran número de personas de a la organización no autorizados, los manipule, tal situación con lleva a que la información sea mucho más asequible, y susceptible a modificaciones que puedan producir destrucción, fraude o error.

Para estar a la altura de las circunstancias, es necesario que los usuarios se pongan al día en cuanto a la tecnología y entorno de la Auditoría Informática, y para acceder a este nuevo paradigma debe tratarse el problema de minimizar la complejidad de los procesos de evaluación y control de los entornos de aplicación de las tecnologías de la información. En tal sentido, un modelo de registro de planes, recursos, procesos, riesgos, controles y guías de evaluación y control de los sistemas de información y

sus tecnologías, favorecerá y facilitará la función de Evaluación y Auditoría Informática en la Organización. En resumen, se plantean entonces los siguientes interrogantes: ¿Qué tipo de riesgos se encuentran presentes en la red de datos del Peaje Boconoito?, ¿Qué factores deben considerarse para establecer controles internos dentro del Peaje Boconoito?, ¿Cuáles son las estrategias a considerar con base en los resultados obtenidos a partir de la valoración realizada?

Objetivos de la Investigación

Objetivo General

Realizar una Auditoria Informática A La Red Fisica Del Peaje Boconoito – Autopista José Antonio Páez

Objetivos Específicos

Analizar los riesgos presentes en la red Fisica del Peaje Boconoito – Autopista José Antonio Páez.

Determinar factores que deben considerarse como controles internos dentro del Peaje Boconoito – Autopista José Antonio Páez.

Verificar los resultados obtenidos a través de un informe con recomendaciones a partir de la valoración realizada en Peaje Boconoito – Autopista José Antonio Páez.

Justificación de la Investigación

La importancia del estudio que intenta desarrollar el presente proyecto se fundamenta en cuatro aspectos característicos de la información como activo empresarial y en la conceptualización y aplicación de la estructura de

la arquitectura de información y de los procesos soportados en Tecnología de Información (TI) en las organizaciones actuales. Estos aspectos son:

El Valor de la Información en las Organizaciones: si se parte del conocimiento previo de qué la Información representa un activo de singular valor para las organizaciones, y que todos los procesos del negocio se sustentan en el procesamiento de datos y administración de información para soportar la toma de decisiones y mantener la estabilidad y rentabilidad del negocio, es necesario entender que la tecnología relacionada con la información y sus procesos representa un punto de enfoque de especial importancia para la estabilidad empresarial.

Existen principios generalmente aceptados en las buenas practicas, reconocidas internacionalmente por los expertos en la materia de Control y Auditoría de Información y Tecnologías relacionadas; por tal razón, toda investigación que esté sustentada en el marco referencial de las mejores prácticas y persiga la aplicabilidad de sus principios, está dotada de una singular importancia.

Las metodologías de Auditoría informática deben cubrir todos los aspectos de la información y de la tecnología que la soporta. Los Objetivos de Control deben encararse con referencia a las políticas y estándares de la empresa, el propietario del proceso del negocio debe asegurar que se provee un sistema de control adecuado para el ambiente de tecnología informática.

Integración de los Recursos de los Sistemas de Información: el presente estudio está orientado a obtener un producto, que permitirá aplicar modelos de evaluación y control sobre las diferentes actividades y/o tareas, procesos y áreas de aplicación de las Tecnologías de Información bajo el enfoque de aplicación de los diferentes objetivos de control formulados para cada ámbito integrando los recursos y/o componentes de un sistema de información: personas, datos, software (programas), hardware (equipos y facilidades), redes y comunicaciones, información, actividades, conocimiento y bases de conocimiento, retroalimentación (autocontrol), procedimientos e

instalaciones físicas.

Requerimientos de información: Los recursos anteriores se integran para satisfacer los requerimientos del negocio en cuanto a la calidad, aspectos financieros y seguridad (control de riesgos) sobre los criterios de información para optimizar su uso. Comenzando el análisis desde los requerimientos amplios de calidad, financieros y seguridad, se deben contemplar las características de la información que satisfacen los criterios de efectividad, eficiencia, confidencialidad, integridad, disponibilidad, cumplimiento y confiabilidad.

La Estructura de Cobertura Global de la TI: los procesos básicos de información basados en la aplicación de tecnología informática comienzan en las actividades y tareas necesarias para lograr un resultado mensurable. Las actividades tienen un concepto de ciclo de vida mientras que las tareas son consideradas más discretas. El concepto ciclo de vida tiene requerimientos típicos de control diferentes de las actividades discretas. Ejemplos de la primera categoría son las actividades de desarrollo de sistemas, administración de la configuración y administración de los cambios. La segunda categoría incluye tareas realizadas en soporte de planeamiento estratégico de Tecnología Informática, evaluación de riesgos, planeamiento de calidad, administración de capacidad y performance. Al más alto nivel, los procesos son agrupados naturalmente en dominios, su agrupamiento natural es a menudo confirmado como dominios de responsabilidad en una estructura organizacional y está en línea con el ciclo de administración o ciclo de vida aplicable a los procesos de Tecnología Informática.

La observación en todos los aspectos mencionados anteriormente para el diseño de un modelo de auditoría, evaluación y control de los procesos de información y de la tecnología relacionada con estos procesos, permitirá la generación de una estructura conceptual y metodológica de fácil conocimiento y aplicación por parte de los usuarios ejecutivos de negocios, profesionales de TI y auditores de sistemas de información, para saber en

qué medida de control se encuentra la organización respecto a la planificación, desarrollo, uso y evaluación de la TI y en consecuencia, fortalecer o corregir los planes de acción en concordancia con los objetivos del negocio.

Alcances Y Limitaciones

Alcances

En el desarrollo del proyecto se identificaron diferentes técnicas de auditoría de sistemas, y se utilizó la más adecuada en cada uno de los casos de estudio.

La aplicación de técnicas de auditoría de sistemas se realizó a la infraestructura de la red de datos de la sede principal del Peaje, con esto se identificó, comprobó y evaluó las vulnerabilidades de seguridad física a la que está expuesta la entidad en su red de datos de la sede principal. Finalmente los resultados de este proceso se plasmaron en este informe que servirá para que la entidad, tome medidas preventivas y correctivas que subsanen los problemas detectados.

Limitaciones

Estas estuvieron principalmente enfocadas a que dentro del peaje no hay un personal de soporte interno sino que por estar en Barquisimeto, la comunicación para recabar la información estuvo un poco difícil por lo que el informante clave no siempre estuvo disponible.

CAPÍTULO II

MARCO TEÓRICO

Esta Esta sección está elaborada en función de las necesidades de la investigación y se compone de varios elementos que constituyen su propósito teórico. Según Arias (2012), “El marco teórico o marco referencial, es el producto de la revisión documental–bibliográfica, y consiste en una recopilación de ideas, posturas de autores, conceptos y definiciones, que sirven de base a la investigación por realizar” (p.106). En el presente proyecto incluye los antecedentes de la investigación, bases teóricas, bases legales, operacionalización de las variables, y definición de términos básicos. A continuación, se presentan algunos antecedentes históricos vinculados con el desarrollo de este trabajo.

Antecedentes de la Investigación

Según Arias (2012) “Los antecedentes reflejan los avances y el estado actual del conocimiento en un área determinada y sirven de modelo o ejemplo para futuras investigaciones.”. (p106). Por lo tanto, los antecedentes son esenciales ya que permiten contextualizar el estudio y entender cómo se ha desarrollado el conocimiento en el área en cuestión. Estos antecedentes no solo destacan los hallazgos previos, sino que también identifican vacíos

en la literatura que la nueva investigación puede abordar, orientando así el enfoque y la relevancia del trabajo a realizar.

Oliva Guedes, D. (2024) **Auditoría de Seguridad Informática en la evaluación de riesgos de los sistemas en la Corporación Digicable, C.A.**

El estudio de investigación tiene como objetivo general Realizar una Auditoría de Seguridad Informática en la evaluación de riesgos de los sistemas en la Corporación Digicable, C.A., Barinas, Estado Barinas. Dentro de las teóricas empleadas se presenta la teoría de evaluación de riesgos y como principales constructos teóricos se tiene la definición de proceso de control, componentes del control interno basado en la metodología Objetivos de Control para la información y Tecnologías relacionadas (COBIT), todos muy relevantes para fundamentar la investigación. El estudio se abordó bajo un diseño de campo, de nivel descriptivo, enmarcado en un proyecto factible. Los datos se recolectaron mediante la técnica de la encuesta, y la aplicación del cuestionario como instrumento de la investigación. Para el logro de este trabajo la población estuvo conformada por veintisiete (27) colaboradores que laboran en la corporación digicable, C.A., De la misma forma la propuesta de una Auditoría informática para evaluación de riesgos en los sistemas, que permitirá al centro de operaciones, adaptar nuevas estrategias en los procedimientos y fortalecer los ya existentes, brindando respuestas y diagnósticos más eficaces en el manejo de riesgos de gestión de la Unidad a fin de garantizar la consecución de sus objetivos específicos y los objetivos estratégicos de la corporación.

Cortes Camacho, J. (2016) **Auditoría A La Seguridad De La Red De Datos De La Empresa Peaje Boconoito** Proyecto De Grado Para Optar Al Título De: Especialista En Seguridad Informática. Universidad Nacional Abierta Y Distancia "UNAD" Facultad De Ciencias Básicas E Ingeniería Especialización En Seguridad Informática San Juan De Pasto, Colombia.

El presente proyecto aplicado, tiene como finalidad realizar una auditoría de seguridad a la red de datos de la empresa Peaje Boconoito en la

ciudad de San Juan de Pasto el cual tiene por objetivo formular controles y procedimientos con el fin de establecer un sistema de gestión adecuado, identificando vulnerabilidades y amenazas por medio de pruebas de penetración y los procesos de auditoria de sistemas.

Para el desarrollo de la auditoria se aplicaran las cuatro fases:

La primera consiste en la recolección de la información pertinente a la red de datos, por medio de visitas técnicas guiadas y verificando la documentación existente a los procesos de servicio de red.

En la segunda fase de planeación, donde se seleccionaran los respectivos instrumentos de auditoria para la recolección de información y las pruebas de penetración a ejecutar en la red de datos de la empresa Peaje Boconoito, como también la normatividad a aplicar en la presente auditoria.

En la tercera fase de ejecución, se aplicaran los instrumentos seleccionados y las pruebas de penetración, con el fin de detectar vulnerabilidades existentes en la red de datos de la empresa Peaje Boconoito. Con estos hallazgos, se realizara el análisis de riesgos para determinar la probabilidad y el impacto que tienen estos riesgos sobre la red de datos de la empresa.

En la cuarta y última fase, se organizaran los resultados de la anterior fase y se determinara los niveles de madurez, respecto a la normatividad seleccionada y se realizara una declaración de aplicabilidad, que contenga los controles y procedimientos con el fin de establecer un sistema de gestión adecuado.

Por último se entregará el informe final de auditoria en la gerencia de la empresa Peaje Boconoito para realizar las respectivas acciones preventivas, detectivas y correctivas.

Tenorio Ordoñez I. (2024) **Auditoría informática de seguridad física en el área de redes en la Universidad Nacional de Chimborazo utilizando norma ISO 27001.** Trabajo de Titulación para optar al título de Ingeniero en

Tecnologías de la Información. Universidad Nacional De Chimborazo
Facultad De Ingeniería Carrera De Ingeniería De Tecnologías De La
Información

Este trabajo de tesis presenta una auditoría informática enfocada en la seguridad física de la red en el Edificio A de la Facultad de Ingeniería de la Universidad Nacional de Chimborazo, utilizando como marco de referencia la norma ISO 27001. La investigación se centró en evaluar las medidas de seguridad existentes, identificar vulnerabilidades y proponer mejoras alineadas con estándares internacionales.

Inicialmente, se llevó a cabo una exhaustiva investigación sobre la norma ISO 27001, con énfasis en sus directrices para la seguridad física de la infraestructura de redes. Esta norma proporciona un marco sistemático para la gestión de la seguridad de la información, asegurando que se implementen controles adecuados para proteger los activos de información.

La auditoría incluyó la revisión de políticas de acceso, controles de vigilancia, y procedimientos de respuesta a incidentes. Se identificaron varios puntos críticos que necesitan mejoras para cumplir con los estándares de seguridad recomendados por la ISO 27001.

Basado en los hallazgos de la auditoría, se desarrolló un plan de contingencia que incluye recomendaciones específicas para mejorar la seguridad física, tales como la implementación de un sistema de control de acceso más robusto, auditorías periódicas de seguridad, y programas de capacitación para el personal. Estas medidas están diseñadas para mitigar riesgos, proteger los activos de información y asegurar la continuidad operativa.

El resultado de esta tesis proporciona un marco claro y aplicable para la gestión de la seguridad física de la red en la Universidad Nacional de Chimborazo, contribuyendo a una mayor protección de los recursos informáticos y cumplimiento con normas internacionales.

Bases Teóricas

Esta sección del proyecto comprende las bases que a nivel teórico sustentan esta investigación según Arias (2012) "Las bases teóricas implican un desarrollo amplio de los conceptos y proposiciones que conforman el punto de vista o enfoque adoptado, para sustentar o explicar el problema planteado". (p107). En el contexto de este proyecto, las bases teóricas incluyen los conceptos y enfoques pertinentes a las auditorías de redes.

Auditoría

El origen etimológico de la palabra auditoría proviene del verbo latino *audire* que significa „revisar“, „intervenir“ y se define como un proceso sistemático que comprende una serie de procedimientos lógicos, estructurados y organizados. Se entiende como un examen crítico y sistemático utilizando técnicas determinadas que se realiza a una organización con el fin de evaluar el cumplimiento de normas y objetivos que determinan la eficiencia y eficacia de todos los procesos verificados, estableciendo alternativas y soluciones que mejoren el sistema examinado.

De igual manera la American Accounting Association (AAA) define la auditoría identificándola como “un proceso sistemático para obtener y evaluar de manera objetiva las evidencias relacionadas con informes sobre actividades económicas y otros acontecimientos relacionados. El fin del proceso consiste en determinar el grado de correspondencia del contenido informativo con las evidencias que le dieron origen, así como determinar si dichos informes se han elaborado observando principios establecidos para el caso.”

Un auditor debe ser una persona con formación personal y normativa y debe reunir cualidades como lo son el análisis, la observación, imparcialidad, discreto e independiente.

Auditoría de Sistemas

La auditoría de los sistemas de información ha surgido cuando las empresas e instituciones han tomado conciencia de que los datos que adquieren, conservan, procesan y emiten, es vital para su propia supervivencia diaria y proyección de eficiencia. Por tanto, han elevado a la categoría de sistemas críticos prácticamente todos los sistemas internos que manejan información en uno solo, denominado sistema de información. En consecuencia por su naturaleza crítica el enfoque de auditoría debe anotar una perspectiva que se adecue absolutamente a estos sistemas, sea mediante la transformación de métodos, técnicas y procedimientos de la auditoría tradicional, ósea mediante la creación de unos nuevos.

A principios de los años 80's, se empiezan a utilizar técnicas de tratamiento de la información por medio de computadores, como apoyo a la labor de los auditores. El auditor de sistemas de información empieza a ser también experto en el uso de lenguajes informáticos que le sirven para escribir, compilar y ejecutar programas para la consecución de pruebas y obtención de evidencia.

Con la introducción de nuevas tecnologías, pronto se detectaron las limitaciones de los métodos tradicionales para realizar la auditoría de sistemas. En su afán de maximizar la eficiencia de los procesos de auditorías, surgen nuevos modelos que se adecuan a las crecientes necesidades del sector de las tecnologías de la información.

Directrices gerenciales de COBIT, desarrollado por la Information Systems Audit Control Association (ISACA)

Las Directrices Gerenciales son un marco internacional de referencias que abordan las mejores prácticas de auditoría y control de sistemas de

información. Permiten que la gerencia incluya, comprenda y controle los riesgos relacionados con la tecnología de información y establezca el enlace entre los procesos de administración, aspectos técnicos, la necesidad de controles y los riesgos asociados.

The Management of the Control of Data Information Technology, desarrollado por el Instituto Canadiense de Contadores Certificados (CICA):

Este modelo está basado en el concepto de errores que establece responsabilidades relacionadas con la seguridad y los controles correspondientes. Dichos roles están clasificados con base en siete grupos: administración general, gerentes de sistemas, dueños, agentes, usuarios de sistemas de información, así como proveedores de servicios, desarrollo y operaciones de servicios y soporte de sistemas. Además, hace distinción entre los conceptos de autoridad, responsabilidad y respecto a control y riesgo previo al establecimiento del control, en términos de objetivos, estándares y técnicas mínimas a considerar.

SysTrust – Principios y criterios de confiabilidad de Sistemas, desarrollados por la Asociación de Contadores Públicos (AICPA) y el CICA

Este servicio pretende incrementar la confianza de alta gerencia, clientes y socios, con respecto a la confiabilidad en los sistemas por una empresa o actividad en particular. Este modelo incluye elementos como: infraestructura, software de cualquier naturaleza, personal especializado y usuarios, procesos manuales y automatizados, y datos. El modelo persigue determinar si el sistema de información es confiable, (i.e. si un sistema funciona sin errores significativos, o fallas durante un periodo de prueba determinado bajo un ambiente dado).

Modelo de Evaluación de Capacidades de software (CMM), desarrollado por el Instituto de Ingenieros de Software (SEI)

Este modelo hace posible evaluar las capacidades o habilidades para ejecutar, de una organización con respecto al desarrollo y mantenimiento de sistemas de información. Consiste en 18 sectores clave, agrupados alrededor de cinco niveles de madurez. Se puede considerar que CMM es la base de los principios de evaluación recomendados por COBIT, así como para algunos de los procesos de administración de COBIT.

ISO/IEC 27001(Information Technology – Security Techniques – Information Security Management System – Requirements) especifica los requisitos necesarios para establecer, implantar, mantener y mejorar un Sistema de Gestión de Seguridad de la Información (SGSI). Según el conocido “Ciclo de Deming”: PDCA – acrónimo de plan, Do Check, Act (Planificar, Hacer, Verificar, Actuar). Es consistente con las mejores prácticas descritas en ISO/17799 (Actual ISO ICE 27002) y tiene su origen en la revisión de la norma Británica British Standard BS 7799 – 2: 2002.

Si se revisan los antecedentes de proyectos relacionados auditoría de sistemas en la universidad de Nariño se encuentran:

Aspectos Generales Sobre Auditoria

La auditoría puede definirse como un proceso sistemático para obtener y evaluar de manera objetiva las evidencias relacionadas con informes sobre actividades económicas y otros acontecimientos relacionados, cuyo fin consiste en determinar el grado de correspondencia del contenido informativo con las evidencias que le dieron origen, así como establecer si dichos informes se han elaborado observando los principios establecidos para el caso.

Por otra parte la auditoría constituye una herramienta de control y supervisión que contribuye a la creación de una cultura de la disciplina de la organización y permite descubrir fallas en las estructuras o vulnerabilidades

existentes en la organización.

La auditoría como función de control debe ser la herramienta a utilizar para ayudar a los Funcionarios que tienen responsabilidad Administrativa, Técnica y Operacional a que no incurran en falta. Y es por ello que aquí el Control debe ser creativo, inteligente, y constructivo de asesoramiento oportuno a todas las direcciones o gerencias a fin de que la toma de decisiones sea acertada, segura y se logren los objetivos, con la máxima eficiencia.

La responsabilidad de un procedimiento de auditoría debe ir más allá de la búsqueda de problemas y de responsables, la visión de la auditoría debe dar la visión de la empresa en su conjunto. Por lo que saca el máximo provecho de la información real y existente, convirtiéndola en herramienta de reingeniería capaz de retroalimentar procesos o crear nuevos, la auditoría se volvió capaz de identificar necesidades, problemas y soluciones a futuro, con estas facultades el proceso de auditoría se promueve como una función permanente y a largo plazo.

Auditoría Interna.

Es una actividad independiente que realiza la empresa y que está encaminada a la revisión de operaciones contables además de la evaluación y medición de la eficacia de otros controles, con la finalidad de prestar un servicio a la dirección. Se aplica mejor en empresas medianas que tienden a aumentar en volumen, extensión geográfica y complejidad y se hace imposible el control directo de las operaciones por parte del director.

El objetivo principal es ayudar a la dirección en el cumplimiento de sus funciones y responsabilidades, proporcionándole un análisis objetivo, evaluaciones y recomendaciones pertinentes sobre las operaciones examinadas.

Otros objetivos que se busca concretar a través de la auditoría interna

son: realizar investigaciones especiales solicitadas por la dirección, preparar informes de auditoría acerca de las irregularidades que pudiesen encontrarse como resultado de las investigaciones, expresando igualmente las recomendaciones que se juzguen adecuadas, vigilar el cumplimiento de la recomendaciones contenidas en los informes emitidos con anterioridad.

La auditoría interna posee varias ventajas: facilita una ayuda primordial a la dirección al evaluar de forma relativamente independiente los sistemas de organización y de administración, facilita una evaluación global y objetiva de los problemas de la empresa que generalmente suelen ser interpretados de una manera parcial por los departamentos afectados, pone a disposición de la dirección un profundo conocimiento de las operaciones de la empresa, proporcionado por el trabajo de verificación de los datos contables y financieros, contribuye eficazmente a evitar las actividades rutinarias que generalmente se desarrollan en las grandes empresas, favorece la protección de los intereses y bienes de la empresa frente a terceros.

Auditoria externa.

Se puede definir como los métodos empleados por una firma externa de profesionales para averiguar la exactitud del contenido de los estados financieros presentados por una empresa. Se trata de dar carácter público, mediante la revisión, a unos estados financieros que en principio eran privados.

Los objetivos de la auditoría externa son: proporcionar a la dirección y a los propietarios de la empresa unos estados financieros certificados por una autoridad independiente e imparcial, proporcionar asesoramiento a la gerencia y a los responsables de las distintas áreas de la empresa en materia de sistemas contables y financieros, procedimientos de organización y otras numerosas fases de la operatoria de una empresa, suministrar información

objetiva que sirva de base a las entidades de información y clasificación crediticia, servir de punto de partida en las negociaciones para la compraventa de las acciones de una empresa, reducir y controlar riesgos accidentales, fraudes y otras actuaciones anormales, liberar implícitamente a la gerencia de sus responsabilidades de gestión.

Diferencias entre auditoría interna y externa

En la Auditoría Interna existe un vínculo laboral entre el auditor y la empresa, mientras que en la Auditoría Externa la relación es de tipo civil.

En la Auditoría Interna el diagnóstico del auditor, está destinado para la empresa; en el caso de la Auditoría Externa este dictamen se destina generalmente para terceras personas o sea ajena a la empresa.

La Auditoría Interna está inhabilitada para dar Fe Pública, debido a su vinculación contractual laboral, mientras la Auditoría Externa tiene la facultad legal de dar Fe Pública.

Principios generales de la auditoría externa

Exposición: Los estados financieros deben recoger por completo y con claridad todas las transacciones de la empresa.

Uniformidad: la base utilizada en la preparación de los estados financieros de un ejercicio no debe experimentar ninguna variación con respecto al ejercicio precedente. Importancia o materialidad: Este es el criterio que debe presidir el trabajo del auditor es la importancia económica o materialidad de las partidas.

Moderación: De dos o más posibilidades igualmente validas se debe escoger siempre la que dé los resultados más desfavorables.

Normas generales de la auditoría externa

Afectan a las condiciones que debe de reunir el auditor de y a su comportamiento en el desarrollo de la actividad de auditoría.

Realización por una persona competente.

Realización por una persona independiente.

Cuidado profesional en la realización del trabajo y en la confección del informe.

Normas de trabajo de la auditoría externa

Hacen referencia a la preparación y ejecución del trabajo a realizar por el auditor, regulan el conjunto de técnicas de investigación e inspección aplicables a los hechos relativos a los documentos contables sujetos a examen, mediante los cuales el auditor fundamenta su opinión responsable e independiente.

Programación adecuada.

Supervisión adecuada.

Análisis del control interno para fijar el alcance de la pruebas.

Opinión basada en un material y un trabajo razonablemente suficiente.

Normas del informe de la auditoría externa

Regulan los principios que han de ser observados en la elaboración y presentación del informe de auditoría estableciendo la extensión y contenido de los diferentes tipos de informes, así como los criterios que fundamenten el modelo de informe a utilizar en cada caso.

Expresión de si los estados financieros se ajustan a los principios de contabilidad generalmente aceptados.

Expresión de si se han presentado los estados financieros de manera uniforme con respecto al periodo precedente.

Exposiciones informativas razonablemente adecuadas a los estados financieros.

El informe debe contener un dictamen sobre los estados financieros

considerados en su conjunto.

Procedimientos de la auditoría externa

Son la serie de trabajos que hay que realizar para el adecuado cumplimiento de los principios y las normas, antes de presentar el informe definitivo. Se pueden señalar los siguientes procedimientos:

- Revisión de las actividades en las operaciones.

- Inspecciones físicas y recuentos.

- Obtención de pruebas de evidencia.

- Obtención de pruebas de exactitud.

- Preparación de reconciliaciones.

El Auditor

El auditor se refiere a la persona que asume la responsabilidad de realizar un trabajo de este tipo, en todo caso el auditor debe poseer ciertas cualidades para afrontar un trabajo como este:

- Deberá dominar las técnicas y metodologías del proceso auditor.

- Debe ser abierto en sus relaciones personales y que sepa dialogar.

- Debe poseer diversas actitudes como la independencia, la objetividad, la creatividad, el espíritu crítico, la diplomacia, etc.

El auditor debe mantener un cierto grado de independencia en los asuntos que se encuentra evaluando.

El auditor tiene la obligación de realizar con esmero y cuidado el dictamen o informe para el que fue contratado.

- Debe poseer una actitud positiva frente a la entidad evaluada.

- Debe tener estabilidad emocional frente la entidad.

- Es su obligación la de respetar las ideas de los demás.

- Debe tener capacidad para la negociación.

- Sera discreto y respetuoso con la información de la empresa.

- Su comportamiento debe ceñirse a la ética profesional.

Dadas estas características el auditor responsablemente deberá cumplir con las siguientes funciones:

Estudiar la normatividad, misión, objetivos, políticas, estrategias, planes y programas de trabajo.

Desarrollar el programa de trabajo de una auditoria.

Definir los objetivos, alcance y metodología para instrumentar una auditoria

Captar la información necesaria para evaluar la funcionalidad y efectividad de los procesos, funciones y sistemas utilizados.

Recabar y revisar estadísticas sobre volúmenes y cargas de trabajo.

Diagnosticar sobre los métodos de operación y los sistemas de información.

Detectar los hallazgos y evidencias e incorporarlos a los papeles de trabajo.

Respetar las normas de actuación dictadas por los grupos de filiación, corporativos, sectoriales e instancias normativas y, en su caso, globalizadoras.

Proponer los sistemas administrativos y/o las modificaciones que permitan elevar la efectividad de la organización.

Analizar la estructura y funcionamiento de la organización en todos sus ámbitos y niveles.

Revisar el flujo de datos y formas.

Considerar las variables ambientales y económicas que inciden en el funcionamiento de la organización.

Analizar la distribución del espacio y el empleo de equipos de oficina.

Evaluar los registros contables e información financiera.

Mantener el nivel de actuación a través de una interacción y revisión continua de avances.

Proponer los elementos de tecnología de punta requeridos para impulsar el cambio organizacional.

Diseñar y preparar los reportes de avance e informes de una auditoria.

Tipos De Auditoria

Existen algunos tipos de Auditoría entre los que la Auditoría de Sistemas integra un mundo paralelo pero diferente y peculiar resaltando su enfoque a la función informática. Entre los principales enfoques de Auditoría tenemos los siguientes:

Auditoría fiscal. Es una comprobación científica y sistemática de los estados financieros, libros de cuentas, comprobantes y otros registros financieros y legales de una persona natural, firma o corporación realizado por un auditor con el fin de asegurar si los libros han sido llevados por los principios de contabilidad generalmente aceptados y así brindar confianza y credibilidad a las personas, ya sean naturales o jurídicas que puedan estar interesadas en los estados de la empresa. La persona quien realice la auditoría debe ser un ente ajeno a la empresa, de esta manera se evitan vínculos que puedan verse reflejados en una opinión positiva o parcialización a través de la empresa sin que la misma lo merezca. También es necesario mencionar que si la auditoría está hecha por una firma con una amplia y reconocida trayectoria esta otorgara una mayor credibilidad y confianza a las personas interesadas. En conclusión la auditoría fiscal se dedica a observar el cumplimiento de las leyes fiscales.

La auditoría fiscal tiene como principales objetivos:

Determinar si sus sistemas contables son aceptables.

Conocer si el catálogo de cuentas es aceptable.

Verificar si se está al día en el cumplimiento de sus deberes formales.

Detectar áreas de riesgo y saber exactamente que correctivos aplicar.

Auditoría financiera. Es una revisión de los estados financieros similar a la auditoría externa. Su objetivo es expresar una opinión sobre si las cifras del balance y la cuenta de resultados presentan razonablemente la situación actual de la empresa de acuerdo con los principios de contabilidad

generalmente aceptados.

En general la auditoría financiera busca comprobar la veracidad de los estados financieros de la empresa y preparar informes de acuerdo a principios contables

Auditoría operacional. Es una evaluación objetiva, constructiva, sistemática y profesional de las actividades relativas al proceso de gestión de una organización, con el fin de determinar el grado de eficiencia, eficacia, efectividad, economía, equidad, excelencia y valoración de costos ambientales, con que son manejados los recursos; la adecuación y fiabilidad de los sistemas de información y control, de manera que cumpla con las políticas establecidas para alcanzar sus objetivos.

Los informes emergentes de este tipo de auditoría son:

Auditoría Operativa, relacionada básicamente con los objetivo de eficacia, eficiencia y economía.

Evaluaciones del Sistema de Control Interno, cuyo propósito es evaluar el diseño y funcionamiento de los Sistemas establecidos.

La auditoría operativa implica:

El período objeto de examen.

Examen y verificación de la información relativa al desempeño institucional.

Revisión y elaboración de informes sobre la administración de recursos.

Análisis de actividades y procesos clave, evaluación de sistemas de información y control.

Verificar la utilización de recursos públicos de conformidad a principios de eficiencia, efectividad, economía, eficacia, equidad y excelencia.

Verificar el cumplimiento de metas y objetivos.

Evaluar la gestión.

Este tipo de auditoría se aplica generalmente en el Sector Público,

Sector Privado, Sector Social.

El objetivo primordial de la auditoria operacional es brindar a todo tipo de organización la información necesaria para utilizar esta poderosa herramienta en forma congruente con sus necesidades y capacidad instalada, a fin de evaluar su comportamiento y derivar las medidas requeridas para mejorar su desempeño. Otras razones por las que se realiza esta auditoria son para establecer el grado en que la entidad y sus servidores han cumplido adecuadamente los deberes y atribuciones que les han sido asignados, determinar el grado en que el organismo y sus funcionarios controlan y evalúan la calidad tanto en los servicios que presta como en los bienes adquiridos y verificar que la entidad auditada cumpla con normas y demás disposiciones.

Auditoria administrativa. Independientemente de ser ella misma parte integrante del sistema total de control superior, es la principal herramienta para la revisión y evaluación de los resultados logrados. Cumple con una doble misión: primero, como parte integrante del control superior; es decir, un medio para obtener y mantener el control; el segundo es; el medio principal para la medición y evaluación de resultados.

Por tanto la dirección superior, propietarios, accionistas, auditores financieros y otros interesados deben confiar en ésta para la prevención de inconvenientes, y para garantizar la adecuada marcha del sistema.

La auditoría administrativa, como función interna, puede verse desde el punto de vista de la organización como:

- Una extensión de la auditoría interna financiera.

- Función independiente de la administración financiera.

- Forma departamental con la auditoría interna.

- Órgano asesor del consejo de administración.

Las funciones de a auditoria administrativa deben quedar enmarcadas dentro de la organización de una empresa en una unidad que, por su

situación jerárquica le permita la consecución de sus fines.

El nivel donde deberá quedar la unidad departamental de auditoría administrativa reunirá las siguientes características:

Jerarquía suficiente para poder inmiscuirse en cualquier unidad administrativa de la empresa.

Que el tipo de funciones de dicha unidad sea relacionado con la dirección, control y coordinación.

Que tenga suficiente autoridad sobre los demás departamentos.

Funciones que se van a desarrollar en una auditoría administrativa:

Investigación constante de planes y objetivos.

Estudio de las políticas y sus prácticas.

Revisión constante de la estructura orgánica.

Estudio constante de las operaciones de la empresa.

Analizar la eficiencia de la utilización de recursos humanos y materiales.

Revisión del equilibrio de las cargas de trabajo.

Revisión constante de los métodos de control.

Auditoría integral. Es el proceso de obtener y evaluar objetivamente, en un período determinado, evidencia relativa a la información financiera, al comportamiento económico y al manejo de una entidad con la finalidad de informar sobre el grado de correspondencia entre aquellos y los criterios o indicadores establecidos o los comportamientos generalizados.

El objetivo de la auditoría integral es evaluar los sistemas de control, implantados por la Gerencia General que le permitan medir el rendimiento económico y los recursos financieros de la empresa.

Además con la auditoría integral se pretende conocer la normativa que regula a la auditoría Integral, analizar el ambiente de aplicación de la auditoría

Integral, verificar a través de la utilización de un conjunto estructurado de proceso tomando como objetivo la evaluación sistemática y permanente del ente económico para una aseveración verificable.

La Auditoría Integral implica la ejecución de un trabajo con el trabajo o enfoque, por analogía de las revisiones financieras, de cumplimiento, control interno y de gestión, sistema y medio ambiente con los siguientes objetivos:

Determinar, si los Estados Financieros se presentan de acuerdo con los Principios de Contabilidad Generalmente Aceptados.

Determinar, si el ente ha cumplido, en el desarrollo de sus operaciones con las disposiciones legales que le sean aplicables, sus reglamentos, los estatutos y las decisiones de los órganos de dirección y administración.

Evaluar la estructura del control interno del ente con el alcance necesario para dictaminar sobre el mismo.

Evaluar el grado de eficiencia en el logro de los objetivos previstos por el ente y el grado de eficiencia y eficacia con que se han manejado los recursos disponibles.

Evaluar los mecanismos, operaciones, procedimientos, derechos a usuarios, responsabilidad, facultades y aplicaciones específicas de control relacionadas con operaciones en computadora.

Evaluar el impacto medioambiental producido de manera directa o indirecta por empresas que presentan un perfil ambiental diferente, condicionado por los riesgos aparentes asociados con sus procesos y productos; la edad, historia y estado de una planta, el marco jurídico en el cual opera.

Los principios generales de auditoría integral son: independencia, objetividad, permanencia, certificación, integridad, planeamiento, supervisión, oportunidad, forma, cumplimiento de las Normas de Profesión.

Para que el ejercicio de la Auditoría Integral se desarrolle en un ambiente controlado, es importante conducirla dentro de un concepto de normas que provean una estructura, como la posibilidad de pronosticar los

resultados.

La aplicación de normas ayudará a desarrollar una auditoría de alta calidad respondiendo a la necesidad de completar tareas difíciles en forma oportuna, evitando formar juicios prematuros basados en información incompleta por la falta de tiempo, asimismo, establecen orden y disciplina, produciendo auditorías efectivas, garantizando la veracidad de los hallazgos y el soporte adecuado para las recomendaciones, consecuentemente habrá una mayor aceptación por parte de la gerencia.

Auditoria de sistemas. Se ocupa de analizar la actividad que se conoce como técnica de sistemas en todas sus facetas. Hoy, la importancia creciente de las telecomunicaciones ha propiciado que las comunicaciones. Líneas y redes de las instalaciones informáticas, se auditen por separado, aunque formen parte del entorno general de sistemas.

Su finalidad es el examen y análisis de los procedimientos administrativos y de los sistemas de control interno de la compañía auditada. Al finalizar el trabajo realizado, los auditores exponen en su informe aquellos puntos débiles que hayan podido detectar, así como las recomendaciones sobre los cambios convenientes a introducir, en su opinión, en la organización de la compañía.

Normalmente, las empresas funcionan con políticas generales, pero hay procedimientos y métodos, que son términos más operativos. Los procedimientos son también sistemas; si están bien hechos, la empresa funcionará mejor. La auditoría de sistemas analiza todos los procedimientos y métodos de la empresa con la intención de mejorar su eficacia.

Existen varios campos de acción en los que la auditoria informática de sistemas puede operar entre ellos se tienen las auditorias más destacadas del tipo:

Sistemas Operativos.

Engloba los Subsistemas de Teleprocesos, Entrada/Salida, etc. Debe

verificarse en primer lugar que los Sistemas están actualizados con las últimas versiones del fabricante, indagando las causas de las omisiones si las hubiera. El análisis de las versiones de los Sistemas Operativos permite descubrir la posible incompatibilidad entre otros productos de Software Básicos adquiridos por la instalación y determinadas versiones de aquellas. Deben revisarse los parámetros variables de las librerías más importantes de los Sistemas, por si difieren de los valores habituales aconsejados por el constructor.

Software Básico.

Es fundamental para el auditor conocer los productos de software básico que han sido facturados aparte de la propia computadora. Esto, por razones económicas y por razones de comprobación de que la computadora podría funcionar sin el producto adquirido por el cliente. En cuanto al software desarrollado por el personal informático de la empresa, el auditor debe verificar que este no agrede ni condiciona al Sistema Igualmente, debe considerar el esfuerzo en términos de costes, por si hubiera alternativas más económicas.

La auditoría, al igual que cualquier otra actividad, requiere de una buena planeación, que le permita desarrollarse eficientemente y oportunamente.

Auditoria Web.

La auditoría web está diseñada para identificar cuáles son los puntos débiles de la presencia online, para mejorarla y para que en los puntos fuertes se pueda sacar el máximo rendimiento a la internet

Con los diferentes tipos de auditoría web se podrá conocer:

Las limitaciones técnicas de la página.

Que le falta a la página para estar optimizada.

Quién y desde dónde vienen las visitas.

Cómo se mueven los usuarios de la página.
Qué productos o servicios visitan más los usuarios.
Qué sitios enlazan la página.
Con que palabras clave está mejor posicionada la página.

Auditoria De Sistemas Como Objeto De Estudio

Desde que la informática se enfocó hacia el apoyo de la sistematización en las áreas del negocio, se empezaron a implantar aplicaciones administrativas como contabilidad, nómina, etc., lo que originó el proceso conocido como auditoria a sistemas de información.

La auditoría de sistemas es el proceso de recoger, agrupar y evaluar evidencias para determinar si un sistema de información salvaguarda el activo empresarial, mantiene la integridad de los datos, lleva a cabo eficazmente los fines de la organización, utiliza eficientemente los recursos, y cumple con las leyes y regulaciones establecidas. También permiten detectar de forma sistemática el uso de los recursos y los flujos de información dentro de una organización y determinar qué información es crítica para el cumplimiento de su misión y objetivos, identificando necesidades, duplicidades, costes, valor y barreras, que obstaculizan flujos de información eficientes.

Auditar consiste principalmente en estudiar los mecanismos de control que están implantados en una empresa u organización, determinando si los mismos son adecuados y cumplen unos determinados objetivos o estrategias, estableciendo los cambios que se deberían realizar para la consecución de los mismos. Los mecanismos de control pueden ser directivos, preventivos, de detección, correctivos o de recuperación ante una contingencia.

La auditoría de sistemas permite además verificar que la información

desde su entrada, procedimientos, controles, almacenamientos y salidas, sea integra y verificable y por tanto permita el apoyo a la toma de decisiones dentro de una organización.

Dentro de este procedimiento es necesario evaluar los mecanismos de control implantados en una organización, determinando así, si son adecuados y cumplen con los objetivos o estrategias, de esta manera, es posible proponer cambios que se deberían realizar para el mejoramiento de los mismos. Estos mecanismos de control pueden ser directivos, preventivos, de detección, correctivos o de recuperación ante una contingencia.

Alcance de la auditoria de sistemas. El alcance ha de definir con precisión el entorno y los límites en que va a desarrollarse la auditoría de sistemas, se complementa con los objetivos de ésta. El alcance ha de figurar expresamente en el Informe Final, de modo que quede perfectamente determinado no solamente hasta que puntos se ha llegado, sino cuales materias fronterizas han sido omitidas. La indefinición de los alcances de la auditoria compromete el éxito o el fracaso de la misma. Así mismo, las personas que realizan la auditoría han de conocer con la mayor exactitud posible los objetivos a los que su tarea debe llegar.

Objetivos de la auditoria de sistemas

El objetivo principal de la auditoria de sistemas es evaluar el uso adecuado de los sistemas para el correcto ingreso de datos, el procesamiento adecuado de la información y la emisión oportuna de los resultados en la organización, incluyendo la evaluación en el cumplimiento de las funciones, actividades y operaciones de funcionarios, empleados y usuarios involucrados con los servicios que proporcionan los sistemas de información dentro de la empresa.

Objetivos específicos de la auditoria de sistemas

El control de la función informática.

El análisis de la eficiencia de los Sistemas Informáticos.

La verificación del cumplimiento de la Normativa en este ámbito.

La revisión de la eficaz gestión de los recursos informáticos.

La auditoría de sistemas sirve para mejorar ciertas características en la empresa como:

Eficiencia.

Eficacia.

Rentabilidad

Seguridad

Principales pruebas y herramientas para efectuar una auditoría de sistemas

Pruebas sustantivas: Verifican el grado de confiabilidad del sistema de información de la organización. Se suelen obtener mediante observación, cálculos, muestreos, entrevistas, técnicas de examen analítico, revisiones y conciliaciones. Verifican así mismo la exactitud, integridad y validez de la información.

Pruebas de cumplimiento: Verifican el grado de cumplimiento de aquello extraído el análisis de la muestra. Proporciona evidencias de que los controles claves existen y que son aplicables efectiva y uniformemente

Las principales herramientas de las que dispone un auditor informático son:

Observación

Realización de cuestionarios

Entrevistas a auditados y no auditados

Muestreo estadístico

Flujo gramas

Listas de chequeo

Mapas conceptuales

Perfiles Profesionales de los auditores informáticos.

Cuadro 1
Perfiles Profesionales y Actividades

Profesión	Actividades y conocimientos deseables
Informático Generalista	Con experiencia amplia en ramas distintas. Deseable que su labor se haya desarrollado en Explotación y en Desarrollo de Proyectos. Conocedor de Sistemas.
Experto en Desarrollo de Proyectos	Amplia experiencia como responsable de proyectos. Experto analista. Conocedor de las metodologías de Desarrollo más importantes.
Técnico de Sistemas	Experto en Sistemas Operativos y Software Básico. Conocedor de los productos equivalentes en el mercado. Amplios conocimientos de Explotación.
Experto en Bases de Datos y Administración de las mismas.	Con experiencia en el mantenimiento de Bases de Datos. Conocimiento de productos compatibles y equivalentes. Buenos conocimientos de explotación
Experto en Software de Comunicación	Alta especialización dentro de la técnica de sistemas. Conocimientos profundos de redes. Muy experto en Subsistemas de teleproceso.
Experto en Explotación y Gestión de CPD'S	Responsable de algún Centro de Cálculo. Amplia experiencia en Automatización de trabajos. Experto en relaciones humanas. Buenos conocimientos de los sistemas.
Técnico de Organización	Experto organizador y coordinador. Especialista en el análisis de flujos de información.
Técnico de evaluación de Costos	Economista con conocimiento de Informática. Gestión de costos.

Fuente: Piattini y Del Peso (1996)

Pasos a seguir para una auditoria de sistemas en una organización.

Estudio preliminar. Para realizar dicho estudio se examinan las funciones y actividades generales del área o departamento de sistemas, con el fin de tener un contacto inicial con el personal de dicha área, y conocer a grandes rasgos la distribución del sistema, características de equipos, instalaciones y medidas de seguridad visibles.

Para su realización el auditor debe conocer lo siguiente:

Organización: Es de vital importancia conocer dentro del departamento o área de sistemas quien es el jefe, quien diseña y quien ejecuta, para lo cual es necesario conocer:

Organigrama: El organigrama permite conocer la estructura oficial dentro de la organización a auditar.

Departamentos: Es importante conocer los departamentos que hacen parte de la organización y las funciones que se deben llevar a cabo dentro de cada uno de ellos.

Relaciones Jerárquicas y funcionales entre órganos de la Organización: Es necesario verificar si dentro de la organización se cumplen las relaciones funcionales y jerárquicas que se evidencian dentro del organigrama.

Corrientes de información: Los flujos de información entre los diferentes departamentos dentro de una organización son de vital importancia ya que evidencian una gestión eficiente, siempre y cuando estas corrientes no vayan en direcciones no contempladas dentro del organigrama.

En muchas ocasiones es posible que se hayan creado canales de información alternativos, lo cual ocurre cuando existen pequeños o grandes fallos en la estructura de la organización.

Además, la aparición de corrientes de información no planeados pueden obedecer a afinidades personales o desacato a las reglas establecidas. Los cuales pueden producir perturbaciones dentro de la organización.

Flujos de información: Dentro del proceso de auditoría es necesario

verificar que los nombres de los cargos dentro de la organización correspondan a las funciones que realiza esa persona.

Puede ocurrir que bajo nombres de cargos diferentes se realicen funciones idénticas, en este caso se estaría realizando tareas redundantes lo cual podría conllevar a deficiencias estructurales.

Entorno operacional: Es importante conocer por parte de los auditores de sistemas la referencia del entorno en el cual se va a trabajar, esto se logra determinando:

Ubicación geográfica del o los centros de procesamiento de información de la empresa. Evaluando además el personal responsable de cada uno de ellos.

Arquitectura y configuración de Hardware y Software: es fundamental la verificación de la compatibilidad e intercomunicación de los equipos ya que estas, están estrechamente ligadas a los grados de seguridad lógica de las organizaciones.

Situación geográfica de los Sistemas: el equipo auditor debe estudiar la información que proporcione la organización sobre los elementos físicos y lógicos de las instalaciones.

Comunicación y Redes de Comunicación: se debe disponer de un inventario, estado y características de las redes de comunicación.

Aplicaciones bases de datos: Finalmente para el equipo auditor es necesario tener una idea general de los procesos informáticos realizados dentro de la organización.

Para ello es necesario recolectar la siguiente información:

Inventario de Hardware y Software

Volumen, antigüedad y complejidad de las Aplicaciones

Se clasificará globalmente la existencia total o parcial de metodología en el desarrollo de las aplicaciones.

Si se han utilizados varias a lo largo del tiempo se pondrá de manifiesto:

Metodología del diseño: La existencia de una adecuada documentación

de las aplicaciones proporciona beneficios tangibles e inmediatos muy importantes.

La documentación de programas disminuye gravemente el mantenimiento de los mismos.

Documentación: El auditor recaudará información de tamaño y características de las Bases de Datos, clasificándolas en relación y jerarquías. Hallará un promedio de número de accesos a ellas por hora o días. Esta operación se repetirá con los ficheros, así como la frecuencia de actualizaciones de los mismos.

Estos datos proporcionan una visión aceptable de las características de la carga informática.

Determinación de recursos de la auditoría de sistemas. Por medio de los resultados del estudio preliminar es posible determinar los recursos humanos y físicos que son necesarios en el proceso de auditoría.

Elaboración del plan y de los programas de trabajo. El plan de trabajo se realiza de acuerdo a los siguientes criterios:

El proceso de auditoría se llevará a cabo en áreas generales o específicas.

La auditoría se hará de manera global o específica.

De acuerdo a si se manejan recursos genéricos o específicos se realizará un cronograma de trabajo.

El Plan establece disponibilidad futura de los recursos durante la revisión.

El Plan estructura las tareas a realizar por cada integrante del grupo auditoría.

En el Plan se expresan todas las ayudas que el auditor ha de recibir del auditado.

Una vez elaborado el Plan, se procede a la Programación de actividades, esta ha de ser lo suficientemente flexible como para permitir modificaciones a lo largo del proyecto.

Actividades de la auditoría de sistemas. La auditoría de sistemas general se realiza por áreas generales o por áreas específicas. Si se examina por grandes temas, resulta evidente la mayor calidad y el empleo de más tiempo total y mayores recursos. Cuando la auditoría se realiza por áreas específicas, se abarcan de una vez todas las peculiaridades que afectan a la misma, de forma que el resultado se obtiene más rápidamente y con menor calidad.

Técnicas de Trabajo:

- Análisis de la información recabada del auditado
- Análisis de la información propia
- Cruzamiento de las informaciones anteriores
- Entrevistas
- Simulación
- Muestreos

Herramientas:

- Cuestionario general inicial
- Cuestionario Checklist
- Estándares
- Monitores
- Simuladores (Generadores de datos)
- Paquetes de auditoría (Generadores de Programas)
- Matrices de riesgo

Informe Final. El informe final de la auditoría de sistemas se realiza por escrito, el cual contempla la siguiente estructura:

- Definición de objetivos y alcance de la auditoría

Enumeración de temas objeto de la auditoria

Cuerpo de la auditoria: para lo cual se mostrara lo siguiente para cada tema:

Situación actual

Tendencias futuras

Puntos débiles y amenazas

Recomendaciones y planes de acción

Redacción posterior de la Carta de Introducción o Presentación Algunas Características que deben ser consideradas en los informes son:

Las características de fondo se refieren a que la información sea veraz y oportuna, el uso de la terminología se exacta y objetiva, que exista congruencia con lo observado sin hacer ninguna distorsión de lo encontrado.

Las características de forma: el estilo de redacción concreto conciso, clara, sencilla y amena, que no haya redundancia, redacción impecable en ortografía.

Metodologías De Auditoria De Sistemas

La auditoría de sistemas en el ámbito empresarial, ha sido de gran importancia, puesto que con ella se pretende gestionar la información y sirve como apoyo a la toma de decisiones. Además se busca disponer de un sistema de información que sea eficiente y eficaz para obtener la mayor productividad y calidad posibles, debido a que la información se ha convertido en el activo más importante de las empresas.

En la actualidad, gran parte de las organizaciones consideran que la información y la tecnología representan activos importantes para la misma, sin dejar de lado otros activos indispensables, como los requerimientos de calidad, controles, seguridad e información. Por tal razón los directivos deben establecer un adecuado sistema de control interno, para proporcionar seguridad razonable, respecto a si están lográndose los objetivos como:

promover la efectividad y eficiencia de las operaciones, proteger y conservar todos los recursos de la organización, cumplir las leyes y reglamentos internos y externos relacionados con la empresa.

Para esto, se hace necesario aplicar una auditoria de sistemas llevando a cabo una metodología adecuada, que permita evaluar de manera objetiva las vulnerabilidades o falta de controles existentes en la empresa.

Las metodologías desarrolladas y utilizadas en la auditoría y el control informático, se dividen en dos grupos:

Cuantitativas

Cualitativas

Las metodologías cuantitativas están basadas en un modelo matemático, diseñadas para producir una lista de riesgos que pueden compararse entre sí con facilidad por tener asignados unos valores numéricos. Estos valores son datos de probabilidad de ocurrencia de un evento que se debe extraer de un riesgo de incidencias donde el número de incidencias tiende al infinito.

Y las metodologías cualitativas están basadas en el criterio humano capaz de definir un proceso de trabajo. Así mismo, esta metodología establece métodos estadísticos y lógica borrosa, que requiere menos recursos humanos y menos tiempo que las metodologías cuantitativas.

Esta metodología presenta un enfoque amplio y logra un plan de trabajo flexible y reactivo. Sin embargo tiene la desventaja de depender mucho de la experiencia, habilidad y calidad del profesional involucrado. Dicha anomalía nace de la dificultad que tiene un profesional sin experiencia que asume la función auditora y busca una fórmula fácil que le permita empezar su trabajo rápidamente. Por lo tanto es necesario que el auditor tenga una gran experiencia y una gran formación tanto auditora como informática. Esta formación debe ser adquirida mediante el estudio y la práctica.

Estas últimas hacen parte de los modelos a seguir dentro del control interno y son necesarias para desarrollar cualquier proyecto de manera

ordenada y eficaz, por lo que cada una cumple un papel importante y al optar por una de ellas, el auditor debe cumplirlas a cabalidad.

COBIT (Control Objectives for Information and related Technology). La Organización ISACA (Information Systems Audit and Control Association), se formó como una fundación de educación para llevar a cabo los esfuerzos de investigación a gran escala para expandir el conocimiento y el valor de la gobernanza de las Tecnologías de Información (TI) y el campo de control. A través de su Fundación, publicó en 1995 el COBIT, como resultado de cuatro años de intensa investigación.

El COBIT es una metodología utilizada en las empresas para auditar los sistemas de información, donde se evalúa la gestión y el control, enfocado a los administradores de las TI, los usuarios y los auditores encargados del proceso.

COBIT se aplica a los sistemas de información de toda la empresa, incluyendo las computadoras personales, mini computadoras y ambientes distribuidos, está basado en la filosofía de que los recursos de TI necesitan ser administrados por un conjunto de procesos naturalmente agrupados para proveer la información pertinente y confiable que requiere una organización para lograr sus objetivos.

La estructura del modelo COBIT evalúa los criterios de información, como la seguridad y calidad, así como también se verifican los recursos que comprenden la tecnología de información, como el recurso humano, instalaciones, sistemas, entre otros, y finalmente se realiza una evaluación sobre los procesos implicados en la organización.

Cuando se implementa el COBIT adecuadamente en una organización, se evalúa de manera ágil y consistente el cumplimiento de los objetivos de control, haciendo que los procesos y recursos de información y tecnología contribuyan al logro de los objetivos de la empresa.

El modelo COBIT, clasifica los procesos de las unidades de tecnología de información de las organizaciones en cuatro dominios:

Dominio: Planificación y organización (PO).

Este dominio cubre la estrategia y las tácticas y se refiere a la identificación de la forma en que la tecnología de información puede contribuir de la mejor manera al logro de los objetivos de negocio. Además, la consecución de la visión estratégica necesita ser planeada, comunicada y administrada desde diferentes perspectivas. Finalmente, deberán establecerse una organización y una infraestructura tecnológica apropiadas.

Procesos:

PO1 Definición de un plan Estratégico

PO1.1 Administración del Valor de TI

PO1.2 Alineación de TI con el Negocio

PO1.3 Evaluación del Desempeño y la Capacidad Actual

PO1.4 Plan Estratégico de TI

PO1.5 Planes Tácticos de TI

PO1.6 Administración del Portafolio de TI

Objetivo: Lograr un balance óptimo entre las oportunidades de tecnología de información y los requerimientos de TI de negocio, para asegurar sus logros futuros.

Su realización se concreta a través un proceso de planeación estratégica emprendido en intervalos regulares dando lugar a planes a largo plazo, los que deberán ser traducidos periódicamente en planes operacionales estableciendo metas claras y concretas a corto plazo, teniendo en cuenta:

La definición de objetivos de negocio y necesidades de TI, la alta gerencia será la responsable de desarrollar e implementar planes a largo y corto plazo que satisfagan la misión y las metas generales de la organización.

El inventario de soluciones tecnológicas e infraestructura actual, se deberá evaluar los sistemas existentes en términos de: nivel de automatización de negocio, funcionalidad, estabilidad, complejidad, costo y fortalezas y debilidades, con el propósito de determinar el nivel de soporte

que reciben los requerimientos del negocio de los sistemas existentes.

Los cambios organizacionales, se deberá asegurar que se establezca un proceso para modificar oportunamente y con precisión el plan a largo plazo de tecnología de información con el fin de adaptar los cambios al plan a largo plazo de la organización y los cambios en las condiciones de la TI.

Estudios de factibilidad oportunos, para que se puedan obtener resultados efectivos

PO2 Definición de la Arquitectura de Información

PO2.1 Modelo de Arquitectura de Información Empresarial

PO2.2 Diccionario de Datos Empresarial y Reglas de Sintaxis de Datos

PO2.3 Esquema de Clasificación de Datos

PO2.4 Administración de Integridad

Objetivo: Satisfacer los requerimientos de negocio, organizando de la mejor manera posible los sistemas de información, a través de la creación y mantenimiento de un modelo de información de negocio, asegurándose que se definan los sistemas apropiados para optimizar la utilización de esta información, tomando en consideración:

La documentación deberá conservar consistencia con las necesidades permitiendo a los responsables llevar a cabo sus tareas eficiente y oportunamente.

El diccionario de datos, el cual incorporara las reglas de sintaxis de datos de la organización y deberá ser continuamente actualizado.

La propiedad de la información y la clasificación de severidad con el que se establecerá un marco de referencia de clasificación general relativo a la ubicación de datos en clases de información.

PO3 Determinación de la dirección tecnológica

PO3.1 Planeación de la Dirección Tecnológica

PO3.2 Plan de Infraestructura Tecnológica

PO3.3 Monitoreo de Tendencias y Regulaciones Futuras

P03.4 Estándares Tecnológicos

P03.5 Consejo de Arquitectura de TI

Objetivo: Aprovechar al máximo de la tecnología disponible o tecnología emergente, satisfaciendo los requerimientos de negocio, a través de la creación y mantenimiento de un plan de infraestructura tecnológica, tomando en consideración:

La capacidad de adecuación y evolución de la infraestructura actual, que deberá concordar con los planes a largo y corto plazo de tecnología de información y debiendo abarcar aspectos tales como arquitectura de sistemas, dirección tecnológica y estrategias de migración.

El monitoreo de desarrollos tecnológicos que serán tomados en consideración durante el desarrollo y mantenimiento del plan de infraestructura tecnológica.

Las contingencias (por ejemplo, redundancia, resistencia, capacidad de adecuación y evolución de la infraestructura), con lo que se evaluará sistemáticamente el plan de infraestructura tecnológica.

Planes de adquisición, los cuales deberán reflejar las necesidades identificadas en el plan de infraestructura tecnológica.

PO4 Definición de la organización y de las relaciones de TI

PO4.1 Marco de Trabajo de Procesos de TI

PO4.2 Comité Estratégico de TI

PO4.3 Comité Directivo de TI

PO4.4 Ubicación Organizacional de la Función de TI

PO4.5 Estructura Organizacional

PO4.6 Establecimiento de Roles y Responsabilidades

PO4.7 Responsabilidad de Aseguramiento de Calidad de TI

PO4.8 Responsabilidad sobre el Riesgo, la Seguridad y el Cumplimiento

PO4.9 Propiedad de Datos y de Sistemas

PO4.10 Supervisión

PO4.11 Segregación de Funciones

PO4.12 Personal de TI

PO4.13 Personal Clave de TI

PO4.14 Políticas y Procedimientos para Personal Contratado

PO4.15 Relaciones

Objetivo: Prestación de servicios de TI

Esto se realiza por medio de una organización conveniente en número y

habilidades, con tareas y responsabilidades definidas y comunicadas, teniendo en cuenta:

El comité de dirección el cual se encargara de vigilar la función de servicios de información y sus actividades.

Propiedad, custodia, la Gerencia deberá crear una estructura para designar formalmente a los propietarios y custodios de los datos. Sus funciones y responsabilidades deberán estar claramente definidas.

Supervisión, para asegurar que las funciones y responsabilidades sean llevadas a cabo apropiadamente

Segregación de funciones, con la que se evitará la posibilidad de que un solo individuo resuelva un proceso crítico.

Los roles y responsabilidades, la gerencia deberá asegurarse de que todo el personal deberá conocer y contar con la autoridad suficiente para llevar a cabo las funciones y responsabilidades que le hayan sido asignadas

La descripción de puestos, deberá delinear claramente tanto la responsabilidad como la autoridad, incluyendo las definiciones de las habilidades y la experiencia necesarias para el puesto, y ser adecuadas para su utilización en evaluaciones de desempeño.

Los niveles de asignación de personal, deberán hacerse evaluaciones de requerimientos regularmente para asegurar para asegurar una asignación de personal adecuada en el presente y en el futuro.

El personal clave, la gerencia deberá definir e identificar al personal clave de tecnología de información.

PO5 Manejo de la inversión

PO5.1 Marco de Trabajo para la Administración Financiera

PO5.2 Prioridades Dentro del Presupuesto de TI

PO5.3 Proceso Presupuestal

PO5.4 Administración de Costos de TI

PO5.5 Administración de Beneficios

Objetivo: tiene como finalidad la satisfacción de los requerimientos de

negocio, asegurando el financiamiento y el control de desembolsos de recursos financieros. Su realización se concreta a través presupuestos periódicos sobre inversiones y operaciones establecidas y aprobados por el negocio, teniendo en cuenta:

Las alternativas de financiamiento, se deberán investigar diferentes alternativas de financiamiento.

El control del gasto real, se deberá tomar como base el sistema de contabilidad de la organización, mismo que deberá registrar, procesar y reportar rutinariamente los costos asociados con las actividades de la función de servicios de información

La justificación de costos y beneficios, deberá establecerse un control gerencial que garantice que la prestación de servicios por parte de la función de servicios de información se justifique en cuanto a costos. Los beneficios derivados de las actividades de TI deberán ser analizados en forma similar.

PO6 Comunicación de la dirección y aspiraciones de la gerencia

PO6.1 Ambiente de Políticas y de Control

PO6.2 Riesgo Corporativo y Marco de Referencia de Control Interno de TI

PO6.3 Administración de Políticas para TI

PO6.4 Implantación de Políticas de TI

PO6.5 Comunicación de los Objetivos y la Dirección de TI

Objetivo: Asegura el conocimiento y comprensión de los usuarios sobre las aspiraciones del alto nivel (gerencia), se concreta a través de políticas establecidas y transmitidas a la comunidad de usuarios, necesitándose para esto estándares para traducir las opciones estratégicas en reglas de usuario prácticas y utilizables. Toma en cuenta:

Los código de ética / conducta, el cumplimiento de las reglas de ética, conducta, seguridad y estándares de control interno deberá ser establecido por la Alta Gerencia y promoverse a través del ejemplo.

Las directrices tecnológicas

El cumplimiento, la Gerencia deberá también asegurar y monitorear la duración de la implementación de sus políticas.

El compromiso con la calidad, la Gerencia de la función de servicios de información deberá definir, documentar y mantener una filosofía de calidad, debiendo ser comprendidos, implementados y mantenidos por todos los niveles de la función de servicios de información.

Las políticas de seguridad y control interno, la alta gerencia deberá asegurar que esta política de seguridad y de control interno especifique el propósito y los objetivos, la estructura gerencial, el alcance dentro de la organización, la definición y asignación de responsabilidades para su implementación a todos los niveles y la definición de multas y de acciones disciplinarias asociadas con la falta de cumplimiento de estas políticas.

P07 Administración de recursos humanos

P07.1 Reclutamiento y Retención del Personal

P07.2 Competencias del Personal

P07.3 Asignación de Roles

P07.4 Entrenamiento del Personal de TI

P07.5 Dependencia Sobre los Individuos

P07.6 Procedimientos de Investigación del Personal

P07.7 Evaluación del Desempeño del Empleado

P07.8 Cambios y Terminación de Trabajo

Objetivo: Maximizar las contribuciones del personal a los procesos de TI, satisfaciendo así los requerimientos de negocio, a través de técnicas sólidas para administración de personal, tomando en consideración:

El reclutamiento y promoción, deberá tener como base criterios objetivos, considerando factores como la educación, la experiencia y la responsabilidad. Los requerimientos de calificaciones, el personal deberá estar calificado, tomando como base una educación, entrenamiento y o experiencia apropiados, según se requiera.

La capacitación, los programas de educación y entrenamiento estarán dirigidos a incrementar los niveles de habilidad técnica y administrativa del personal.

La evaluación objetiva y medible del desempeño, se deberá asegurar que dichas evaluaciones sean llevadas a cabo regularmente según los estándares establecidos y las responsabilidades específicas del puesto. Los empleados deberán recibir asesoría sobre su desempeño o su conducta cuando esto sea apropiado.

PO8 Asegurar el cumplimiento con los requerimientos Externos

Objetivo: Cumplir con obligaciones legales, regulatorias y contractuales. Para ello se realiza una identificación y análisis de los requerimientos externos en cuanto a su impacto en TI, llevando a cabo las medidas apropiadas para cumplir con ellos y se toma en consideración:

Definición y mantenimiento de procedimientos para la revisión de requerimientos externos, para la coordinación de estas actividades y para el cumplimiento continuo de los mismos.

Leyes, regulaciones y contratos

Revisiones regulares en cuanto a cambios

Búsqueda de asistencia legal y modificaciones

Seguridad y ergonomía con respecto al ambiente de trabajo de los usuarios y el personal de la función de servicios de información.

Privacidad

Propiedad intelectual

Flujo de datos externos y criptografía

PO9 Evaluación de riesgos

PO9.1 Marco de Trabajo de Administración de Riesgos

PO9.2 Establecimiento del Contexto del Riesgo

PO9.3 Identificación de Eventos

PO9.4 Evaluación de Riesgos de TI

PO9.5 Respuesta a los Riesgos

PO9.6 Mantenimiento y Monitoreo de un Plan de Acción de Riesgos

Objetivo: Asegurar el logro de los objetivos de TI y responder a las amenazas hacia la provisión de servicios de TI

Para ello se logra la participación de la propia organización en la identificación de riesgos de TI y en el análisis de impacto, tomando medidas económicas para mitigar los riesgos y se toma en consideración:

Identificación, definición y actualización regular de los diferentes tipos de riesgos de TI (por ej.: tecnológicos, de seguridad, etc.) de manera de que se pueda determinar la manera en la que los riesgos deben ser manejados a un nivel aceptable.

Definición de alcances, límites de los riesgos y la metodología para las evaluaciones de los riesgos.

Actualización de evaluación de riesgos.

Metodología de evaluación de riesgos.

Medición de riesgos cualitativos y/o cuantitativos

Definición de un plan de acción contra los riesgos para asegurar que existan controles y medidas de seguridad económicas que mitiguen los riesgos en forma continua.

Aceptación de riesgos dependiendo de la identificación y la medición del riesgo, de la política organizacional, de la incertidumbre incorporada al enfoque de evaluación de riesgos y de que tan económico resulte implementar protecciones y controles.

PO10 Administración de proyectos

PO10.1 Marco de Trabajo para la Administración de Programas

PO10.2 Marco de Trabajo para la Administración de Proyectos

PO10.3 Enfoque de Administración de Proyectos

PO10.4 Compromiso de los Interesados

PO10.5 Declaración de Alcance del Proyecto

PO10.6 Inicio de las Fases del Proyecto

PO10.7 Plan Integrado del Proyecto

PO10.8 Recursos del Proyecto

PO10.9 Administración de Riesgos del Proyecto

PO10.10 Plan de Calidad del Proyecto

PO10.11 Control de Cambios del Proyecto

PO10.12 Planeación del Proyecto y Métodos de Aseguramiento

PO10.13 Medición del Desempeño, Reporte y Monitoreo del Proyecto

PO10.14 Cierre del Proyecto

Objetivo: Establecer prioridades y entregar servicios oportunamente y de acuerdo al presupuesto de inversión.

Para ello se realiza una identificación y priorización de los proyectos en línea con el plan operacional por parte de la misma organización. Además, la organización deberá adoptar y aplicar sólidas técnicas de administración de proyectos para cada proyecto emprendido y se toma en consideración:

Definición de un marco de referencia general para la administración de proyectos que defina el alcance y los límites del mismo, así como la metodología de administración de proyectos a ser adoptada y aplicada para cada proyecto emprendido. La metodología deberá cubrir, como mínimo, la asignación de responsabilidades, la determinación de tareas, la realización de presupuestos de tiempo y recursos, los avances, los puntos de revisión y las aprobaciones.

El involucramiento de los usuarios en el desarrollo, implementación o modificación de los proyectos.

Asignación de responsabilidades y autoridades a los miembros del personal asignados al proyecto.

Aprobación de fases de proyecto por parte de los usuarios antes de pasar a la siguiente fase.

Presupuestos de costos y horas hombre

Planes y metodologías de aseguramiento de calidad que sean revisados y acordados por las partes interesadas.

Plan de administración de riesgos para eliminar o minimizar los riesgos.

Planes de prueba, entrenamiento, revisión post-implementación.

PO11 Administración de calidad

PO8.1 Sistema de Administración de Calidad

PO8.2 Estándares y Prácticas de Calidad

PO8.3 Estándares de Desarrollo y de Adquisición

PO8.4 Enfoque en el Cliente de TI

PO8.5 Mejora Continua

PO8.6 Medición, Monitoreo y Revisión de la Calidad.

Objetivo: Satisfacer los requerimientos del cliente. Para ello se realiza una planeación, implementación y mantenimiento de estándares y sistemas de administración de calidad por parte de la organización y se toma en consideración:

Definición y mantenimiento regular del plan de calidad, el cual deberá promover la filosofía de mejora continua y contestar a las preguntas básicas de qué, quién y cómo.

Responsabilidades de aseguramiento de calidad que determine los tipos de actividades de aseguramiento de calidad tales como revisiones, auditorías, inspecciones, etc. que deben realizarse para alcanzar los objetivos del plan general de calidad.

Metodologías del ciclo de vida de desarrollo de sistemas que rijan el proceso de desarrollo, adquisición, implementación y mantenimiento de sistemas de información.

Documentación de pruebas de sistemas y programas

Revisiones y reportes de aseguramiento de calidad

Dominio: Adquisición e implementación.

Para llevar a cabo la estrategia de TI, las soluciones de TI deben ser identificadas, desarrolladas o adquiridas, así como implementadas e integradas dentro del proceso del negocio. Además, este dominio cubre los cambios y el mantenimiento realizados a sistemas existentes.

Procesos:

AI1 Identificación de Soluciones Automatizadas

AI1.1 Definición y Mantenimiento de los Requerimientos Técnicos y Funcionales del Negocio

AI1.2 Reporte de Análisis de Riesgos

AI1.3 Estudio de Factibilidad y Formulación de Cursos de Acción Alternativos

AI1.4 Requerimientos, Decisión de Factibilidad y Aprobación

Objetivo: Asegurar el mejor enfoque para cumplir con los requerimientos del usuario.

Para ello se realiza un análisis claro de las oportunidades alternativas comparadas contra los requerimientos de los usuarios y toma en consideración:

Definición de requerimientos de información para poder aprobar un proyecto de desarrollo.

Estudios de factibilidad con la finalidad de satisfacer los requerimientos del negocio establecidos para el desarrollo de un proyecto.

Arquitectura de información para tener en consideración el modelo de datos al definir soluciones y analizar la factibilidad de las mismas.

Seguridad con relación de costo-beneficio favorable para controlar que los costos no excedan los beneficios.

Pistas de auditoría para ello deben existir mecanismos adecuados. Dichos mecanismos deben proporcionar la capacidad de proteger datos sensitivos (ej. Identificación de usuarios contra divulgación o mal uso)

Contratación de terceros con el objeto de adquirir productos con buena calidad y excelente estado.

Aceptación de instalaciones y tecnología a través del contrato con el Proveedor donde se acuerda un plan de aceptación para las instalaciones y tecnología específica a ser proporcionada.

AI2 Adquisición y mantenimiento del software aplicativo

AI2.1 Diseño de Alto Nivel

AI2.2 Diseño Detallado

AI2.3 Control y Posibilidad de Auditar las Aplicaciones

AI2.4 Seguridad y Disponibilidad de las Aplicaciones

AI2.5 Configuración e Implantación de Software Aplicativo Adquirido

AI2.6 Actualizaciones Importantes en Sistemas Existentes

AI2.7 Desarrollo de Software Aplicativo

AI2.8 Aseguramiento de la Calidad del Software

AI2.9 Administración de los Requerimientos de Aplicaciones

AI2.10 Mantenimiento de Software Aplicativo

Objetivo: Proporciona funciones automatizadas que soporten efectivamente al negocio.

Para ello se definen declaraciones específicas sobre requerimientos funcionales y operacionales y una implementación estructurada con entregables claros y se toma en consideración:

Requerimientos de usuarios, para realizar un correcto análisis y obtener un software claro y fácil de usar.

Requerimientos de archivo, entrada, proceso y salida.

Interface usuario-maquina asegurando que el software sea fácil de utilizar y que sea capaz de auto documentarse.

Personalización de paquetes

Realizar pruebas funcionales (unitarias, de aplicación, de integración y de carga y estrés), de acuerdo con el plan de prueba del proyecto y con los estándares establecidos antes de ser aprobado por los usuarios.

Controles de aplicación y requerimientos funcionales

Documentación (materiales de consulta y soporte para usuarios) con el objeto de que los usuarios puedan aprender a utilizar el sistema o puedan

sacarse todas aquellas inquietudes que se les puedan presentar.

AI3 Adquisición y mantenimiento de la infraestructura tecnológica

AI3.1 Plan de Adquisición de Infraestructura Tecnológica

AI3.2 Protección y Disponibilidad del Recurso de Infraestructura

AI3.3 Mantenimiento de la Infraestructura

AI3.4 Ambiente de Prueba de Factibilidad

Objetivo: Proporcionar las plataformas apropiadas para soportar aplicaciones de negocios.

Para ello se realizara una evaluación del desempeño del hardware y software, la provisión de mantenimiento preventivo de hardware y la instalación, seguridad y control del software del sistema y toma en consideración:

Evaluación de tecnología para identificar el impacto del nuevo hardware o software sobre el rendimiento del sistema general.

Mantenimiento preventivo del hardware con el objeto de reducir la frecuencia y el impacto de fallas de rendimiento.

Seguridad del software de sistema, instalación y mantenimiento para no arriesgar la seguridad de los datos y programas ya almacenados en el mismo.

AI4 Desarrollo y mantenimiento de procedimientos

Objetivo: Asegurar el uso apropiado de las aplicaciones y de las soluciones tecnológicas establecidas.

Para ello se realiza un enfoque estructurado del desarrollo de manuales de procedimientos de operaciones para usuarios, requerimientos de servicio y material de entrenamiento y toma en consideración:

Manuales de procedimientos de usuarios y controles, de manera que los mismos permanezcan en permanente actualización para el mejor desempeño y control de los usuarios.

Manuales de Operaciones y controles, de manera que estén en permanente actualización.

Materiales de entrenamiento enfocados al uso del sistema en la práctica diaria.

AI5 Instalación y aceptación de los sistemas

AI7.1 Entrenamiento

AI7.2 Plan de Prueba

AI7.3 Plan de Implantación

AI7.4 Ambiente de Prueba

AI7.5 Conversión de Sistemas y Datos

AI7.6 Pruebas de Cambios

AI7.7 Prueba de Aceptación Final.

AI7.8 Promoción a Producción

AI7.9 Revisión Posterior a la Implantación

Objetivo: Verificar y confirmar que la solución sea adecuada para el propósito deseado

Para ello se realiza una migración de instalación, conversión y plan de aceptaciones adecuadamente formalizadas y toma en consideración:

Capacitación del personal de acuerdo al plan de entrenamiento definido y los materiales relacionados.

Conversión / carga de datos, de manera que los elementos necesarios del sistema anterior sean convertidos al sistema nuevo.

Pruebas específicas (cambios, desempeño, aceptación final, operacional) con el objeto de obtener un producto satisfactorio.

Acreditación de manera que la Gerencia de operaciones y usuaria acepten los resultados de las pruebas y el nivel de seguridad para los sistemas, junto con el riesgo residual existente.

Revisiones post implementación con el objeto de reportar si el sistema proporciona los beneficios esperados de la manera más económica.

AI6 Administración de los cambios

AI6.1 Estándares y Procedimientos para Cambios

AI6.2 Evaluación de Impacto, Priorización y Autorización

AI6.3 Cambios de Emergencia

AI6.4 Seguimiento y Reporte del Estatus de Cambio

AI6.5 Cierre y Documentación del Cambio

Objetivo: Minimizar la probabilidad de interrupciones, alteraciones no autorizadas y errores.

Esto se hace posible a través de un sistema de administración que permita el análisis, implementación y seguimiento de todos los cambios requeridos y llevados a cabo a la infraestructura de TI actual y toma en consideración:

- Identificación de cambios tanto internos como por parte de proveedores

- Procedimientos de categorización, priorización y emergencia de solicitudes de cambios.

- Evaluación del impacto que provocaran los cambios.

- Autorización de cambios

- Manejo de liberación de manera que la liberación de software este regida por procedimientos formales asegurando aprobación, empaque, pruebas de regresión, entrega, etc.

- Distribución de software, estableciendo medidas de control específicas para asegurar la distribución de software correcto al lugar correcto, con integridad y de manera oportuna.

Dominio: Entregar y Dar Soporte.

En este dominio se hace referencia a la entrega de los servicios requeridos, que abarca desde las operaciones tradicionales hasta el entrenamiento, pasando por seguridad y aspectos de continuidad. Con el fin de proveer servicios, deberán establecerse los procesos de soporte necesarios. Este dominio incluye el procesamiento de los datos por sistemas de aplicación, frecuentemente clasificados como controles de aplicación.

Procesos

DS1 Definición de niveles de servicio

DS1.1 Marco de Trabajo de la Administración de los Niveles de Servicio

DS1.2 Definición de Servicios

DS1.3 Acuerdos de Niveles de Servicio

DS1.4 Acuerdos de Niveles de Operación

DS1.5 Monitoreo y Reporte del Cumplimiento de los Niveles de Servicio

DS1.6 Revisión de los Acuerdos de Niveles de Servicio y de los Contratos

Objetivo: Establecer una comprensión común del nivel de servicio requerido

Para ello se establecen convenios de niveles de servicio que formalicen los criterios de desempeño contra los cuales se medirá la cantidad y la calidad del servicio y se toma en consideración:

Convenios formales que determinen la disponibilidad, confiabilidad, desempeño, capacidad de crecimiento, niveles de soporte proporcionados al usuario, plan de contingencia / recuperación, nivel mínimo aceptable de funcionalidad del sistema satisfactoriamente liberado, restricciones (límites en la cantidad de trabajo), cargos por servicio, instalaciones de impresión central (disponibilidad), distribución de impresión central y procedimientos de cambio.

Definición de las responsabilidades de los usuarios y de la función de servicios de información.

Procedimientos de desempeño que aseguren que la manera y las responsabilidades sobre las relaciones que rigen el desempeño entre todas las partes involucradas sean establecidas, coordinadas, mantenidas y comunicadas a todos los departamentos afectados.

Definición de dependencias asignando un Gerente de nivel de Servicio que sea responsable de monitorear y reportar los alcances de los criterios de desempeño del servicio especificado y todos los problemas encontrados durante el procesamiento.

Provisiones para elementos sujetos a cargos en los acuerdos de niveles de servicio para hacer posibles comparaciones y decisiones de niveles de servicios contra su costo.

Garantías de integridad

Convenios de confidencialidad

Implementación de un programa de mejoramiento del servicio.

DS2 Administración de servicios prestados por terceros

DS2.1 Identificación de Todas las Relaciones con Proveedores

DS2.2 Gestión de Relaciones con Proveedores

DS2.3 Administración de Riesgos del Proveedor

DS2.4 Monitoreo del Desempeño del Proveedor

Objetivo: Asegurar que las tareas y responsabilidades de las terceras partes estén claramente definidas, que cumplan y continúen satisfaciendo los requerimientos Para ello se establecen medidas de control dirigidas a la revisión y monitoreo de contratos y procedimientos existentes, en cuanto a su efectividad y suficiencia, con respecto a las políticas de la organización y toma en consideración:

Acuerdos de servicios con terceras partes a través de contratos entre la organización y el proveedor de la administración de instalaciones este basado en niveles de procesamiento requeridos, seguridad, monitoreo y requerimientos de contingencia, así como en otras estipulaciones según sea apropiado.

Acuerdos de confidencialidad. Además, se deberá calificar a los terceros y el contrato deberá definirse y acordarse para cada relación de servicio con un proveedor.

Requerimientos legales regulatorios de manera de asegurar que estos concuerde con los acuerdos de seguridad identificados, declarados y acordados

Monitoreo de la entrega de servicio con el fin de asegurar el cumplimiento de los acuerdos del contrato.

DS3 Administración de desempeño y capacidad

DS3.1 Planeación del Desempeño y la Capacidad

DS3.2 Capacidad y Desempeño Actual

DS3.3 Capacidad y Desempeño Futuros

DS3.4 Disponibilidad de Recursos de TI

DS3.5 Monitoreo y Reporte

Objetivo: Asegurar que la capacidad adecuada está disponible y que se esté haciendo el mejor uso de ella para alcanzar el desempeño deseado.

Para ello se realizan controles de manejo de capacidad y desempeño que recopilen datos y reporten acerca del manejo de cargas de trabajo, tamaño de aplicaciones, manejo y demanda de recursos y toma en consideración:

Requerimientos de disponibilidad y desempeño de los servicios de sistemas de información

Monitoreo y reporte de los recursos de tecnología de información.

Utilizar herramientas de modelado apropiadas para producir un modelo del sistema actual para apoyar el pronóstico de los requerimientos de capacidad, confiabilidad de configuración, desempeño y disponibilidad.

Administración de capacidad estableciendo un proceso de planeación para la revisión del desempeño y capacidad de hardware con el fin de asegurar que siempre exista una capacidad justificable económicamente para procesar cargas de trabajo con cantidad y calidad de desempeño

Prevenir que se pierda la disponibilidad de recursos mediante la implementación de mecanismos de tolerancia de fallas, de asignación equitativos de recursos y de prioridad de tareas.

DS4 Asegurar el Servicio Continuo

DS4.1 Marco de Trabajo de Continuidad de TI

DS4.2 Planes de Continuidad de TI

DS4.3 Recursos Críticos de TI

DS4.4 Mantenimiento del Plan de Continuidad de TI

DS4.5 Pruebas del Plan de Continuidad de TI

DS4.6 Entrenamiento del Plan de Continuidad de TI

DS4.7 Distribución del Plan de Continuidad de TI

DS4.8 Recuperación y Reanudación de los Servicios de TI

DS4.9 Almacenamiento de Respaldos Fuera de las Instalaciones

DS4.10 Revisión Post Reanudación

Objetivo: mantener el servicio disponible de acuerdo con los requerimientos y continuar su provisión en caso de interrupciones.

Para ello se tiene un plan de continuidad probado y funcional, que esté alineado con el plan de continuidad del negocio y relacionado con los requerimientos de negocio y toma en consideración:

Planificación de Severidad

Plan Documentado

Procedimientos Alternativos

Respaldo y Recuperación

Pruebas y entrenamiento sistemático y singulares

DS5 Garantizar la seguridad de sistemas

DS5.1 Administración de la Seguridad de TI

DS5.2 Plan de Seguridad de TI

DS5.3 Administración de Identidad

DS5.4 Administración de Cuentas del Usuario

DS5.5 Pruebas, Vigilancia y Monitoreo de la Seguridad

DS5.6 Definición de Incidente de Seguridad

DS5.7 Protección de la Tecnología de Seguridad

DS5.8 Administración de Llaves Criptográficas

DS5.9 Prevención, Detección y Corrección de Software Malicioso

DS5.10 Seguridad de la Red

DS5.11 Intercambio de Datos Sensitivos

Objetivo: salvaguardar la información contra uso no autorizados, divulgación, modificación, daño o pérdida

Para ello se realizan controles de acceso lógico que aseguren que el acceso a sistemas, datos y programas está restringido a usuarios autorizados y toma en consideración:

Autorización, autenticación y el acceso lógico junto con el uso de los recursos de TI deberá restringirse a través de la instrumentación de mecanismos de autenticación de usuarios identificados y recursos asociados con las reglas de acceso.

Perfiles e identificación de usuarios estableciendo procedimientos para asegurar acciones oportunas relacionadas con la requisición, establecimiento, emisión, suspensión y suspensión de cuentas de usuario

Administración de llaves criptográficas definiendo implementando procedimientos y protocolos a ser utilizados en la generación, distribución, certificación, almacenamiento, entrada, utilización y archivo de llaves criptográficas con el fin de asegurar la protección de las mismas

Manejo, reporte y seguimiento de incidentes implementado capacidad para la atención de los mismos

Prevención y detección de virus tales como Caballos de Troya, estableciendo adecuadas medidas de control preventivas, detectivas y correctivas.

Utilización de Firewalls si existe una conexión con Internet u otras redes públicas en la organización

DS6 Educación y entrenamiento de usuarios

DS6.1 Identificación de Necesidades de Entrenamiento y Educación

DS6.2 Impartición de Entrenamiento y Educación

DS6.3 Evaluación del Entrenamiento Recibido

Objetivo: Asegurar que los usuarios estén haciendo un uso efectivo de la tecnología y estén conscientes de los riesgos y responsabilidades involucrados.

Para ello se realiza un plan completo de entrenamiento y desarrollo y se toma en consideración:

Currículo de entrenamiento estableciendo y manteniendo procedimientos para identificar y documentar las necesidades de entrenamiento de todo el personal que haga uso de los servicios de información.

Campañas de concientización, definiendo los grupos objetivos, identificar y asignar entrenadores y organizar oportunamente las sesiones de entrenamiento

Técnicas de concientización proporcionando un programa de educación y entrenamiento que incluya conducta ética de la función de servicios de información

DS7 Identificación y asignación de costos

DS7.1 Definición de Servicios

DS7.2 Contabilización de TI

DS7.3 Modelación de Costos y Cargos

DS7.4 Mantenimiento del Modelo de Costos

Objetivo: Asegurar un conocimiento correcto de los costos atribuibles a los servicios de TI

Para ello se realiza un sistema de contabilidad de costos que asegure que éstos sean registrados, calculados y asignados a los niveles de detalle requeridos y toma en consideración:

Los elementos sujetos a cargo deben ser recursos identificables, medibles y predecibles para los usuarios

Procedimientos y políticas de cargo que fomenten el uso apropiado de los recursos de cómputo y aseguren el trato justo de los departamentos usuarios y sus necesidades

Tarifas definiendo e implementando procedimientos de costeo de prestar servicios, para ser analizados, monitoreados, evaluados asegurando al mismo tiempo la economía

DS8 Apoyo y asistencia a los clientes de TI

Objetivo: asegurar que cualquier problema experimentado por los usuarios sea atendido apropiadamente

Para ello se realiza un Buró de ayuda que proporcione soporte y asesoría de primera línea y toma en consideración:

Consultas de usuarios y respuesta a problemas estableciendo un soporte de una función de buró de ayuda

Monitoreo de consultas y despacho estableciendo procedimientos que aseguren que las preguntas de los clientes que pueden ser resueltas sean reasignadas al nivel adecuado para atenderlas

Análisis y reporte de tendencias adecuado de las preguntas de los clientes y su solución, de los tiempos de respuesta y la identificación de tendencias

DS9 Administración de la configuración

DS9.1 Repositorio y Línea Base de Configuración

DS9.2 Identificación y Mantenimiento de Elementos de Configuración

DS9.3 Revisión de Integridad de la Configuración

Objetivo: Dar cuenta de todos los componentes de TI, prevenir alteraciones no autorizadas, verificar la existencia física y proporcionar una base para el sano manejo de cambios

Para ello se realizan controles que identifiquen y registren todos los activos de TI así como su localización física y un programa regular de verificación que confirme su existencia y toma en consideración:

Registro de activos estableciendo procedimientos para asegurar que sean registrados únicamente elementos de configuración autorizados e identificables en el inventario, al momento de adquisición

Administración de cambios en la configuración asegurando que los registros de configuración reflejen el status real de todos los elementos de la configuración

Chequeo de software no autorizado revisando periódicamente las

computadoras personales de la organización

Controles de almacenamiento de software definiendo un área de almacenamiento de archivos para todos los elementos de software válidos en las fases del ciclo de vida de desarrollo de sistemas

DS10 Administración de Problemas

DS10.1 Identificación y Clasificación de Problemas

DS10.2 Rastreo y Resolución de Problemas

DS10.3 Cierre de Problemas

DS10.4 Integración de las Administraciones de Cambios, Configuración y Problemas

Objetivo: Asegurar que los problemas e incidentes sean resueltos y que sus causas sean investigadas para prevenir que vuelvan a suceder.

Para ello se necesita un sistema de manejo de problemas que registre y dé seguimiento a todos los incidentes, además de un conjunto de procedimientos de escalamiento de problemas para resolver de la manera más eficiente los problemas identificados. Este sistema de administración de problemas deberá también realizar un seguimiento de las causas a partir de un incidente dado.

DS11 Administración de Datos

DS11.1 Requerimientos del Negocio para Administración de Datos

DS11.2 Acuerdos de Almacenamiento y Conservación

DS11.3 Sistema de Administración de Librerías de Medios

DS11.4 Eliminación

DS11.5 Respaldo y Restauración

DS11.6 Requerimientos de Seguridad para la Administración de Datos

Objetivo: Asegurar que los datos permanezcan completos, precisos y válidos durante su entrada, actualización, salida y almacenamiento.

Lo cual se logra a través de una combinación efectiva de controles generales y de aplicación sobre las operaciones de TI. Para tal fin, la gerencia deberá diseñar formatos de entrada de datos para los usuarios de manera

que se minimicen los errores y las omisiones durante la creación de los datos.

Este proceso deberá controlar los documentos fuentes (de donde se extraen los datos), de manera que estén completos, sean precisos y se registren apropiadamente. Se deberán crear también procedimientos que validen los datos de entrada y corrijan o detecten los datos erróneos, como así también procedimientos de validación para transacciones erróneas, de manera que éstas no sean procesadas. Cabe destacar la importancia de crear procedimientos para el almacenamiento, respaldo y recuperación de datos, teniendo un registro físico (discos, disquetes, CDs y cintas magnéticas) de todas las transacciones y datos manejados por la organización, albergados tanto dentro como fuera de la empresa.

La gerencia deberá asegurar también la integridad, autenticidad y confidencialidad de los datos almacenados, definiendo e implementando procedimientos para tal fin.

DS12 Administración de las instalaciones

DS12.1 Selección y Diseño del Centro de Datos

DS12.2 Medidas de Seguridad Física

DS12.3 Acceso Físico

DS12.4 Protección Contra Factores Ambientales

DS12.5 Administración de Instalaciones Físicas

Objetivo: Proporcionar un ambiente físico conveniente que proteja al equipo y al personal de TI contra peligros naturales (fuego, polvo, calor excesivos) o fallas humanas lo cual se hace posible con la instalación de controles físicos y ambientales adecuados que sean revisados regularmente para su funcionamiento apropiado definiendo procedimientos que provean control de acceso del personal a las instalaciones y contemplen su seguridad física.

DS13 Administración de la operación

DS13.1 Procedimientos e Instrucciones de Operación

DS13.2 Programación de Tareas

DS13.3 Monitoreo de la Infraestructura de TI

DS13.4 Documentos Sensitivos y Dispositivos de Salida

DS13.5 Mantenimiento Preventivo del Hardware

Objetivo: Asegurar que las funciones importantes de soporte de TI estén siendo llevadas a cabo regularmente y de una manera ordenada.

Esto se logra a través de una calendarización de actividades de soporte que sea registrada y completada en cuanto al logro de todas las actividades. Para ello, la gerencia deberá establecer y documentar procedimientos para las operaciones de tecnología de información (incluyendo operaciones de red), los cuales deberán ser revisados periódicamente para garantizar su eficiencia y cumplimiento.

Dominio: Monitorear y Evaluar.

Todos los procesos de una organización necesitan ser evaluados regularmente a través del tiempo para verificar su calidad y suficiencia en cuanto a los requerimientos de control, integridad y confidencialidad. Este es, precisamente, el ámbito de este dominio.

Procesos

M1 Monitoreo del Proceso

ME1.1 Enfoque del Monitoreo

ME1.2 Definición y Recolección de Datos de Monitoreo

ME1.3 Método de Monitoreo

ME1.4 Evaluación del Desempeño

ME1.5 Reportes al Consejo Directivo y a Ejecutivos

ME1.6 Acciones Correctivas

Objetivo: Asegurar el logro de los objetivos establecidos para los procesos de TI.

Lo cual se logra definiendo por parte de la gerencia reportes e indicadores de desempeño gerenciales y la implementación de sistemas de soporte así como la atención regular a los reportes emitidos.

Para ello la gerencia podrá definir indicadores claves de desempeño y/o factores críticos de éxito y compararlos con los niveles objetivos propuestos para evaluar el desempeño de los procesos de la organización. La gerencia deberá también medir el grado de satisfacción del los clientes con respecto a los servicios de información proporcionados para identificar deficiencias en los niveles de servicio y establecer objetivos de mejoramiento, confeccionando informes que indiquen el avance de la organización hacia los objetivos propuestos.

M2 Evaluar lo adecuado del Control Interno

ME2.1 Monitoreo del Marco de Trabajo de Control Interno

ME2.2 Revisiones de Auditoría

ME2.3 Excepciones de Control

ME2.4 Auto Evaluación del Control

ME2.5 Aseguramiento del Control Interno

ME2.6 Control Interno para Terceros

ME2.7 Acciones Correctivas

Objetivo: Asegurar el logro de los objetivos de control interno establecidos para los procesos de TI.

Para ello la gerencia es la encargada de monitorear la efectividad de los controles internos a través de actividades administrativas y de supervisión, comparaciones, reconciliaciones y otras acciones rutinarias., evaluar su efectividad y emitir reportes sobre ellos en forma regular. Estas actividades de monitoreo continuo por parte de la Gerencia deberán revisar la existencia de puntos vulnerables y problemas de seguridad.

M3 Obtención de Aseguramiento Independiente

ME3.1 Identificar los Requerimientos de las Leyes, Regulaciones y Cumplimientos Contractuales

ME3.2 Optimizar la Respuesta a Requerimientos Externos

ME3.3 Evaluación del Cumplimiento con Requerimientos Externos

ME3.4 Aseguramiento Positivo del Cumplimiento

ME3.5 Reportes Integrados

Objetivo: Incrementar los niveles de confianza entre la organización, clientes y proveedores externos. Este proceso se lleva a cabo a intervalos regulares de tiempo.

Para ello la gerencia deberá obtener una certificación o acreditación independiente de seguridad y control interno antes de implementar nuevos servicios de tecnología de información que resulten críticos, como así también para trabajar con nuevos proveedores de servicios de tecnología de información. Luego la gerencia deberá adoptar como trabajo rutinario tanto hacer evaluaciones periódicas sobre la efectividad de los servicios de tecnología de información y de los proveedores de estos servicios como así también asegurarse el cumplimiento de los compromisos contractuales de los servicios de tecnología de información y de los proveedores de estos servicios.

M4 Proveer Auditoria Independiente

o ME4.1 Establecimiento de un Marco de Gobierno de TI

ME4.2 Alineamiento Estratégico

ME4.3 Entrega de Valor

ME4.4 Administración de Recursos

ME4.5 Administración de Riesgos

ME4.6 Medición del Desempeño

ME4.7 Aseguramiento Independiente

Objetivo: Incrementar los niveles de confianza y beneficiarse de recomendaciones basadas en mejores prácticas de su implementación, lo que se logra con el uso de auditorías independientes desarrolladas a intervalos regulares de tiempo. Para ello la gerencia deberá establecer los estatutos para la función de auditoría, destacando en este documento la responsabilidad, autoridad y obligaciones de la auditoria. El auditor deberá ser independiente del auditado, esto significa que los auditores no deberán

estar relacionados con la sección o departamento que esté siendo auditado y en lo posible deberá ser independiente de la propia empresa.

Esta auditoría deberá respetar la ética y los estándares profesionales, seleccionando para ello auditores que sean técnicamente competentes, es decir que cuenten con habilidades y conocimientos que aseguren tareas efectivas y eficientes de auditoría.

La función de auditoría deberá proporcionar un reporte que muestre los objetivos de la auditoría, período de cobertura, naturaleza y trabajo de auditoría realizado, como así también la organización, conclusión y recomendaciones relacionadas con el trabajo de auditoría llevado a cabo.

Los 34 procesos propuestos se concretan en 32 objetivos de control detallados anteriormente.

Un Control se define como "las normas, estándares, procedimientos, usos y costumbres y las estructuras organizativas, diseñadas para proporcionar garantía razonable de que los objetivos empresariales se alcancen y que los eventos no deseados se preverán o se detectaran, y corregirán"

Un Objetivo de Control se define como "la declaración del resultado deseado o propuesto que se ha de alcanzar mediante la aplicación de procedimientos de control en cualquier actividad de TI".

En resumen, la estructura conceptual se puede enfocar desde tres puntos de vista:

- Los recursos de las TI

- Los criterios empresariales que deben satisfacer la información

- Los procesos de TI

Estos dominios facilitan que la generación y procesamiento de la información cumplan con las características de efectividad, eficiencia, confidencialidad, integridad, disponibilidad, cumplimiento y confiabilidad. Además, se toma en cuenta los recursos que proporciona la tecnología de

información, tales como: datos, aplicaciones, plataformas tecnológicas, instalaciones y recurso humano.

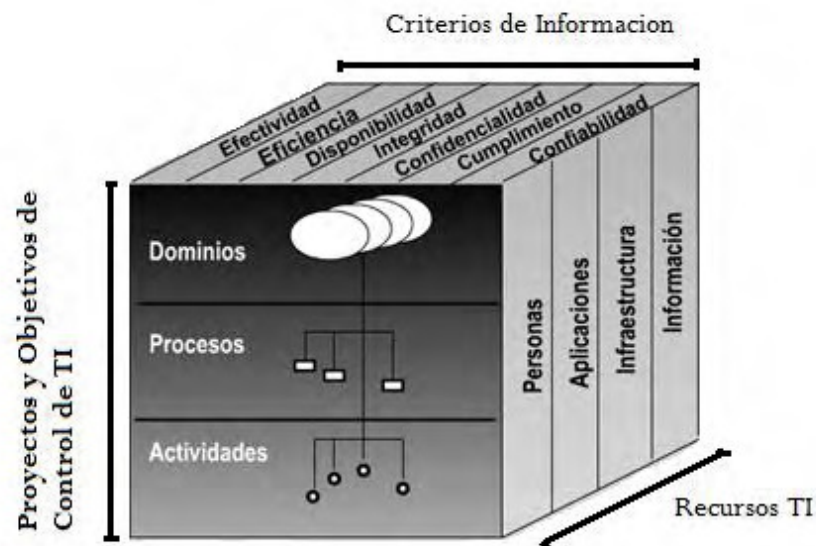


Figura 1. Las tres dimensiones conceptuales de COBIT

Las tres dimensiones conceptuales de COBIT

Toda organización, necesita desarrollar una tecnología que le permita rediseñar actividades y procesos para lograr un mejor desempeño en las mismas, es así como el COBIT es fundamental en toda empresa, pues esta metodología reduce posibles vulnerabilidades y riesgos de los recursos de las tecnologías de información y así mismo evalúa el resultado de los objetivos de la empresa.

COSO (Sponsoring Organizations of the Treadway Commission). COSO inicio en 1985 recomendando que las organizaciones patrocinadoras de la Comisión trabajen juntas para desarrollar sistemas integrados de orientación sobre el control interno.

El modelo COSO define el control interno como un conjunto de procesos, realizado por los directivos de una organización, y creado para garantizar el

logro de los objetivos. COSO consta de cinco elementos, estos elementos proporcionan un marco eficaz para describir y analizar el sistema de control interno, los cuales son:

Entorno de control. Sirve como base para los demás componentes del control interno, proporcionando disciplina y estructura. Los factores del entorno de control incluyen la integridad, los valores éticos, el estilo de funcionamiento de la administración, la delegación de los sistemas de autoridad, así como los procesos de gestión y desarrollo de las personas en la empresa.

Evaluación del riesgo. Cada empresa se enfrenta a una variedad de riesgos de fuentes externas e internas que deben ser evaluados. Una condición previa para la evaluación de riesgos es el establecimiento de objetivos y por lo tanto la evaluación de riesgos es la caracterización y análisis de los riesgos relevantes para la consecución de los objetivos asignados. La evaluación de riesgos es un requisito previo para establecer cómo los riesgos deberían ser manejados.

Las actividades de control. Las actividades de control son las políticas y procedimientos que ayudan a asegurar la gestión de las directivas se llevan a cabo. También garantizan la toma de medidas necesarias para hacer frente a los riesgos que pueden obstaculizar el logro de los objetivos de la entidad. Las actividades de control se originan en toda la organización, en todos los niveles y en todas las funciones. Estos incluyen una amplia gama de actividades tan diversas como aprobaciones, autorizaciones, verificaciones, conciliaciones, revisiones de desempeño operativo, la seguridad de los activos y la separación de funciones.

Información y comunicación. Los sistemas de información juegan un papel importante en los sistemas de control interno que producen los informes, incluidos los operativos, financieros y el cumplimiento de información relacionada, que permiten elaborar y controlar la entidad. De manera más amplia, la comunicación eficaz debe garantizar los flujos de

información hacia abajo, y hasta a través de la organización.

Seguimiento. Los sistemas de control interno deben ser supervisados, un proceso que evalúa la calidad del desempeño del sistema en el tiempo. Esto se

logra a través de continuas actividades de supervisión o evaluaciones por separado. Las fallas de control interno detectadas a través de estas actividades deberían notificar las medidas de planificación y correctivas garantizando la mejora continua del sistema.

Algunas diferencias entre COSO y COBIT, que son los dos modelos más difundidos actualmente son:

El modelo COSO está enfocado a toda la empresa, mientras que el COBIT se limita a las tecnologías de la información (TI).

El COBIT establece como uno de sus objetivos la seguridad de la información, por el contrario COSO, no lo toma en cuenta en su evaluación.

El modelo de control interno que presenta el COSO no es muy completo, a diferencia de la metodología COBIT que contempla políticas, procedimientos y estructuras organizativas, además de procesos para definir el modelo de control interno.

Técnicas De Auditoria De Sistemas

Selección de áreas de auditoria. Dada la magnitud del universo por auditar, la revisión debe hacerse de manera selectiva, esta técnica es adecuada para empresas con múltiples localizaciones o sucursales, con el fin de dar prioridad a los procesos, se aplican evaluaciones estadísticas a estos en forma periódica, para poder clasificar cuales de estos procesos son claves para el proceso de auditoría.

El uso del computador es indispensable en esta técnica ya que se manejan grandes volúmenes de información y los tamaños de muestra son muy grandes, además esta herramienta mejora la efectividad y eficiencia de los procesos de auditoría, también proporciona pruebas de control efectivas.

Una desventaja de esta técnica es que la construcción de estos modelos es costosa y consume demasiado tiempo y se deben tener conocimientos avanzados y especializados en materia de diseño y construcción.

Simulación – Modelaje. Esta técnica consiste en la creación de modelos conceptuales o físicos bajo ciertas condiciones y simular el comportamiento del sistema computacional, de un programa, o evaluar el sistema financiero en forma periódica (evaluar el incremento o decremento de las cuentas contables o áreas financieras en términos de ingresos, egresos y gastos, para determinar el crecimiento organizacional), estos modelos brindan la posibilidad de realizar pruebas controladas o realizar comparaciones entre valores proyectados y valores reales en materia financiera, con los resultados obtenidos en la simulación el auditor puede dar una opinión acerca del rendimiento del sistema y también proponer medidas de contingencia al respecto.

Sistema de puntajes (Scoring). A diferencia de las anteriores técnicas la evaluación a los procesos y aplicaciones computarizadas se realiza de forma manual, con el fin de priorizar procesos con base en el análisis de riesgos, con la asignación de valores numéricos a las características claves, el auditor asignará la ponderación que este considere para cada factor, teniendo en cuenta el análisis de riesgo realizado con anterioridad que permita obtener un alto grado de confiabilidad, para llevar a cabo esta técnica se deberá diligenciar un formato de puntajes el que dará por resultado la clasificación para la auditoría.

Técnicas para operacionalizar la función de auditoría

Software de auditoría multisitio. Es una técnica aplicable a grandes empresas que tengan diferentes centros electrónicos de datos (PED, Procesamiento electrónico de datos). Desarrollando un programa o grupo de programas e instalándolos en las regionales para que sean utilizados por los auditores. Se requiere que se guarde uniformidad en el software utilizado en los PED para facilitar el proceso de auditaje, esta técnica es aplicada en ambientes de procesamiento distribuido.

Centros de competencia. Esta técnica funciona a la inversa que la

técnica de multisitio, ya que centra toda la información de las regionales en un centro de competencia y después de su análisis, evaluación e informes son enviados a las sucursales para tomar las respectivas decisiones.

Técnicas para probar controles de sistemas en funcionamiento

Métodos de datos de prueba. Las técnicas de datos de prueba se usan durante una auditoría alimentando datos en el sistema de computadora de una entidad y comparando los resultados obtenidos con resultados predeterminados. Un elemento de gran importancia en esta técnica es el diseño de los datos de prueba, lo que en últimas determinara la efectividad de esta técnica. Es recomendable seleccionar datos normales, ilógicos, imposibles, con valores extremos, etc. Un auditor podría usar esta técnica para:

Poner a prueba los controles específicos en los programas de cómputo, como son la clave de acceso en línea y los controles para el acceso a datos.

Colocar a prueba transacciones de prueba seleccionadas a partir de transacciones anteriores o creadas por el auditor para verificar las características específicas de procesamiento del sistema de cómputo de una dependencia. En general, estas transacciones se procesan fuera del procesamiento normal que utilice la dependencia.

Poner a prueba transacciones usadas en un mecanismo integrado de pruebas donde se establece una unidad modelo (por ejemplo, un departamento o empleado ficticio), a la cual se le registran las transacciones durante el ciclo de procesamiento normal.

Realizar pruebas de cumplimiento de los controles generales, por ejemplo, el uso de datos de prueba para verificar los procedimientos de acceso a las bibliotecas del programa.

Pruebas de cumplimiento de los controles de aplicación, por ejemplo,

el uso de los datos de prueba para verificar el funcionamiento de un procedimiento programado.

Cuando se procesan los datos de prueba con el procesamiento normal de la entidad, el auditor se asegura de que las transacciones de prueba sean eliminadas posteriormente de los registros contables de la entidad.

Se debe tener en cuenta que si se trata de una entidad pequeña y se procesan volúmenes menores de datos, los métodos manuales pueden ser de costo más efectivo.

En los procedimientos de auditoría para controlar las aplicaciones de datos de prueba se deben realizar las siguientes acciones:

Controlar la secuencia de presentación de datos de prueba cuando se extienda a varios ciclos de procesamiento.

Realizar corridas de prueba que contengan pequeñas cantidades de datos de prueba antes de presentar los datos de prueba principales de la auditoría.

Predecir los resultados de los datos de prueba y compararlos con la salida real de datos de pruebas, para las transacciones individuales.

Confirmar que se usó la versión actual de los programas para procesar los datos de prueba.

Poner a prueba si los programas usados para procesar los datos de prueba fueron utilizados por la entidad durante el periodo aplicable de auditoría.

En síntesis se puede emplear esta técnica para: evaluación de controles específicos, verificación de validaciones, prueba de perfiles de acceso, prueba a transacciones seleccionadas con las siguientes ventajas y desventajas:

Evaluación del sistema en caso base (BCSE). Cuando la técnica de datos de prueba se mantiene en el tiempo para ser, consistente y cotidianamente, aplicada al sistema en producción, toma el nombre de Evaluación Del Sistema Del Caso Base (ESCB), en tal caso, la prueba es más completa y requiere de un alto grado de cooperación entre usuarios,

auditores y personal de sistemas.

Esta técnica se utiliza en auditorías que hacen uso de controles preventivos y detectivos a los sistemas, los cuales manejan aplicativos para sistemas contables, sistema de nómina, sistemas estadísticos, etc., y en fin sistemas que deban validar los campos de datos que se ingresarán al aplicativo, y de forma paralela evaluar los procedimientos internos del sistema.

Técnicas para la auditoría de información almacenada. El fin de un proceso auditor es asistir a la gerencia o al departamento auditado para brindar apoyo en la identificación de los diversos hallazgos y posibles riesgos, y formular soluciones que sirvan para el control que eviten estos errores y minimicen los riesgos, generalmente algunas tareas del proceso auditor toman demasiado tiempo como por ejemplo el planteamiento, desarrollo y documentación; la automatización de algunas tareas puede resultar muy productivo para el equipo auditor, especialmente en el caso de auditoría de sistemas donde algunos procesos se prestan para ser automatizados.

Estos procesos toman cada vez más fuerza a nivel mundial después de lo acontecido con los desfalcos que llevaron a la quiebra a grandes empresas como Parmalat (italiana) y Enron (norteamericana) los cual replantea el proceso de auditoría tanto interna, como externa y la utilización de herramientas informáticas tanto de nivel general como herramientas especializadas.

La automatización como se menciona anteriormente, se facilita para algunos procesos en la auditoría de sistemas, lo cual brinda algunos beneficios como la clara reducción en el tiempo y posiblemente de recursos en el desarrollo del proceso automatizado, la estandarización en los procesos y a su vez una mayor flexibilidad ante los cambios lo cual se puede ver reflejado en una mejora en la calidad, provee mecanismos de monitoreo y retroalimentación, además la posibilidad de realizar análisis con diversos criterios, tales como recalcular de operaciones, búsqueda avanzada de información, seguimiento de transacciones, etc.,

convirtiéndose así en un poderoso aliado del equipo auditor permitiéndoles enfocarse en otros campos y obtener así un mejor y más profundo resultado.

El avance tecnológico que se ha vivido en los últimos años en el mundo ha generado la importancia para las personas y empresas de mantenerse actualizado e informado, pero esta información debe cumplir con ciertas características importantes como la veracidad, confiabilidad y oportunidad de la misma. Con el fin de obtener y gestionar esta información han surgido las NTIC (Nuevas Tecnologías de la Información y la comunicación); gracias a esto la información que se ha convertido en uno de los más valiosos recursos en las empresas, puede ser obtenida, tratada y almacenada para una mejor toma de decisiones.

Al introducir una herramienta tan poderosa como el computador en el proceso de auditoría esto conlleva a la utilización de herramientas informáticas para analizar la información que en su gran mayoría se encuentra en medios de almacenamiento magnético (discos duros, cd, dvd), con esto se busca evaluar la consistencia que presentan los sistemas de información, análisis de datos de una muestra de transacciones para verificar la integridad, consistencia y confiabilidad de la información presentada a través de los sistemas de información, el auditor debe desarrollar procedimientos en el que se consideren la herramientas informáticas como apoyo para la realización de la auditoria.

Aplicaciones estandarizadas para grandes volúmenes de información. Es indispensable que las empresas realicen auditorias rigurosas frecuentemente, especialmente a las áreas más sensibles del negocio, realizar un manual del comportamiento de la empresa con las normas y procedimientos internos.

Seguridad Física

La seguridad física se refiere a medidas y controles diseñados para proteger los activos, recursos y personas de una organización de

amenazas físicas como robo, vandalismo, intrusión, desastres naturales y otros eventos que pueden causar daños o pérdidas. El campo de la seguridad física incluye todos los aspectos relacionados con la protección de las instalaciones, la infraestructura y el personal de una organización.

La seguridad física incluye varios elementos clave para proteger las instalaciones, los activos y el personal de una organización de amenazas físicas. Esto incluye implementar controles de acceso físico como cerraduras, tarjetas de acceso, sistemas de control de acceso biométrico y videovigilancia para evitar el acceso no autorizado a las instalaciones.

Además, la seguridad perimetral incluye proteger el perímetro físico de la propiedad con vallas, muros, barreras para vehículos y sistemas de detección de intrusos para ayudar a prevenir intrusiones no deseadas.

La protección de los activos físicos es otro fundamento y se refiere a la seguridad de los equipos, el inventario, las materias primas y los recursos críticos de una organización. Esto se logra mediante la implementación de medidas como candados, cables de seguridad, etiquetas de activos y sistemas de seguimiento de activos. La seguridad ambiental es esencial para proteger los activos de peligros como incendios, inundaciones y terremotos a través de sistemas de detección y extinción de incendios, alerta temprana y planes de respuesta a emergencias,

La protección de las personas es otra prioridad con medidas que incluyen la instalación de sistemas de alarma de emergencia, iluminación adecuada, formación en seguridad y procedimientos de evacuación. También, el control de acceso de vehículos es importante para evitar que vehículos no autorizados entren en las instalaciones mediante la implementación de controles como barreras de acceso, puertas automáticas, sistemas de reconocimiento de matrículas y control de acceso remoto.

Podemos decir que, la seguridad física incluye todas las medidas y controles diseñados para garantizar que el entorno operativo de una organización sea seguro protegiendo sus instalaciones, activos y personal de amenazas físicas.

Importancia de la seguridad física en el ámbito de la seguridad de la información.

La seguridad física juega un papel importante en la seguridad de la información al proteger los activos físicos que almacenan, procesan y transmiten datos importantes para la organización. Su importancia se refleja en varios aspectos clave. En primer lugar, reducir significativamente el riesgo de acceso no autorizado a la infraestructura de TI y a los datos confidenciales mediante la implementación de medidas como cerraduras de puertas, sistemas de control de acceso y videovigilancia para controlar el acceso a áreas críticas.

Además, la seguridad física ayuda a prevenir robos, vandalismo y vandalismo, reduciendo el riesgo de pérdida de datos y tiempo de inactividad. Esto es especialmente cierto para el cumplimiento legal, ya que muchas regulaciones y estándares de seguridad requieren controles físicos para proteger los activos de información y garantizar el cumplimiento legal.

Además, la seguridad física respalda y complementa los controles de seguridad lógicos, como los firewalls y el cifrado, para garantizar la eficacia de estos controles en la protección de la infraestructura que los respalda. También elimina los riesgos asociados con desastres naturales y fallas de hardware, y garantiza la disponibilidad e integridad de los datos en caso de eventos imprevistos. En resumen, la seguridad física es la base de la seguridad de la información. Garantiza la integridad, confidencialidad y disponibilidad de los datos clave de una organización. Su correcta implementación es fundamental para la protección integral de los activos de información.

Elementos y controles de seguridad física.

La seguridad física consta de varios elementos y controles diseñados para proteger las instalaciones, los activos y el personal de una organización de amenazas físicas. A continuación, en el cuadro 2 se presentan los aspectos más destacados y controles:

Cuadro 2
Elementos y Controles

Elementos y Controles	Concepto
Control de Acceso Físico	Cerraduras
	Tarjetas de Acceso
	Sistemas de Control de Acceso
	Biométrico
	Vigilancia por Video
Seguridad Perimetral	Cercas
	Muros
	Barreras Vehiculares
	Sistemas de Detección de Intrusos
	Vigilancia por Video
Vigilancia y Monitoreo	Sistemas de Monitoreo
	Sistemas de Detección y
Protección contra Desastres	Extinción de Incendios
	Sistemas de Alerta Temprana
	Planes de Respuesta a Emergencias
	Barreras de Entrada
	Puertas Automáticas
Controles de Acceso de Vehículos	Sistemas de Reconocimiento de Placas

Elaboración propia

Redes de Computadoras:

Las redes de computadoras son sistemas que permiten la comunicación y el intercambio de información entre dispositivos conectados, como computadoras, servidores y dispositivos móviles. Funcionan mediante la transmisión de datos a través de medios de comunicación, como cables de red o conexiones inalámbricas, utilizando protocolos de comunicación estándar. Esto facilita el acceso compartido a recursos, como archivos y aplicaciones, y permite la colaboración y el intercambio de datos entre usuarios y sistemas en una amplia variedad de entornos, desde entornos domésticos hasta entornos empresariales..

Tipos de redes y sus características.

LAN (Red de Área Local): Limitada a un área geográfica pequeña, como una oficina o un edificio. Alta velocidad y bajo costo de implementación.

WAN (Red de Área Amplia): Extiende su alcance sobre áreas geográficas más grandes, como ciudades o países. Utiliza servicios de telecomunicaciones y suele ser más lenta que una LAN.

MAN (Red de Área Metropolitana): Cubre una ciudad o una región metropolitana. Ofrece una velocidad y capacidad intermedias entre LAN y WAN.

Redes Inalámbricas: Utilizan tecnologías como Wi-Fi para la comunicación sin cables. Ofrecen movilidad y flexibilidad, pero pueden ser más vulnerables a intrusiones.

Redes de Malla: Cada dispositivo se conecta con múltiples nodos, lo que proporciona redundancia y fiabilidad. Son utilizadas en aplicaciones críticas donde la disponibilidad es fundamental,

Vulnerabilidades comunes en las redes de computadoras.

Falta de actualizaciones de seguridad: No aplicar parches y actualizaciones puede dejar sistemas vulnerables a exploits conocidos,

Contraseñas débiles: Contraseñas fáciles de adivinar o predeterminadas pueden ser fácilmente comprometidas por atacantes.

Ataques de ingeniería social: Los usuarios pueden ser engañados para revelar información confidencial o realizar acciones que comprometan la seguridad de la red.

Malware y ataques de phishing: Descargas de archivos infectados o hacer clic en enlaces maliciosos pueden infectar dispositivos con malware o comprometer credenciales de usuario.

Falta de cifrado: Las comunicaciones no cifradas pueden ser

interceptadas y los datos sensibles expuestos.

Configuraciones inseguras de dispositivos de red: Configuraciones predeterminadas o mal configuradas pueden dejar puertas traseras abiertas para atacantes.

Bases Legales

En esta sección se presentan los basamentos legales sobre los cuales se sustenta la investigación, esto se relaciona con lo expuesto por Querales (2017) "Son todos aquellos artículos que servirán de funcionamiento legal a la ejecución del proyecto". (p40), en este sentido la presente investigación es sustentada por artículos de la Constitución de República Bolivariana de Venezuela, artículos de la Ley Orgánica de Ciencia, Tecnología e Innovación y decretos.

Constitución de la República Bolivariana de Venezuela, Capítulo VI De los Derechos Culturales y Educativos.

Artículo 110. El Estado reconocerá el interés público de la ciencia, la tecnología, el conocimiento, la innovación y sus aplicaciones y los servicios de información necesarios por ser instrumentos fundamentales para el desarrollo económico, social y político del país, así como para la seguridad y soberanía nacional...

Artículo 108. Los centros educativos deben incorporar el conocimiento y aplicación de las nuevas tecnologías, de sus innovaciones, según los requisitos que establezca la ley.

Ley Orgánica de Ciencia, Tecnología e Innovación.

Artículo 21. La autoridad nacional con competencia en materia de ciencia, tecnología, innovación y sus aplicaciones creará mecanismos de

apoyo, promoción y difusión de invenciones e innovaciones populares, que generen bienestar a la población o logren un impacto económico o social en la Nación.

Artículo 18. La autoridad nacional con competencia en materia de ciencia, tecnología, innovación y sus aplicaciones, ejercerá la dirección en el área de tecnologías de información. En tal sentido, deberá:

Establecer políticas sobre la generación de contenidos en la red, respetando la diversidad, así como el carácter multiétnico y pluricultural de nuestra sociedad.

Resguardar la inviolabilidad del carácter confidencial de los datos electrónicos obtenidos en el ejercicio de las funciones de los órganos y entes públicos.

Definición de Términos Básicos

Según lo expuesto por Arias (2012) ““Consiste en dar el significado preciso y según el contexto a los conceptos principales, expresiones o variables involucradas en el problema y en los objetivos formulados”. (p108).” Basado en esto esta sección consiste en presentar los términos relacionados con la investigación del proyecto los cuales se presentan a continuación

Activo: En relación con la seguridad de la información, se refiere a cualquier información o sistema relacionado con el tratamiento de la misma que tenga valor para la organización. Según [ISO/IEC 13335-1:2004]: Cualquier cosa que tiene valor para la organización.

Alerta: Una notificación formal de que se ha producido un incidente relacionado con la seguridad de la información que puede evolucionar hasta convertirse en desastre.

Amenaza: Según [ISO/IEC 13335-1:2004]: causa potencial de un incidente no deseado, el cual puede causar el daño a un sistema o la organización.

Análisis de riesgos: Según [ISO/IEC Guía 73:2002]: Uso sistemático de la información para identificar fuentes y estimar el riesgo.

Aplicación: Aunque se suele utilizar indistintamente como sinónimo genérico de 'programa' es necesario subrayar que se trata de un tipo de programa específicamente dedicado al proceso de una función concreta dentro de la empresa.

Archivo de datos: Cualquier archivo creado dentro de una aplicación: por ejemplo, un documento creado por un procesador de textos, una hoja de cálculo, una base de datos o un gráfico. También denominado Documento.

Auditor: Persona encargada de verificar, de manera independiente, la calidad e integridad del trabajo que se ha realizado en un área particular.

Auditoría: Proceso planificado y sistemático en el cual un auditor obtiene evidencias objetivas que le permitan emitir un juicio informado sobre el estado y efectividad del SGSI de una organización.

Autenticación: Proceso que tiene por objetivo asegurar la identificación de una persona o sistema.

Bases de Datos: Colección de datos organizada de tal modo que el ordenador pueda acceder rápidamente a ella. Una base de datos relacionar es aquella en la que las conexiones entre los distintos elementos que forman la base de datos están almacenadas explícitamente con el fin de ayudar a la manipulación y el acceso a éstos.

Checklist: Lista de apoyo para el auditor con los puntos a auditar, que ayuda a mantener claros los objetivos de la auditoría, sirve de evidencia del plan de auditoría, asegura su continuidad y profundidad y reduce los prejuicios del auditor y su carga de trabajo. Este tipo de listas también se pueden utilizar durante la implantación del SGSI para facilitar su desarrollo.

Cliente: Cliente o 'programa cliente' es aquel programa que permite conectarse a un determinado sistema, servicio o red.

COBIT (Objetivos de Control de las Tecnologías de la Información y Tecnologías Relacionadas) Publicados y mantenidos por ISACA. Su misión

es investigar, desarrollar, publicar y promover un conjunto de objetivos de control de Tecnología de Información rectores, actualizados, internacionales y generalmente aceptados para ser empleados por gerentes de empresas y auditores.

Confidencialidad: Acceso a la información por parte únicamente de quienes estén autorizados. Según [ISO/IEC 13335-1:2004]: "característica/propiedad por la que la información no está disponible o revelada a individuos, entidades, o procesos no autorizados.

Control: Las políticas, los procedimientos, las prácticas y las estructuras organizativas concebidas para mantener los riesgos de seguridad de la información por debajo del nivel de riesgo asumido. (Nota: Control es también utilizado como sinónimo de salvaguarda o contramedida.

Conexión física: Permiten a las computadoras transmitir y recibir señales directamente. Las conexiones físicas están definidas por el medio empleado (pueden ser cables hasta satélites) para transmitir la señal, por la disposición geométrica de las computadoras (topología) y por el método usado para compartir información, desde textos, imágenes y hasta videos y sonidos.

Criptografía: Ciencia dedicada al estudio de técnicas capaces de conferir seguridad a los datos. El cifrado es fundamental a la hora de enviar datos a través de las redes de telecomunicaciones con el fin de conservar su privacidad.

Datos: Término general para la información procesada por un ordenador.

Desastre: Cualquier evento accidental, natural o malintencionado que interrumpe las operaciones o servicios habituales de una organización durante el tiempo suficiente como para verse la misma afectada de manera significativa.

Disponibilidad: Acceso a la información y los sistemas de tratamiento de la misma por parte de los usuarios autorizados cuando lo

requieran. Según [ISO/IEC 13335-1:2004]: característica o propiedad de permanecer accesible y disponible para su uso cuando lo requiera una entidad autorizada.

Evaluación de riesgos: Según [ISO/IEC Guía 73:2002]: proceso de comparar el riesgo estimado contra un criterio de riesgo dado con el objeto de determinar la importancia del riesgo.

Evento: Según [ISO/IEC TR 18044:2004]: Suceso identificado en un sistema, servicio o estado de la red que indica una posible brecha en la política de seguridad de la información o fallo de las salvaguardias, o una situación anterior desconocida que podría ser relevante para la seguridad.

Factibilidad: Es la disponibilidad de los recursos necesarios para llevar a cabo los objetivos o metas señaladas, sirve para recopilar datos relevantes sobre el desarrollo de un proyecto y en base a ello tomar la mejor decisión.

Gestión de riesgos: Proceso de identificación, control y minimización o eliminación, a un coste aceptable, de los riesgos que afecten a la información de la organización. Incluye la valoración de riesgos y el tratamiento de riesgos. Según [ISO/IEC Guía 73:2002]: actividades coordinadas para dirigir y controlar una organización con respecto al riesgo.

Hardware: Conjunto de dispositivos de los que consiste un sistema. Comprende componentes tales como el teclado, el Mouse, las unidades de disco y el monitor.

Impacto: El coste para la empresa de un incidente de la escala que sea, que puede o no ser medido en términos estrictamente financieros ej., pérdida de reputación, implicaciones legales, etc.

Incidente: Según [ISO/IEC TR 18044:2004]: Evento único o serie de eventos de seguridad de la información inesperados o no deseados que poseen una probabilidad significativa de comprometer las operaciones del negocio y amenazar la seguridad de la información.

Integridad: Mantenimiento de la exactitud y completitud de la información y sus métodos de proceso. Según [ISO/IEC 13335-1:2004]:

propiedad/característica de salvaguardar la exactitud y completitud de los activos.

Internet: Interconexión de redes informáticas que permite a las computadoras conectadas comunicarse directamente.

Inventario de activos: Lista de todos aquellos recursos (físicos, de información, software, documentos, servicios, personas, reputación de la organización, etc.) dentro del alcance del SGSI, que tengan valor para la organización y necesiten por tanto ser protegidos de potenciales riesgos.

ISACA: Information Systems Audit and Control Association. Publica COBIT y emite diversas acreditaciones en el ámbito de la seguridad de la información.

LAN (Local Área Network – Red de Área Local): Interconexión de computadoras y periféricos para formar una red dentro de una empresa u hogar, limitada generalmente a un edificio.

Metodología: Conjunto de métodos utilizados en la investigación científica

Norma: Principio que se impone o se adopta para dirigir la conducta o la correcta realización de una acción o el correcto desarrollo de una actividad.

Objetivo: Declaración del resultado o fin que se desea lograr mediante la implementación de procedimientos de control en una actividad de TI determinada.

Papeles de trabajo: Registra el planeamiento, naturaleza, oportunidad y alcance de los procedimientos de auditoría aplicados por el auditor y los resultados y conclusiones extraídas a la evidencia obtenida. Se utilizan para controlar el progreso del trabajo realizado para respaldar la opinión del auditor. Los papeles de trabajo pueden estar constituidos por datos conservados en papel, película, medios electrónicos u otros medios.

Password: Conocida también como 'clave de acceso'. Palabra o clave privada utilizada para confirmar una identidad en un sistema remoto que se utiliza para que una persona no pueda usurpar la identidad de otra.

Plan de contingencia: Es un tipo de plan preventivo, predictivo y reactivo. Presenta una estructura estratégica y operativa que ayudara a controlar una situación de emergencia y minimizar sus consecuencias negativas.

Política de seguridad: Documento que establece el compromiso de la Dirección y el enfoque de la organización en la gestión de la seguridad de la información. Según [ISO/IEC 27002:2005]: intención y dirección general expresada formalmente por la Dirección.

Procedimiento: Método o sistema estructurado para la ejecución de actividades. En computación, una subrutina o subprograma, como idea general, se presenta como un algoritmo separado del algoritmo principal, el cual permite resolver una tarea específica.

Proceso: Conjunto de operaciones lógicas y aritméticas ordenadas, cuyo fin es la obtención de resultados.

Programa: Secuencia de instrucciones que obliga al ordenador a realizar una tarea determinada.

Programa cliente: Programa cliente o simplemente 'cliente' es aquel programa que permite conectarse a un determinado sistema, servicio o red.

Red: Servicio de comunicación de datos entre ordenadores. Conocido también por su denominación inglesa: 'network'. Se dice que una red está débilmente conectada cuando la red no mantiene conexiones permanentes entre los ordenadores que la forman. Esta estructura es propia de redes no profesionales con el fin de abaratar su mantenimiento.

Repositorio: Donde se almacenan los elementos definidos o creados por la herramienta, y cuya gestión se realiza mediante el apoyo de un Sistema de Gestión de Base de Datos (SGBD) o de un sistema de gestión de ficheros

Riesgo: Posibilidad de que una amenaza concreta pueda explotar una vulnerabilidad para causar una pérdida o daño en un activo de información. Según [ISO Guía 73:2002]: combinación de la probabilidad de un evento y sus consecuencias.

Router: Es un dispositivo que proporciona conectividad a nivel de red o nivel tres en el modelo OSI. Su función principal consiste en enviar o encaminar paquetes de datos de una red a otra, es decir, interconectar subredes, entendiendo por subred un conjunto de máquinas IP que se pueden comunicar sin la intervención de un router (mediante bridges), y que por tanto tienen prefijos de red distintos.

Segregación de tareas: Reparto de tareas sensibles entre distintos empleados para reducir el riesgo de un mal uso de los sistemas e informaciones deliberado o por negligencia.

Seguridad de la información: Preservación de la confidencialidad, integridad y disponibilidad de la información; además, otras propiedades como autenticidad, responsabilidad, no repudio y fiabilidad pueden ser también consideradas.

Selección de controles: Proceso de elección de los controles que aseguren la reducción de los riesgos a un nivel aceptable.

Servidor: Ordenador que ejecuta uno o más programas simultáneamente con el fin de distribuir información a los ordenadores que se conecten con él para dicho fin. Vocablo más conocido bajo su denominación inglesa 'server'

Sistema de información: Se denomina Sistema de Información al conjunto de procedimientos manuales y/o automatizados que están orientados a proporcionar información para la toma de decisiones.

Software: Componentes inmateriales del ordenador: programas, sistemas operativos, etc.

Switch: Dispositivo digital lógico de interconexión de redes de computadoras que opera en la capa de enlace de datos del modelo OSI. Su función es interconectar dos o más segmentos de red, de manera similar a los puentes de red, pasando datos de un segmento a otro de acuerdo con la dirección MAC de destino de las tramas en la red.

TI: Tecnologías de Información

Técnica: La técnica es el procedimiento o el conjunto de procedimientos que tienen como objetivo obtener un resultado determinado, ya sea en el campo de la ciencia, de la tecnología, de las artesanías o en otra actividad

Tratamiento de riesgos: Según [ISO/IEC Guía 73:2002]: Proceso de selección e implementación de medidas para modificar el riesgo.

Valoración de riesgos: Según [ISO/IEC Guía 73:2002]: Proceso completo de análisis y evaluación de riesgos.

Vulnerabilidad: Debilidad en la seguridad de la información de una organización que potencialmente permite que una amenaza afecte a un activo. Según [ISO/IEC 13335-1:2004]: debilidad de un activo o conjunto de activos que puede ser explotado por una amenaza.

Sistema de Variables

Las variables se definieron como cualquier cosa que será medida y controlada y estudiar en una encuesta o estudio, por lo tanto, es muy importante, por hacer una encuesta entrevista que contribuyan a la investigación.

Arias (2016), "Un sistema de variable es el conjunto de características cambiantes que se relacionan según dependencia o función en uno investigación." por consiguiente, las variables, en el caso de estudio son nominales porque se identifican por sus nombres debiendo también definirse conceptual y operacionalmente.

Cuadro 2.
Sistema de Variables

Objetivo General	Realizar una Auditoria Informática A La Red Física Del Peaje Boconoito – Autopista José Antonio Páez
-------------------------	--

Variable independiente	Red física
Variable Dependiente	Auditoría Informática

Nota: Rodríguez (2025)

Operacionalización de las Variables

Activar variables es un proceso donde las variables de búsqueda se dividen una por una dimensiones cubiertas e indicadores de cada tipo. Las variables de investigación provienen de objetivos generales y específicos, cuando tenemos estos elementos, es necesario citar una fuente información, es decir, se refiere a la referencia de donde se obtuvo datos, así como indicar qué cuales ítems del instrumento se relacionaban con la variable, están asociados con variables a la hora de estudiar los requisitos de aplicación de la herramienta, la operación variable puede ser detallada la función, estructura, tamaño y puntero de la variable investigar. La Operacionalización de la variable de este trabajo, se representa mediante una matriz operacional en el siguiente cuadro.

Cuadro 3
Operacionalización de Variables

Variables	Definición Conceptual	Definición Operacional	Dimensiones	Indicadores	Items
Red Física	La red se puede definir, según Jimeno (2008, p.38), como un conjunto de computadores interconectados entre sí, que permiten a sus usuarios compartir información, recursos, tales como archivos, impresoras, servicios, entre otros	Las redes de datos son una de las tecnologías de comunicaciones vitales para la ejecución de una gran parte de los procesos de cualquier organización, permiten a sus miembros colaborar entre sí, además de hacer uso compartido de los recursos informáticos disponibles, bien sea por el uso de aplicaciones, compartir archivos en línea, servicio de impresión, entre otros	Gestión de seguridad física	Número de cumplimiento de Normativas Numero de Índice de incidentes Tiempo de respuesta ante incidentes físicos	Controles
Auditoria Informática	Para Iturmendi, la auditoría informática es “un conjunto de procedimientos y técnicas para evaluar y controlar total o parcialmente un sistema informático, con el fin de proteger sus activos y recursos, verificar si sus actividades se desarrollan eficientemente y de acuerdo con la normativa informática y general existente en cada empresa y para conseguir la eficacia exigida en el marco de la organización correspondiente	Esta se constituye principalmente en la revisión de las redes nodales, redes locales, protocolos, topologías de red, arquitecturas de red, como también la revisión y uso idóneo de los soportes de red como es su hardware y software.	Auditoría informática de la seguridad física en el área de redes	Probabilidad de implementación Percepción de la efectividad de las medidas Resiliencia ante amenazas físicas	Controles

Nota: Rodríguez (2025)

CAPÍTULO III

MARCO METODOLÓGICO

El contenido del marco metodológico se tomó según la estructura de la metodología utilizada, explicando la forma como fue realizada la investigación unida al proceso de la investigación científica, es por eso que Arias (2016), explico que “La metodología del proyecto incluye el tipo o tipos de investigación, las técnicas y los instrumentos que serán utilizados para llevar a cabo la indagación, es el “cómo” se realizará el estudio para responder al problema planteado”.

Para ello se definió el nivel y tipo de diseño, la población, muestra, las técnicas de recolección de datos, validez y confiabilidad de los instrumentos y la técnica de análisis, cada una fue sustentado con autores, tal como se describe a continuación.

Naturaleza de la Investigación

La investigación se ubica en el enfoque cuantitativo, que según Hernández, Fernández y Baptista (2012) se concentra en:

Generalizar los resultados encontrados en un grupo o segmento (muestra) a una colectividad mayor (universo o población). También se busca que los estudios efectuados puedan replicarse. Al final, con los estudios cuantitativos se intenta explicar y predecir los fenómenos investigados, buscando regularidades y relaciones causales entre elementos. Esto significa que la meta principal es la construcción y demostración de teorías (que explican y predicen).”.

Tipo de Investigación

El presente trabajo de investigación se enmarca en la modalidad de investigación de campo, ya que se obtiene información de primera mano, mediante la encuesta realizada a los profesionales del Peaje Boconoito. Esta investigación de campo sirve de base para realizar la clasificación de los procesos, control y asignación de métodos de trabajo para poder recoger datos directamente de la realidad donde ocurren los hechos.

Según Palella & Martins (2012) señala que el diseño de campo: "Consiste en la recolección de datos directamente de la realidad donde ocurren los hechos, sin manipular o controlar variables. Estudia los fenómenos sociales en su ambiente natural" (p.88).

Diseño de la Investigación

Al respecto, Galán (2009), define el diseño de una investigación "como un diseño básico, elaborado por un conjunto de procedimientos y técnicas específicas consideradas como adecuadas para la recolección y análisis de la información requerida por los objetivos del estudio" (p.56). Para efectos de este estudio, será un diseño no experimental definido por Palella & Martins (2012) como se indica a continuación:

El que se realiza sin manipular en forma deliberada ninguna variable. El investigador no sustituye intencionalmente las variables independientes. Se observan los hechos tal y como se presentan en su contexto real y en un tiempo determinado o no, para luego analizarlos. (p.87)

Nivel de la Investigación

De acuerdo con los razonamientos que se han desarrollado, el presente estudio posee un nivel descriptivo, en virtud que se elaboró un análisis que

incluye características detalladas en relación con los elementos representativos que conforman la evaluación física de la red de datos del Peaje Boconoito, identificando los aspectos positivos y negativos, sus particularidades, los lineamientos gerenciales aplicados y su impacto. Según Arias (2012), la investigación descriptiva consiste en:

“La caracterización de un hecho, fenómeno, individuo o grupo con el fin de establecer su estructura o comportamiento. Los resultados de este tipo de investigación se ubican en un nivel intermedio en cuanto a la profundidad de los conocimientos se refiere” (p.24).

Modalidad de la Investigación

La presente investigación se identificó como un proyecto factible, puesto que percibió a proponer soluciones a problemas presentes en la red de datos del Peaje Boconoito, por lo tanto un proyecto especial de grado según Arias, (2006):

“se trata de una propuesta de acción para resolver un problema práctico o satisfacer una necesidad. Es indispensable que dicha propuesta se acompañe de una investigación, que demuestre su factibilidad o posibilidad de realización”. Es decir se realiza una propuesta con el fin de resolver problemas prácticos acompañado de una investigación que manifieste su factibilidad.

Población y Muestra

Población

Al tratarse de un trabajo de campo cuya intencionalidad fue analizar el

fenómeno objeto de estudio, se hizo necesario trabajar con una población, la cual de acuerdo a Paella y Martins (2012) “es el conjunto de unidades de las que se desea obtener información y sobre las que se van a generar conclusiones” (p.105). Es por ello, que la población se determina cuando un total de elementos tienen aspectos iguales. En este informe investigativo, la población estuvo conformada por un total de seis (6) colaboradores que representan el 30% del personal que labora en el área técnica y gerencia de operaciones del peaje.

En tal sentido, se utilizó la totalidad de la población para realizar la investigación, lo que es una muestra censal; la cual se concibe como aquellas donde todas las unidades de investigación son consideradas como muestra, y para Tamayo y Tamayo (2007), es “una parte representativa de un conjunto, de población o universo, cuyas características debe reproducir en pequeño lo más exacto posible” (p.60).

Cuadro 4
Población y muestra

Descripción de cargos	Cantidad
Gerente de Operaciones	1
Supervisores de operaciones	3
Soporte técnico	2
Total de la población	6

Fuente: Gerencia de RRHH Peaje Boconoito (2025)

Técnicas E Instrumentos De Recolección De Datos

Técnicas de Recolección de Datos

En cuanto a las técnicas utilizadas para el estudio, se tiene lo establecido por Arias (2012), quien señala que: “las técnicas de recolección

de datos comprenden procedimientos y actividades que le permitan al investigador dar respuestas a sus preguntas de investigación” (p.53). En esta investigación la técnica utilizada fue la encuesta la cual es definida por Palella & Martins (2012) como “una técnica destinada a obtener datos de varias personas cuyas opiniones interesan al investigador” (p.123).

Instrumentos de Recolección de Datos

En cuanto al instrumento Hernández, Fernández y Baptista (2006) lo define: “como aquel que registra datos observables que representan verdaderamente a los conceptos o variables que el investigador tiene en mente” (p.43). Se infiere que el instrumento debe acercar más al investigador a la realidad de los sujetos; es decir, aporta la mejor posibilidad a la presentación fiel de las variables a estudiar. El instrumento a utilizar será el cuestionario que según Palella & Martins (2012) lo define como: “... un instrumento de investigación que forma parte de la técnica de la encuesta” (p.143). Proyectando la investigación en curso, se aplicó la técnica de la encuesta y como instrumento el cuestionario, el cual se diseñó con una escala de respuesta tipo dicotómicas, integrada por preguntas cerradas de selección simple (Si y No) para recabar la información requerida para la investigación.

Validez y Confiabilidad del Instrumento

Validez

Según Rusque (2003), “la validez representa la posibilidad de que un método de investigación sea capaz de responder a las interrogantes formuladas”, por lo tanto la validez debe estar siempre presente en todo diseño de investigación ya que permitirá conocer factores tales como la

consistencia y exactitud de los resultados y en caso de que vuelva a ser aplicada se deberán obtener resultados similares o iguales. En el caso de este estudio, la validez del instrumento se determinó en juicio de expertos, donde especialistas en metodología y contenido de la Universidad evaluarán su pertinencia y coherencia, correspondencia entre ítems, veracidad y profundidad así como su verificabilidad, y se realizarán observaciones para ajustarlo (en caso que se requiera) a los objetivos propuestos, de modo que puedan arrojar datos de verdadero interés indagatorio. Ver anexo B.

Confiabilidad

Según Hernández, Fernández y Baptista (2006) “la confiabilidad de un instrumento de medición se refiere al grado en que su aplicación repetida al mismo sujeto u objeto produce resultados iguales”(p.117). En este caso se estima el método Kuder Richardson KR-20 el cual permitió medir las preguntas dicotómicas formuladas y permitió determinar la confiabilidad de manera precisa.

Su fórmula es la siguiente:

$$Kr20 = \frac{K}{K-1} \left[1 - \left[\frac{\sum \sigma^2}{\sigma^2} \right] \right]$$

Dónde:

K= Numero de ítems que contiene el instrumento.

s²t= Varianza total de la prueba

Sp*Q =Sumatoria de la varianza individual de los ítems.

Ver anexo C.

CAPÍTULO IV

RESULTADOS

El análisis de acuerdo Hurtado (2008), constituye un proceso que involucra la clasificación, codificación, procesamiento e interpretación de la recolección de los datos, y finalmente llegar a conclusiones específicas con relación al evento en estudio, y darles respuestas a las preguntas de investigación, mediante un tratamiento estadístico previo a la interpretación. Considerando lo expuesto en este trabajo, el estudio y análisis de la información se realizó directamente de los cuadros elaborados para cada una de las partes del instrumento aplicado, en las cuales se muestra la distribución de frecuencias relativas y absolutas y porcentajes de las respuestas obtenidas.

Para facilitar la interpretación de la data se calculó porcentualmente para cada dimensión y se estableció la relación entre resultados y los objetivos de la investigación, de igual forma para la mejor comprensión serializaron gráficos de pastel. A continuación, se muestran los cuadros y gráficos con su respectivo análisis, a partir de los cuales se elaboraron algunas consideraciones del presente estudio.

Ítem 1. ¿El Peaje Boconoito – Autopista José Antonio Páez cuenta con un sistema de monitoreo para analizar los riesgos físicos que se manejan en el departamento de operaciones?

Cuadro 5
Ítem 1

Alternativa	Frecuencia Absoluta	Frecuencia Relativa
SI	6	100%
NO	0	00%
Total	10	100%

Nota: Rodríguez (2025)

NO
0%

SI
100%

Gráfico 1. Resultados cuadro 6

Análisis:

El 100 por ciento de la muestra afirma que dentro del Peaje existe un sistema de tele vigilancia o circuito cerrado de cámaras el cual funciona a la perfección siempre y cuando haya energía eléctrica, a pesar de haber una planta eléctrica, la falta de gasoil evita que la misma arranque y por ende el sistema se desconecta, los UPS tampoco están en óptimas condiciones para garantizar la operatividad de los sistemas

Ítem 2. ¿El departamento de Operaciones esta consiente de los riesgos que están expuestos y posee una matriz de riesgo para identificarlos?

Cuadro 6
Ítem 2

Alternativa	Frecuencia Absoluta	Frecuencia Relativa
SI	2	33%
NO	4	67%
Total	6	100%

Nota: Rodríguez (2025)

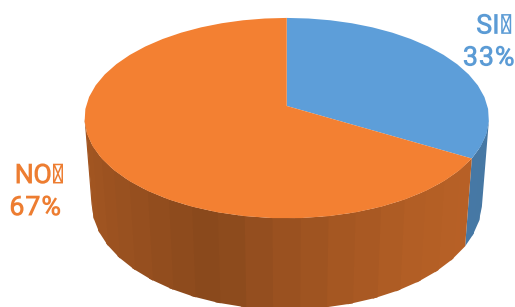


Gráfico 2. Resultados cuadro 7

Análisis:

El treinta y tres por ciento (33%) representado en este caso por el gerente general y el gerente de operaciones tan conscientes de los riesgos a los que están expuesto, sin embargo el restante sesenta y siete (67%) afirma lo contrario y esto se debe a que dentro del peaje no se lleva una matriz de riesgos ni físicos ni lógicos por lo que la vulnerabilidad del sistema e instalaciones es alta y deben tomarse medidas para garantizar la operatividad del peaje.

Ítem 3. ¿Se han evaluado los riesgos que representan los empleados que laboran en el peaje?

Cuadro 7

Ítem 3

Alternativa	Frecuencia Absoluta	Frecuencia Relativa
SI	0	00%
NO	6	100%
Total	10	100%

Nota: Rodríguez (2025)

SI
0%

NO
100%

Gráfico 3. Resultados cuadro 8

Análisis:

La totalidad de la muestra o sea el 100 por ciento asegura que no se han evaluado los riesgos sobre todo físicos que puedan presentarse en el peaje, solo hay un extintor de incendios, los bomberos tienen 3 años sin inspeccionar las instalaciones y en algunas ocasiones ha habido hurtos, la falta de seguridad se ha evidenciado, sin embargo la toma de decisiones al respecto es lenta, perjudicando así a todo el personal y las instalaciones.

Ítem 4. ¿Existe una estructura organizativa en el Peaje Boconoito – Autopista José Antonio Páez?

Cuadro 8
Ítem 4

Alternativa	Frecuencia Absoluta	Frecuencia Relativa
SI	6	100%
NO	0	00%
Total	6	100%

Nota: Rodríguez (2025)

NO
0%

SI
100%

Gráfico 4. Resultados cuadro 9

Análisis:

El 100 por ciento afirma que si hay una estructura organizativa (organigrama) dentro del peaje, lo que si no hay definido es un manual de organización donde se describan con exactitud las funciones del personal, cuando ingresa un nuevo empleado solo le dicen que hacer de manera verbal mas no hay un documento que lo respalde.

Ítem 5. ¿Las auditorías internas y externas realizadas cuentan con un historial donde se pueda validar la información?

Cuadro 9
Ítem 5

Alternativa	Frecuencia Absoluta	Frecuencia Relativa
SI	0	00%
NO	6	100%
Total	6	100%

Nota: Rodriguez(2025)

NO
0%

SI
100%

Gráfico 5. Resultados cuadro 10

Análisis:

Dentro del peaje solo se hacen auditorías externas por parte de la contraloría del estado ya que el peaje es una empresa mixta, internamente lo que hace el administrador es un cuadre de caja diario, a nivel técnico nunca se ha realizado ningún tipo de evaluación de este tipo a pesar del tiempo que ya tiene en funcionamiento el peaje.

Ítem 6. ¿El gerencia de operaciones posee políticas de seguridad de para minimizar los riesgos en las instalaciones?

Cuadro 10

Ítem 6

Alternativa	Frecuencia Absoluta	Frecuencia Relativa
SI	1	17%
NO	5	83%
Total	6	100%

Nota: Rodríguez (2025)

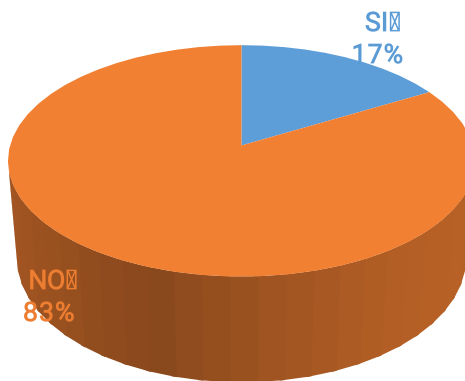


Gráfico 6. Resultados cuadro 11

Análisis:

La seguridad de cualquier sistema, edificio, red, debe garantizarse en todo momento, ya que los datos que ahí reposan son responsabilidad de quien los administra y la fuga de estos es penalizada, el diecisiete por ciento (17%) afirma que si hay políticas de seguridad, y es que solamente hay carteles que dicen acceso restringido, mas nada, mas no existe alguna otra medida tecnológica que lo respalde, el ochenta y tres (83%) restante así lo afirma, por lo que la seguridad en las instalaciones, más allá de las cámaras se hace mínimo

Ítem 7. ¿Cuentan con un manual de normas y procedimientos en el departamento de operaciones?

Cuadro 11
Item 7

Alternativa	Frecuencia Absoluta	Frecuencia Relativa
SI	0	00%
NO	6	100%
Total	6	100%

Nota: Rodríguez (2025)

SI
0%

NO
100%

Gráfico 7. Resultados cuadro 12

Análisis:

Dentro del peaje y exclusivamente dentro de la gerencia de operaciones no hay ningún tipo de documentación con respecto a qué hacer cuando sucede algún evento o suceso, la falta de manuales genera incertidumbre al momento de tomar acciones, a nivel técnico se tiene que llamar a la empresa de soporte que está en Barquisimeto y si pueden solventar vía remota lo hacen pero si se requiere intervención personal hay que esperar que envíen al mismo para brindar la solución al respecto, así lo afirmó el 100 por ciento.

Ítem 8. ¿Se han realizado evaluaciones de riesgos de los sistemas y/o estructura de red que se encuentran en el peaje?

Cuadro 12

Item 8

Alternativa	Frecuencia Absoluta	Frecuencia Relativa
SI	0	00%
NO	6	100%
Total	6	100%

Nota: Rodríguez (2025)

SI
0%

NO
100%

Gráfico 8. Resultados cuadro 13

Análisis:

El 100 por ciento afirma que desde que laboran dentro del peaje no se han hecho nunca evaluaciones de riesgos de ningún tipo por lo que la falta de control es inminente, a diario circula todo tipo de transporte y ni siquiera un mecanismo de apoyo hay por si se genera algún accidente, internamente no hay algún tipo de supervisión y si llegase a ocurrir algún evento solo hay

señalizaciones de vías de escape, mas nada.

Item 9. ¿El departamento de operaciones monitorea constantemente los riesgos que pueden generar daños graves y que pueden generar grandes pérdidas a la empresa?

Cuadro 13

Item 9

Alternativa	Frecuencia Absoluta	Frecuencia Relativa
SI	0	00%
NO	6	100%
Total	6	100%

Nota: Rodriguez(2025)

SI
0%

NO
100%

Gráfico 9. Resultados cuadro 14

Análisis

Lamentablemente el 100 por ciento afirmó que no hay ningún tipo de

monitoreo en función de la ocurrencia de algún riesgo o evento que ponga en peligro las instalaciones y por ende al personal, lo que es una gran desventaja, y justifica más aun la investigación, porque cualquier extraño puede sabotear cualquier componente físico o lógico dentro del peaje.

Item 10. ¿Los sistemas de control interno del departamento de operaciones son monitoreados y evaluados con regularidad?

Cuadro 14
Item 10

Alternativa	Frecuencia Absoluta	Frecuencia Relativa
SI	0	00%
NO	6	100%
Total	6	100%

Nota: Rodríguez (2025)

SI
0%

NO
100%

Gráfico 10. Resultados cuadro 15

Análisis

La auditoría como función de control debe ser la herramienta a utilizar para ayudar a los Funcionarios que tienen responsabilidad Administrativa, Técnica y Operacional a que no incurran en falta. Es por ello que aquí el Control debe ser creativo, inteligente, y constructivo de asesoramiento oportuno a todas las direcciones o gerencias a fin de que la toma de decisiones sea acertada, segura y se logren los objetivos, con la máxima eficiencia. La responsabilidad de un procedimiento de auditoría debe ir más allá de la búsqueda de problemas y de responsables, la visión de la auditoría debe dar la visión de la empresa en su conjunto. Por lo que saca el máximo provecho de la información real y existente, convirtiéndola en herramienta de reingeniería capaz de retroalimentar procesos o crear nuevos, la auditoría se volvió capaz de identificar necesidades, problemas y soluciones a futuro, con estas facultades el proceso de auditoría se promueve como una función permanente y a largo plazo. El 100 por ciento afirma que no hay existen indicativos de existencia de control interno.

Conclusiones del Diagnóstico

Aplicado el instrumento de recolección de datos para realizar un diagnóstico previo sobre situaciones que afectan el buen desempeño del peaje se pudo conocer en cuanto a la seguridad física de las instalaciones hay muchas carencias, no hay nada que impida el acceso de cualquier persona a las instalaciones, en cuanto a la garantía de la operatividad del sistema de cobranza, existe una planta que no siempre está activa debido a la falta de gasoil, no se han hecho supervisiones debido a los cambios de gerencia, a pesar de ser una empresa mixta la toma de decisiones no siempre es la más óptima, no hay indicadores de eficiencia de las transacciones, no hay manuales de normas y procedimientos ni de

organización. A pesar de tener buena tecnología el no tener un personal en el área técnica fijo en el peaje retrasa la solución a muchas situaciones ya que el personal a cargo se encuentra en Barquisimeto.

Todas estas debilidades entre otras encontradas afecta el buen trabajo de la organización, en cuanto a la red de datos, la misma es por fibra óptica, en ocasiones por desconocimiento del personal hacen mal uso de la misma generando vulnerabilidades, a pesar de existir cámaras de vigilancia, parecen no ser suficientes, hay constantes fallas por error humano.

CAPÍTULO V

CONCLUSIONES Y RECOMENDACIONES

Conclusiones

La auditoría a la seguridad de la red de datos en el Peaje Boconoito finalizo cumpliendo cada una de las fases propuestas.

Se ejecutaron los instrumentos necesarios para identificar las vulnerabilidades existentes en la red de datos del Peaje Boconoito.

La auditoría finalizó cumpliendo cada una de las fases propuestas. A pesar de que en la primera fase, en la recolección de información de la empresa, no se realizó a tiempo ya que gran parte de la información solicitada no existía y no se han implementado procedimientos respecto a la gestión de la red de datos, se logró detectar las primeras falencias, respectivas a la auditoria. Las visitas técnicas, también aportaron gran cantidad de observaciones, respecto a identificar vulnerabilidades en la red

Determinar los riesgos informáticos a los cuales está expuesto la red permitió establecer los procedimientos necesarios para garantizar los niveles de confidencialidad, integridad y disponibilidad de la información.

En cuanto al control de acceso, se deben implementar controles respecto a procedimientos de autorización para determinar el personal que accede al área de red y los servicios de red, como también la protección del acceso a la red y servicios y medios seguros para acceder a las mismas. Estos controles se encuentran sustentados en las guías de hallazgo como también en la declaración de aplicabilidad, depende de la organización dar mitigación a estos procedimientos.

Recomendaciones

Las recomendaciones de seguridad formuladas para la red del Peaje Boconoito permitirán implantar nuevos controles para proteger y mantener la seguridad de la información que actualmente se maneja en el área de sistemas.

Se recomienda hacer uso e implementar los controles propuestos en las guías de hallazgos como también en la declaración de aplicabilidad.

Se debería elaborar e implementar un manual de políticas de seguridad de la información que contenga la gestión de los activos de información, los activos informáticos, respecto al equipo de cómputo y de red en la empresa y la delegación de responsabilidades para dichos activos y acciones.

Una vez implementada la documentación respectiva a las políticas de seguridad y el manual de procedimientos de la red de datos, se deben coordinar actividades de gestión, con el apoyo y aprobación de la gerencia de la empresa, para optimizar el servicio de red en la organización y que los controles se apliquen en forma coherente.

El desarrollo de la presente auditoria, ayudara a la empresa a establecer un sistema de gestión de seguridad informático adecuado que le permita mitigar vulnerabilidades y amenazas presentes en su red de datos.

CAPÍTULO VI

AUDITORIA INFORMÁTICA A LA RED FISICA DEL PEAJE BOCONOITO

El presente proyecto aplicado, tiene como finalidad realizar una auditoría de seguridad a la red de datos del Peaje Boconoito, tiene por objetivo formular controles y procedimientos con el fin de establecer un sistema de gestión adecuado, identificando vulnerabilidades y amenazas por medio de pruebas de penetración y los procesos de auditoria de sistemas.

Se ejecutaron entrevistas, la primera para evaluar la seguridad física de la red de datos del Peaje Boconoito realizadas directamente al encargado de la oficina de sistemas y comunicaciones con el objetivo de conocer acerca de la administración de esta.

Para evaluar la seguridad física de la red del Peaje se tienen en cuenta los siguientes controles:

Control de áreas para los equipos de redes y comunicaciones, previniendo accesos inadecuados.

Controles de utilización de los equipos de red y de

comunicaciones, previniendo accesos inadecuados.

Controles para la protección y tendido adecuado de cables y líneas de comunicaciones.

Controles para pérdida de la información y desastres.

En la entrevista a la seguridad física de la red, se obtuvieron los siguientes hallazgos:

No existen mecanismo de control de acceso a la Gerencia de Operaciones y cualquier funcionario de la empresa puede ingresar.

El servidor no se encuentra en conjunto con los demás elementos de la red en la oficina de sistemas y comunicaciones, se encuentra Gerencia de Operaciones

No existe inventario de los equipos de red.

Se realiza mantenimiento a los equipos de red como al cableado y switches, pero no periódicamente. Esto lo realiza la empresa proveedora del servicio y lo hace en un plazo máximo de dos veces al año.

No existen equipos para monitorización de la red en la empresa.

El cableado de la red no se encuentra protegido (blindado) ni etiquetado.

El rack de comunicaciones no posee etiquetas para sus elementos y no se le ha organizado debidamente.

Lo que los equipos de cómputo y de red son vulnerables a robo.

No existen planes de contingencia en cuanto a fallas en las telecomunicaciones, lo que puede afectar la continuidad del negocio, ya que la mayoría de los procesos de la empresa, dependen del servicio de internet.

Los equipos de cómputo y de red no se encuentran protegidos en su totalidad sobre posibles amenazas físicas y ambientales.

Evaluación de dominios directamente relacionados

Los dominios directamente relacionados, son aquellos que ayudan a consecución directa del objetivo planteado para el desarrollo de la auditoria.

Los dominios directamente relacionados son A9. Control de Acceso y A13. Seguridad en las Telecomunicaciones, donde se verifican los subdominios o controles existentes en la red de la empresa a través de la ejecución de listas de chequeo diseñadas directamente de la ISO/IEC 27002:2013, cuestionarios de control, para determinar el porcentaje de riesgo a la que está sometido el dominio evaluado y por último se realiza el análisis de riesgos de acuerdo a los hallazgos encontrados durante la auditoria.

Evaluación del Dominio A9. Control de Acceso

Se procede a evaluar el primer dominio directamente relacionado, que corresponde al dominio A9. Control de Acceso, el cual tiene por objetivo verificar los controles A9.1.2 de "Control de Acceso a las Redes y Servicios Asociados", y A9.4.1 de Restricción de Acceso a la Información según la norma NTC/ISO/IEC 27002:2013. Para esto, se ejecutaran Listas de Chequeo con cada uno de los subdominios a evaluar, cuestionarios de control y se realizara el análisis de riesgos con los hallazgos obtenidos.

Ejecución de listas de chequeo del dominio A9. Control de Acceso

Para el primer dominio directamente relacionado, el cual es el A9. Control de Acceso, se evalúan los siguientes subdominios:

A9.1.2. Control de Acceso a las Redes y Servicios Asociados

A9.4.1 Restricción de Acceso a la Información

Tras la ejecución de la lista de chequeo para verificar los controles del primer dominio A9. Control de Acceso, en la red de datos del Peaje Boconoito, se obtienen los siguientes resultados:

No existen procedimientos de autorización para determinar a quien

se permiten acceder a las redes y servicios de red.

No existen controles y procedimientos de gestión para proteger el acceso a la red y los servicios de red.

No existe monitoreo del uso de los servicios de red.

No existen controles de acceso físico o lógico para el aislamiento de aplicaciones, datos y sistemas críticos.

Ejecución de cuestionarios de control del dominio A9. Control de Acceso

Estos cuestionarios cuantitativos, se realizan en conjunto con el encargado de la oficina de sistemas y comunicaciones del Peaje Boconoito, donde se da una calificación numérica, el cual va en una escala de menor a mayor, de 1 a 5 a los procesos para determinar su nivel de vulnerabilidad, donde 1 significa que no es importante tener el control y 5 significa que es importante que se tenga este.

Se aplica el cuestionario de control al primer dominio directamente relacionado, que corresponde a A9. Control de Acceso, donde se evalúa cuantitativamente los hallazgos obtenidos en la lista de chequeo. En conjunto se evalúan los procesos que corresponden a sus subdominios los cuales son A9.1.2. Control de acceso a las redes y servicios asociados y A9.4.1. Restricción de acceso a la información. El resumen del cuestionario de control se encuentra en la siguiente tabla:

Cuadro 15

Resultados del cuestionario en el dominio A9. Control de Acceso

Pregunta	Si	No	N/A	Observaciones
¿Las redes y servicios de red solo tiene el acceso el usuario autorizado?	3			Los servicios de red solo accede el encargado pero al área de red accede cualquier funcionario.

¿Existen procedimientos de autorización para determinar a quién se permiten acceder a las redes y servicios de red?		4		No existen controles para determinar quién accede al área de red.
¿Existen controles y procedimientos de gestión para proteger el acceso a red y a los servicios de red?		4		No existen controles para proteger el acceso al área de red.
¿Existen medios usados para acceder a las redes y servicios de red (uso de VPN o redes inalámbricas)?		3		No existen medios de acceso a la red como VPN pero si existe la red inalámbrica.
¿Existen requisitos de autenticación de usuarios para acceder a diversos servicios de red?	2			Si existen requisitos de autenticación para acceder a la red.
¿Existe monitoreo del uso de los servicios de red?		5		No existe monitoreo de los servicios de red para detectar fallas.
¿Existen menús para controlar acceso a la funcionalidad de las aplicaciones?	1			Si existen control de accesos
¿Existe control de los datos a los que puede tener acceso un usuario particular?	1			Si existe control de los datos
¿Existe control de los derechos de acceso de otras aplicaciones?	1			Si existen controles de acceso basados en roles
¿Existe limitación de la información contenida en las salidas?	3			Controles de salida mínimos
¿Existen controles de acceso físico o lógico para el aislamiento de aplicaciones, datos de aplicaciones o sistemas críticos?		5		No existen controles para asegurar la protección y la integridad de los datos dentro de los sistemas de aplicación y redes.
TOTALES	11	21		
PUNTAJE TOTAL	32			

Fuente: Rodríguez (2025)

Con los resultados, se procede a obtener el porcentaje del riesgo, que corresponde al cuestionario del dominio A9. Control de Acceso, donde se aplica el siguiente proceso:

Porcentaje de riesgo parcial = $(\text{Total SI} * 100) / \text{Total Porcentaje de riesgo} = 100 - \text{Porcentaje de riesgo parcial}$

De acuerdo a los resultados, se procede a realizar el respectivo cálculo:
Porcentaje de riesgo parcial = $(11 * 100) / 33 = 33.33$

Porcentaje de riesgo = $100 - 33.33 = 66.66$

Para determinar el nivel de riesgo total, se tiene en cuenta la siguiente categorización:

1% - 30% = Riesgo Bajo
31% - 70% = Riesgo Medio
71% - 100% = Riesgo Alto

De acuerdo a los resultados, se obtiene la siguiente información final respecto al cálculo del porcentaje y nivel de riesgo del dominio A9. Control de Acceso, según el cuestionario aplicado:

- Porcentaje de riesgo parcial = 33,33%
- Porcentaje de riesgo = **66,66%**
- Impacto según relevancia del proceso: **Riesgo Medio**

El formato diligenciado sobre el cuestionario de control para evaluar los controles del dominio A9. Control de Acceso y sus procesos seleccionados para la auditoria a la seguridad de la red de datos de la empresa Peaje Boconoito.

Análisis de riesgos del dominio A9. Control de Acceso

Se procede a realizar el análisis de riesgos correspondiente al dominio A9. Control de Acceso, con los hallazgos encontrados en las listas de chequeo y la evaluación obtenida de los cuestionarios de control. De acuerdo al porcentaje de riesgos evaluado en los cuestionarios del presente dominio, este se clasifica de Riesgo Medio.

Listado de vulnerabilidades para el dominio A9. Control de Acceso

El listado de vulnerabilidades se obtiene al verificar la ausencia o no cumplimiento de los controles realizados en las listas de chequeo y los cuestionarios de control. Para el dominio A9. Control de Acceso, se identificaron las siguientes vulnerabilidades:

Cuadro 16.

Listado de vulnerabilidades del dominio A9. Control de Acceso

Ítem	Vulnerabilidad
R001	No existen procedimientos de autorización para determinar a quién se permiten acceder a las redes y servicios de red.
R002	No existen controles y procedimientos de gestión para proteger el acceso a red y a los servicios de red.
R003	No existen medios usados para acceder a las redes y servicios de red como el uso de VPN.
R004	No existe monitoreo del uso de los servicios de red
R005	No existen controles de acceso físico o lógico para asegurar la protección y la integridad de los datos dentro de los sistemas de aplicación y redes.

Fuente: Rodríguez (2025)

Calculo de análisis de riesgo para el dominio A9. Control de Acceso

De acuerdo a las vulnerabilidades encontradas en el dominio A9. Control de Acceso, se procede a hacer una valoración estimando la probabilidad por el impacto acerca de las consecuencias que podrían traer y la probabilidad de ocurrencia. El cálculo del análisis de riesgo para cada una de las vulnerabilidades encontradas en el dominio A9. Control de Acceso, se muestra en la siguiente tabla:

Cuadro 17.
Calculo de análisis de riesgo del dominio A9. Control de Acceso

No	Vulnerabilidad	Probabilidad	Impacto	Evaluación del Riesgo
R001	No existen procedimientos de autorización para determinar a quién se permiten acceder a las redes y servicios de red.	3	2	6
R002	No existen controles y procedimientos de gestión para proteger el acceso a red y a los servicios de red.	3	2	6
R003	No existen medios usados para acceder a las redes y servicios de red como el uso de VPN.	4	3	12
R004	No existe monitoreo del uso de los servicios de red	4	4	16

R005	No existen controles de acceso físico o lógico para asegurar la protección y la integridad de los datos dentro de los sistemas de aplicación y redes.	4	4	16
------	---	---	---	----

Fuente: Rodríguez (2025)

Matriz de riesgos para el dominio A9. Control de Acceso

Se trasladan los resultados obtenidos en el cálculo del análisis de riesgos del dominio A9. Control de Acceso a una matriz para poder observar fácilmente los resultados obtenidos, donde se asigna con colores para cada una de la celdas asociadas a la escala (Verde=Riesgo Bajo, Amarillo=Riesgo Medio, Rojo=Riesgo Alto) y de esta manera poder dictaminar el tratamiento para los riesgos evaluados. La matriz de riesgo para el dominio A9. Control de Acceso con sus riesgos evaluados se muestra en la siguiente tabla:

Cuadro 18

Matriz de riesgos del dominio A9. Control de Acceso

P R O B A B I L I D A D	4				R004, R005
	3			R003	
	2			R001, R002	
	1				
		1	2	3	4
IMPACTO					

Fuente: Rodríguez (2025)

De acuerdo a la matriz de riesgo evaluada, los riesgos que necesitan

mayor tratamiento son los que corresponde al R004 (No existe monitoreo del uso de los servicios de red) y R005 (No existen controles de acceso físico o lógico para asegurar la protección y la integridad de los datos dentro de los sistemas de aplicación y redes). Estos son los que se encuentran a mayor escala y se deben tratar inmediatamente. El R003 (No existen medios usados para acceder a las redes y servicios de red como el uso de VPN), también debe tratarse, ya que de acuerdo a la escala se considera de riesgo alto, pero en menor grado a los dos anteriores. Los riesgos R001 Y R002 se clasifican como riesgo medio, de igual manera se deben establecer controles para que su probabilidad de ocurrencia no se incremente y generen un impacto mayor.

Ejecución de listas de chequeo del dominio A11. Seguridad Física y del Entorno

Para el último dominio indirectamente relacionado, el cual es el A11. Seguridad Física y del Entorno, se evalúan los siguientes subdominios:

Subdominio A11.2.1 Ubicación y Protección de los Equipos

Subdominio A11.2.3 Seguridad del Cableado

El tercer dominio indirectamente relacionado es el A11. Seguridad Física y del Entorno, donde se verifican el cumplimiento de dos subdominios o controles existentes en la empresa, se obtienen los siguientes resultados:

Las instalaciones de procesamiento de información y de redes no están ubicadas cuidadosamente para reducir el riesgo de que las personas no autorizadas puedan acceder a ellas.

No se han adoptado controles para minimizar el riesgo de amenazas físicas y ambientales potenciales como robo, incendio, explosivos, humo, agua, polvo, vibración, efectos químicos, interferencia en el suministro eléctrico, interferencia en las comunicaciones, radiación electromagnética y

vandalismo. Existen cámaras de vigilancia y alarmas contra incendio pero estas no abarcan toda el área de la empresa.

Las líneas de energía eléctrica y de telecomunicaciones que entran a las instalaciones de procesamiento de información no o cuentan con protección.

Ejecución de cuestionarios del dominio A11. Seguridad Física y del Entorno

Estos cuestionarios cuantitativos, se realizan en conjunto con el encargado de la oficina de sistemas y comunicaciones del Peaje Boconoito, donde se da una calificación numérica, el cual va en una escala de menor a mayor, de 1 a 5 a los procesos para determinar su nivel de vulnerabilidad, donde 1 significa que no es importante tener el control y 5 significa que es importante que se tenga este.

De los dominios indirectamente relacionados, el único que arroja hallazgos en su verificación es el dominio A11. Seguridad Física y del Entorno donde se procede a evaluar evalúa cuantitativamente sus resultados. En conjunto se evalúan los procesos que corresponde a los subdominios A11.2.1. Ubicación y protección de los equipos y A11.2.3. Seguridad del cableado. El resumen de los resultados del cuestionario de control se muestra en la siguiente tabla:

Cuadro 19.

Resultados del cuestionario en el dominio A11. Seguridad Física y del Entorno

Pregunta	Si	No	N/A	Observaciones
¿Las instalaciones de procesamiento de información y de redes están ubicadas cuidadosamente para reducir el riesgo de que las personas no autorizadas puedan acceder a ellas?		5		Los equipos de red no están ubicados en su lugar idóneo. No hay ordenamiento del rack y el servidor no se encuentra en el área de red.

¿Se han adoptado controles para minimizar el riesgo de amenazas físicas y ambientales potenciales como robo, incendio, explosivos, humo, agua, polvo, vibración, efectos químicos, interferencia en el suministro eléctrico, interferencia en las comunicaciones, radiación electromagnética y vandalismo?		4		Existen cámaras de vigilancia y alarmas contra incendio, pero estas no abarcan toda la empresa, por lo que son vulnerables y el cableado UTP es de cobre y este es vulnerable a interferencias.
¿Se hace seguimiento de las condiciones ambientales tales como temperatura y humedad, para determinar las condiciones que puedan afectar adversamente la operación de las instalaciones de procesamiento de información y de redes?	4			El seguimiento lo hace la empresa proveedora, pero no lo realiza periódicamente. Es preciso que esto se gestione con el personal de la misma empresa.
Las líneas de energía eléctrica y de telecomunicaciones que entran a las instalaciones de procesamiento de información, ¿son subterráneas o cuentan con otra protección alternativa?		5		El cableado UTP de cobre no cuenta con protección de blindaje.
¿Los cables de energía eléctrica se encuentran separados de los cables de telecomunicaciones para evitar interferencias?	3			El cableado si se encuentra separado, pero existen interferencias por ser cableado de cobre. Es necesario cambiar a fibra óptica.

¿Existen controles para inspecciones físicas al cableado?	4			El seguimiento lo hace la empresa proveedora, pero no lo realiza periódicamente. Es preciso que esto se gestione con el personal de la misma empresa.
TOTALES	11	14		
PUNTAJE TOTAL	25			

Fuente: Rodríguez (2025)

Con los resultados, se procede a obtener el porcentaje del riesgo, que corresponde al cuestionario del dominio A11. Seguridad Física y del Entorno, donde se aplica el siguiente proceso:

Porcentaje de riesgo parcial = $(\text{Total SI} * 100) / \text{Total Porcentaje de riesgo} = 100 - \text{Porcentaje de riesgo parcial}$

De acuerdo a los resultados, se procede a realizar el respectivo cálculo:
 Porcentaje de riesgo parcial = $(11 * 100) / 25 = 44$

Porcentaje de riesgo = $100 - 44 = 56$

Para determinar el nivel de riesgo total, se tiene en cuenta la siguiente categorización:

1% - 30% = Riesgo Bajo

31% - 70% = Riesgo Medio

71% - 100% = Riesgo Alto

De acuerdo a los resultados, se obtiene la siguiente información final respecto al cálculo del porcentaje y nivel de riesgo del dominio A11. Seguridad Física y del Entorno, según el cuestionario aplicado:

Porcentaje de riesgo parcial = 44%

Porcentaje de riesgo = **56 %**

Impacto según relevancia del proceso: **Riesgo Medio**

Análisis de riesgos del dominio A11. Seguridad Física y del Entorno

Se procede a realizar el análisis de riesgos correspondiente al dominio A11. Seguridad Física y del Entorno, con los hallazgos encontrados en las listas de chequeo y la evaluación obtenida de los cuestionarios de control. De acuerdo al porcentaje de riesgos evaluado en los cuestionarios del presente dominio, este se clasifica de Riesgo Medio.

Listado de vulnerabilidades para el dominio A11. Seguridad Física y del Entorno

El listado de vulnerabilidades se obtiene al verificar la ausencia o no cumplimiento de los controles realizados en las listas de chequeo y los cuestionarios de control. Para el dominio A11. Seguridad Física y del Entorno, se identificaron las siguientes vulnerabilidades:

Cuadro 20. Listado de vulnerabilidades del dominio A11. Seguridad Física y del Entorno

Ítem	Vulnerabilidad
R019	Las instalaciones de procesamiento de información y de redes no están ubicadas cuidadosamente para reducir el riesgo de que las personas no autorizadas puedan acceder a ellas
R020	No se han adoptado controles para minimizar el riesgo de amenazas físicas y ambientales potenciales como robo, incendio, explosivos, humo, agua, polvo, vibración, efectos químicos, interferencia en el suministro eléctrico, interferencia en las comunicaciones, radiación electromagnética y vandalismo

R021	El seguimiento y mantenimiento de las de las condiciones ambientales tales como temperatura y humedad, para determinar las condiciones que puedan afectar adversamente la operación de las instalaciones de procesamiento de información e instalación de redes no lo realiza el personal encargado de la misma empresa.
R022	Las líneas de telecomunicaciones que entran a las instalaciones de procesamiento de información no cuentan con protección alternativa.

Fuente: Rodríguez (2025)

Calculo de análisis de riesgo para dominio A11. Seguridad Física y del Entorno

De acuerdo a las vulnerabilidades encontradas en el dominio A11. Seguridad Física y del Entorno, se procede a hacer una valoración estimando la probabilidad por el impacto acerca de las consecuencias que podrían traer y la probabilidad de ocurrencia. El cálculo del análisis de riesgo para cada una de las vulnerabilidades encontradas en el dominio A11. Seguridad Física y del Entorno, se muestra en la siguiente tabla:

Cuadro 21. Calculo de análisis de riesgo del dominio A11. Seguridad Física y del Entorno

No	Vulnerabilidad	Probabilidad	Impacto	Evaluación del Riesgo
R019	Las instalaciones de procesamiento de información y de redes no están ubicadas cuidadosamente para reducir el riesgo de que las personas no autorizadas puedan acceder a ellas	4	3	12

R020	No se han adoptado controles para minimizar el riesgo de amenazas físicas y ambientales potenciales como robo, incendio, explosivos, humo, agua, polvo, vibración, efectos químicos, interferencia en el suministro eléctrico, interferencia en las comunicaciones, radiación electromagnética y vandalismo	2	4	8
R021	El seguimiento y mantenimiento de las de las condiciones ambientales tales como temperatura y humedad, para determinar las condiciones que puedan afectar adversamente la operación de las instalaciones de procesamiento de información e instalación de redes no lo realiza el personal encargado de la misma empresa.	4	2	8
R022	Las líneas de telecomunicaciones que entran a las instalaciones de procesamiento de información no cuentan con protección alternativa.	4	3	12

Fuente: Rodríguez (2025)

Matriz de riesgo para dominio A11. Seguridad Física y del Entorno

Se trasladan los resultados obtenidos en el cálculo del análisis de riesgos del dominio A11. Seguridad Física y del Entorno a una matriz para poder observar fácilmente los resultados obtenidos, donde se asigna con colores para cada una de la celdas asociadas a la escala (Verde=Riesgo Bajo, Amarillo=Riesgo Medio, Rojo=Riesgo Alto) y de esta manera poder dictaminar el tratamiento para los riesgos evaluados. La matriz de riesgo para el dominio

A11. Seguridad Física y del Entorno con sus riesgos evaluados se muestra en la tabla 22

Cuadro 22.

Matriz de riesgos del dominio A11. Seguridad Física y del Entorno

P R O B A B I L I D A D	4		R021	R019, R022	
	3				
	2				R020
	1				
		1	2	3	4
IMPACTO					

Fuente: Autor

De acuerdo a la matriz de riesgo evaluada para este dominio, los riesgos que se debe realizar el tratamiento inmediato, son los que corresponden a R019 (Las instalaciones de procesamiento de información y de redes no están ubicadas cuidadosamente para reducir el riesgo de que las personas no autorizadas puedan acceder a ellas), R022 (El seguimiento y mantenimiento de las instalaciones de redes no lo realiza el personal encargado de la misma empresa) y R023 (Las líneas de telecomunicaciones que entran a las instalaciones de procesamiento de información no cuentan con protección alternativa). Se identifican otros dos riesgos de clasificación alta, como lo son R021 y R020, que a pesar son de menor grado, también se debe realizar el tratamiento respectivo. Todos los riesgos evaluados en el dominio A11. Seguridad Física y del Entorno, se clasifican como Riesgo Alto y se debe realizar el plan de actuación correctiva correspondiente.

Bibliografía

ESTRADA, Alejandro. Seguridad en Redes. Estrategias de Seguridad en Redes. Madrid, España. 2016

FERRER, RODRIGO. Metodología de Análisis de Riesgo. Bogotá. Colombia, 2006. Empresa: SISTESEG.

ITURMENDI ACHA, Juan José. Auditoria Informática en la Empresa. Madrid, España. 1994.

NTC-ISO-IEC 27001:2013. Tecnología de la Información. Técnicas de Seguridad. Sistemas de Gestión de la Seguridad de la Información. Requisitos.

NTC-ISO-IEC 27002:2013. Tecnología de la Información. Técnicas de Seguridad. Código de Práctica para Controles de Seguridad de la Información.

PEREZ, Pablo Gonzales. GARCES, German. DE LA CAMARA, José Miguel. Pentesting con Kali. Madrid, España. 2013

POBLETE, Victoria. Procedimiento de Seguridad del Cableado. Ministerio de Salud. Santiago de Chile, 2013.

SOLARTE, Nicolás Javier. GUSTIN LOPEZ, Enith. HERNANDEZ, Ricardo Javier. Manual de Procedimientos para llevar a la Práctica la Auditoria Informática. San Juan de Pasto, Colombia. 2012.

TAPIADOR, Ángeles Sanz. Controles y Auditoria en Redes de Datos. Guía Práctica. Escuela Politécnica Superior. Facultad de Ingeniería Técnica en Informática de Gestión. Madrid, España. 2010.

VARGAS AVILES, Julio Rito. Conceptos sobre Auditoria Informática. Colombia, 2009. Universidad Nacional de ingeniería. Facultad de Ingeniería de Sistemas. Departamento de Ingeniería.

NORMA ISO/IEC 27000. Portal ISO 27000 en Español [en línea]. [Consultado el 26 de Agosto de 2016]. Disponible en: <<http://www.iso27000.es/>>

AUDITORIA INFORMÁTICA. Construcción de un concepto universal de auditoria [en línea]. [Consultado el 14 de Marzo de 2025] Disponible en: <<http://fccea.unicauca.edu.co/old/tgarf/tgarfse1.html>>

AUDITORIA INFORMÁTICA. Metodología de la Auditoria Informática [en línea]. [Consultado el 12 de Abril de 2025]. Disponible en: <<http://www.ub.edu.ar/catedras/ingenieria/auditoria/tpmetodo/tpmetodo2.htm#p2-1-1>>

SEGURIDAD INFORMÁTICA. Capítulo 1. Estrategias de Seguridad [en línea]. [Consultado el 12 de Abril de 2025]. Disponible en: <http://www.scoop.it/doc/download/cvdXLLFB5B3H35NMF97_qdw>

OWASP ZAP Zed Attack Proxy Project [en línea]. [Consultado el 7 de Octubre de 2016]. Disponible en: <https://www.owasp.org/index.php/OWASP_Zed_Attack_Proxy_Project>

UPGUARD. Web scanner vulnerabilty [en línea]. [Consultado el 11 de Octubre de 2016]. Disponible en: <<https://www.upguard.com/>>

NESSUS. Tenable Network Security [en línea]. [Consultado el 13 de Octubre de 2016]. <Disponible en: <https://www.tenable.com/products/nessus-vulnerability-scanner>>

NVD. National Vulnerability Database National Cyber Awareness System [en línea]. [Consultado el 25 de Octubre de 2016]. <Disponible en: <https://nvd.nist.gov/>>

NVD. National Vulnerability Database Common Vulnerability Scoring System Version 2 Calculator [en línea]. [Consultado el 25 de Octubre de 2016]. <Disponible en: <https://nvd.nist.gov/CVSS/CVSS-v2-Calculator>>

JUMPSTART. JumpStart WPS para Windows [en línea] [Consultado el 28 de Octubre de 2016]. <Disponible en: <http://pokoxemo.blogspot.com.co/2014/06/descarga-jumpstart-wps-para-windows.html>>

SGSI. Capítulo 3 Análisis de riesgos, identificación de amenazas. [en línea]. [Consultado el 10 de Noviembre de 2016]. <Disponible en: http://datateca.unad.edu.co/contenidos/233003/modulo/modulo-233003-online/3231_identificacin_de_amenazas.html>

PORTAL ISO 27002. Control de Acceso [en línea]. [Consultado el 21 de Noviembre de 2016]. <Disponible en: http://www.iso27000.es/iso27002_9.html>

PORTAL ISO 27002. Seguridad en las Telecomunicaciones [en línea]. [Consultado el 21 de Noviembre de 2016]. <Disponible en: http://www.iso27000.es/iso27002_13.html>

PORTAL ISO 27002. Seguridad Física y del Entorno [en línea]. [Consultado el 21 de Noviembre de 2016]. <Disponible en: http://www.iso27000.es/iso27002_11.html>

ISO 27002 WIKI. Procedimientos y responsabilidades de operación [en línea]. [Consultado el 24 de Noviembre de 2016]. <Disponible en: <https://iso27002.wiki.zoho.com/10-1-Procedimientos-y-responsabilidades-de-operaci%C3%B3n.html>>

ISACA. La integridad de los datos [en línea]. [Consultado el 28 de Noviembre de 2016] <Disponible en: http://www.isaca.org/Journal/archives/2011/Volume-6/Pages/Data-Integrity-Information-Securitys-Poor-Relation-spanish.aspx?utm_referrer=>>

anexos

Anexo A
CUESTIONARIO

	CUESTIONARIO	SI	NO
1	¿El Peaje Boconoito – Autopista José Antonio Páez cuenta con un sistema para analizar los riesgos en los sistemas que se manejan en el departamento de operaciones?		
2	¿El departamento de Operaciones esta consiente de los riesgos que están expuestos y posee una matriz de riesgo para identificarlos?		
3	¿Se han evaluado los riesgos que representan los empleados que laboran en el departamento de operaciones?		
4	¿Existe una estructura organizativa en el Peaje Boconoito – Autopista José Antonio Páez ?		
5	¿Las auditorías internas y externas realizadas cuentan con un historial donde se pueda validar la información?		
6	¿El departamento de operaciones posee políticas de seguridad de para minimizar los riesgos en los sistemas?		
7	¿Cuentan con un manual de normas y procedimientos en el departamento de operaciones?		
8	¿Periódicamente se han realizado evaluaciones de riesgos de los sistemas que se encuentran en el departamento de operaciones?		
9	¿El departamento de operaciones monitorea constantemente los riesgos que pueden generar daños graves y que pueden generar grandes pérdidas a la empresa?		
10	¿Los sistemas de control interno del departamento de operaciones son monitoreados y evaluados con regularidad?		

Anexo b

Validaciones



REPÚBLICA BOLIVARIANA DE VENEZUELA
UNIVERSIDAD NACIONAL EXPERIMENTAL
DE LOS LLANOS OCCIDENTALES
EZEQUIEL ZAMORA
VICERRECTORADO ACADÉMICO
PROGRAMA CIENCIAS BÁSICAS Y APLICADAS
SUBPROGRAMA INGENIERÍA EN INFORMÁTICA



FORMATO DE VALIDACION DE INSTRUMENTO

Apellidos y Nombres:

Prof. Danyely Siles

Título de la Investigación: AUDITORIA INFORMÁTICA A LA RED FISICA
DEL PEAJE BOCONOITO – AUTOPISTA JOSÉ ANTONIO PÁEZ

Instrucciones

7. Lea cada uno de los ítems.
8. Utilice el siguiente formato para indicar cada enunciado que se representa, marcado con una equis (X) en el espacio señalado, de acuerdo a la siguiente escala:
 - (A) Dejar
 - (B) Modificar
 - (C) Eliminar
 - (D) Incluir otra Pregunta
9. Si desea plantear algunas sugerencias para mejorar este instrumento, utilice el espacio correspondiente a observaciones.

N° de Ítems	A	B	C	D
01	X			
02	X			
03	X			
04		X		
05	X			
06	X			
07	X			
08		X		
09	X			
10	X			

Leyenda: A= Dejar, B= Modificar, C= Eliminar, D= Incluir otra Pregunta.

Observaciones:

Verificar ortografía y colocar sugerencias

Autor: Rodríguez, Omar José

Evaluator(a): Darjah Slier

Profesión: Ing. Computación

Fecha: 20/05/2025 Firma: Darjah Slier



REPÚBLICA BOLIVARIANA DE VENEZUELA
UNIVERSIDAD NACIONAL EXPERIMENTAL
DE LOS LLANOS OCCIDENTALES
EZEQUIEL ZAMORA
VICERRECTORADO ACADÉMICO
PROGRAMA CIENCIAS BÁSICAS Y APLICADAS
SUBPROGRAMA INGENIERÍA EN INFORMÁTICA



PROGRAMA
CIENCIAS BÁSICAS
Y APLICADAS VPDS

Acta de Validación

Yo, Daryelugo Salas titular de la
Cedula de Identidad N° 13.729.609, por medio de la
presente hago constar que he leído y evaluado el instrumento de recolección
de datos correspondiente al Trabajo titulado: **AUDITORIA INFORMÁTICA A
LA RED FISICA DEL PEAJE BOCONOITO – AUTOPISTA JOSÉ ANTONIO
PÁEZ**, presentado por el Bachiller: **Rodriguez, Omar**, para optar al Título de
Ingeniero e Informática, el cual apruebo en calidad de validador.

En Barinas a los 20 días del mes de
Mayo 2025.

Daryelugo Salas
Firma del Experto

13.729.609
Cédula de Identidad



REPÚBLICA BOLIVARIANA DE VENEZUELA
UNIVERSIDAD NACIONAL EXPERIMENTAL
DE LOS LLANOS OCCIDENTALES
EZEQUIEL ZAMORA
VICERRECTORADO ACADÉMICO
PROGRAMA CIENCIAS BÁSICAS Y APLICADAS
SUBPROGRAMA INGENIERÍA EN INFORMÁTICA



FORMATO DE VALIDACION DE INSTRUMENTO

Apellidos y Nombres:

Título de la Investigación: AUDITORIA INFORMÁTICA A LA RED FISICA
DEL PEAJE BOCONOITO – AUTOPISTA JOSÉ ANTONIO PÁEZ

Instrucciones

4. Lea cada uno de los ítems.
5. Utilice el siguiente formato para indicar cada enunciado que se representa, marcado con una equis (X) en el espacio señalado, de acuerdo a la siguiente escala:
 - (A) Dejar
 - (B) Modificar
 - (C) Eliminar
 - (D) Incluir otra Pregunta
6. Si desea plantear algunas sugerencias para mejorar este instrumento, utilice el espacio correspondiente a observaciones.

Nº de Ítems	A	B	C	D
01	X			
02	X			
03	X			
04	X			
05	X			
06	X			
07	X			
08	X			
09	X			
10	X			

Leyenda: A= Dejar, B= Modificar, C= Eliminar, D= Incluir otra Pregunta.

Observaciones:

Autor: Rodríguez, Omar José

Evaluador(a): Yuriana Rivas

Profesión: Ing. de Sistemas

Fecha: 20/05/2025

Firma:

[Firma manuscrita]



REPÚBLICA BOLIVARIANA DE VENEZUELA
UNIVERSIDAD NACIONAL EXPERIMENTAL
DE LOS LLANOS OCCIDENTALES
EZEQUIEL ZAMORA
VICERRECTORADO ACADÉMICO
PROGRAMA CIENCIAS BÁSICAS Y APLICADAS
SUBPROGRAMA INGENIERÍA EN INFORMÁTICA



Acta de Validación

Yo, YUBAIMA RIVAS titular de la
Cedula de Identidad N° V- 12.199.354, por medio de la
presente hago constar que he leído y evaluado el instrumento de recolección
de datos correspondiente al Trabajo titulado: **AUDITORIA INFORMÁTICA A
LA RED FISICA DEL PEAJE BOCONOITO – AUTOPISTA JOSÉ ANTONIO
PÁEZ**, presentado por el Bachiller: **Rodriguez, Omar**, para optar al Título de
Ingeniero e Informática, el cual apruebo en calidad de validador.

En Barinas a los 20 días del mes de
Mayo 2025.

Firma del Experto

V- 12.199.354

Cédula de Identidad



REPÚBLICA BOLIVARIANA DE VENEZUELA
UNIVERSIDAD NACIONAL EXPERIMENTAL
DE LOS LLANOS OCCIDENTALES
EZEQUIEL ZAMORA
VICERRECTORADO ACADÉMICO
PROGRAMA CIENCIAS BÁSICAS Y APLICADAS
SUBPROGRAMA INGENIERÍA EN INFORMÁTICA



FORMATO DE VALIDACION DE INSTRUMENTO

Apellidos y Nombres:

APELLIDOS: ROMÁN L LELOS M

Título de la Investigación: AUDITORIA INFORMÁTICA A LA RED FISICA
DEL PEAJE BOCONOITO – AUTOPISTA JOSÉ ANTONIO PÁEZ

Instrucciones

1. Lea cada uno de los ítems.
2. Utilice el siguiente formato para indicar cada enunciado que se representa, marcado con una equis (X) en el espacio señalado, de acuerdo a la siguiente escala:
 - (A) Dejar
 - (B) Modificar
 - (C) Eliminar
 - (D) Incluir otra Pregunta
3. Si desea plantear algunas sugerencias para mejorar este instrumento, utilice el espacio correspondiente a observaciones.

N° de ítems	A	B	C	D
01	X			
02	X			
03	X			
04	X			
05	X			
06	X			
07	X			
08	X			
09	X			
10	X			

Leyenda: A= Dejar, B= Modificar, C= Eliminar, D= Incluir otra Pregunta.

Observaciones:

Autor: Rodríguez, Omar José

Evaluador(a): LEON M ROMAN L

Profesión: MSc Administración Mención Gerencia General

Fecha: 20/05/25 Firma: *[Firma]*



UNELLEZ

REPÚBLICA BOLIVARIANA DE VENEZUELA
UNIVERSIDAD NACIONAL EXPERIMENTAL
DE LOS LLANOS OCCIDENTALES
EZEQUIEL ZAMORA
VICERRECTORADO ACADÉMICO
PROGRAMA CIENCIAS BÁSICAS Y APLICADAS
SUBPROGRAMA INGENIERÍA EN INFORMÁTICA



PROGRAMA
CIENCIAS BÁSICAS
Y APLICADAS VPDS

Acta de Validación

Yo, Leticia M. Román L. titular de la
Cédula de Identidad N° 8.625602, por medio de la
presente hago constar que he leído y evaluado el instrumento de recolección
de datos correspondiente al Trabajo titulado: **AUDITORIA INFORMÁTICA A
LA RED FISICA DEL PEAJE BOCONOITO – AUTOPISTA JOSÉ ANTONIO
PÁEZ**, presentado por el Bachiller: **Rodriguez, Omar**, para optar al Título de
Ingeniero e Informática, el cual apruebo en calidad de validador.

En Barinas a los 20 días del mes de
Mayo 2025.

Leticia M. Román L.

Firma del Experto

86256021

Cédula de Identidad